

КОНФИДЕНЦИАЛЬНО

РУКОВОДСТВО ПО РАЗВЁРТЫВАНИЮ И СОПРОВОЖДЕНИЮ

Установка, настройка и эксплуатация

Версия документа: 1.54

Дата: 12.08.2026

Экземпляр передан: Акционерное общество «Холдинговая компания „Остров Мечты“»
(ИНН 9725171970)

© 2026 Мякотных Сергей Михайлович. Все права защищены.

ОГРАНИЧЕНИЯ НА ИСПОЛЬЗОВАНИЕ ДОКУМЕНТА

Правообладатель: Мякотных Сергей Михайлович

Получатель: Акционерное общество «Холдинговая компания „Остров Мечты“» (ИНН 9725171970)

- 1. Правообладатель.** Исключительное право на настоящий документ и на описанную в нём систему, включая её исходный код, интерфейсы и принятые в ней решения, принадлежит правообладателю. Передача документа не влечёт перехода к Получателю каких-либо прав на систему или на её составные части.
- 2. Назначение передачи.** Документ передан Получателю исключительно для ознакомления с системой и принятия решения о её приобретении и внедрении. Использование документа в иных целях не разрешается.
- 3. Запрет передачи третьим лицам.** Документ, его части и любые производные материалы - копии, выдержки, переводы, изложения, презентации, снимки экрана - не подлежат передаче, пересылке, публикации и показу третьим лицам, включая подрядчиков и консультантов Получателя, без предварительного письменного согласия правообладателя. Внутри организации Получателя документ доводится только до работников, которым он необходим для оценки системы.
- 4. Запрет иного использования.** Содержащиеся в документе сведения не подлежат использованию и передаче в целях, не предусмотренных пунктом 2 настоящего листа.
- 5. Отсутствие лицензии.** Документ не является офертой, лицензией или разрешением на использование системы. Право использования системы возникает только на основании отдельного письменного договора с правообладателем.
- 6. Срок действия ограничений.** Ограничения действуют бессрочно. Они не прекращаются отказом Получателя от приобретения системы, истечением пилотного периода, прекращением переговоров или возвратом документа.
- 7. Возврат и уничтожение.** Если решение о приобретении не принято, а также по письменному требованию правообладателя, Получатель прекращает использование документа, удаляет его электронные копии и уничтожает бумажные экземпляры, подтверждая это письменно по запросу правообладателя.
- 8. Ответственность.** Нарушение исключительного права влечёт ответственность, установленную законодательством Российской Федерации, включая возмещение убытков либо выплату компенсации, и не лишает правообладателя права требовать пресечения действий, нарушающих право.
- 9. Принятие условий.** Получение и использование документа означает согласие с изложенными ограничениями. Получатель, не согласный с ними, обязан не использовать документ и уведомить правообладателя о его возврате или уничтожении.

© 2026 Мякотных Сергей Михайлович. Все права защищены.

СОДЕРЖАНИЕ

1. Общие сведения.....	7
1.1. Назначение документа.....	7
1.2. Оформление.....	7
2. Термины.....	7
3. Требования к оборудованию и программному обеспечению.....	8
3.1. Конфигурация сервера.....	8
3.2. Дисковое пространство.....	9
3.3. Программное обеспечение сервера.....	9
3.4. Требования к рабочим местам.....	10
3.5. Сетевые требования.....	10
4. Состав поставки.....	11
4.1. Что передаётся.....	11
4.2. Структура каталога системы.....	14
4.3. Принцип наложения файлов описания.....	15
4.4. Чего в поставке нет.....	15
5. Установка.....	16
5.1. Подготовка сервера.....	16
5.2. Установка Docker.....	20
5.3. Размещение поставки.....	21
5.4. Создание файла параметров.....	22
5.5. Выбор имени базы данных.....	27
5.6. Подготовка сертификата.....	27
5.7. Первый запуск.....	28
5.8. Создание учётной записи администратора.....	28
5.9. Проверка после установки.....	29
5.10. Ограничение доступа к серверу.....	29
6. Параметры конфигурации.....	35
6.1. Как задаются параметры.....	35
6.2. Обязательные параметры.....	37
6.3. Основные параметры.....	37

6.4. Параметры базы данных.....	38
6.5. Пересчёт параметров под другую конфигурацию.....	39
6.6. Почтовые уведомления.....	39
7. Защищённое соединение и сертификат.....	45
7.1. Зачем это нужно.....	45
7.2. Выбор способа получения сертификата.....	45
7.3. Выпуск сертификата.....	46
7.4. Установка корневого сертификата на рабочие места.....	47
7.5. Продление сертификата.....	48
8. Проверочный стенд.....	49
8.1. Назначение.....	49
8.2. Отличия от рабочего сервера.....	49
8.3. Развёртывание стенда.....	50
8.4. Наполнение стенда вымышленными данными.....	51
8.5. Ограничение доступа к стенду.....	53
9. Эксплуатация рабочего сервера.....	55
9.1. Основные команды.....	55
9.2. Повседневные операции.....	57
9.3. Управление учётными записями.....	58
9.4. Восстановление доступа супер-администратора.....	66
9.5. Режим технических работ.....	66
9.6. Файловый архив бланков.....	68
9.7. Доступ к архиву по сети.....	75
9.8. Переименование базы данных.....	76
9.9. Очистка накопленных данных.....	76
10. Порядок внесения изменений в систему.....	80
10.1. Общая схема.....	80
10.2. Получение исходного кода и внесение правки.....	80
10.3. Проверка изменения до выкладывания.....	81
10.4. Проверка на стенде.....	81
10.5. Выкладывание на рабочий сервер.....	82
10.6. Изменения схемы базы данных.....	83

10.7. Возврат к предыдущей версии.....	84
11. Резервное копирование и восстановление.....	84
11.1. Устройство.....	84
11.2. Что входит в копию.....	85
11.3. Сроки хранения.....	86
11.4. Настройка.....	86
11.5. Проверка и наблюдение.....	91
11.6. Хранение вне сервера.....	98
11.7. Восстановление.....	99
11.8. Перенос на другой сервер.....	105
12. Мониторинг и журналы.....	105
12.1. Проверка состояния.....	105
12.2. Журналы приложения.....	105
12.3. Журналы внутри системы.....	106
12.4. Что контролировать.....	107
13. Диагностика и типовые неисправности.....	108
13.1. Порядок диагностики.....	108
13.2. Система недоступна, страница не открывается.....	109
13.3. Обратный прокси не запускается.....	109
13.4. Предупреждение о недоверенном сертификате.....	109
13.5. Прикладной сервер не запускается.....	110
13.6. Изменение параметра не подействовало.....	110
13.7. Заканчивается место на диске.....	110
13.8. Система работает медленно.....	111
13.9. Работник не видит раздел или получает отказ.....	111
13.10. Не приходят обновления без перезагрузки страницы.....	112
13.11. Выгрузка из файлового архива не начинается или обрывается.....	112
13.12. Бланки не появляются в каталоге архива.....	113
13.13. Письма не приходят.....	114
13.14. Система не требует смены паролей по истечении срока.....	116
14. Перенос системы на другой сервер.....	117
14.1. Что переносится.....	118

14.2. Что меняется при переносе.....	118
14.3. Подготовка нового сервера.....	118
14.4. Выгрузка данных со старого сервера.....	119
14.5. Восстановление на новом сервере.....	120
14.6. Сертификат и запуск.....	122
14.7. Проверка после переноса.....	122
14.8. Переключение и вывод прежнего сервера из работы.....	123
Приложение А. Порты и сетевые доступы.....	123
Приложение Б. Перечень параметров конфигурации.....	124
Приложение В. Файлы, необходимые для запуска.....	132
Приложение Г. Проверочный лист ввода в эксплуатацию.....	133

1. Общие сведения

1.1. Назначение документа

Документ содержит порядок развёртывания системы электронной подачи заявок «Бюро пропусков», её настройки, ввода в эксплуатацию и последующего сопровождения.

Документ рассчитан на специалиста, не работавшего ранее с данной системой. Порядок действий описан от состояния «есть сервер с установленной операционной системой» до состояния «система принимает заявки». Команды приведены в виде, пригодном для непосредственного выполнения, с указанием ожидаемого результата каждого шага.

Назначение системы, устройство и состав возможностей описаны в отдельном документе, «Техническое описание системы».

1.2. Оформление

Команды, имена файлов и параметры набраны моноширинным шрифтом. Угловые скобки означают подстановку: <домен> заменяется фактическим значением без скобок.

Сведения, требующие повышенного внимания, выделяются:

ПРИМЕЧАНИЕ. Пояснение, полезное для понимания, но не влияющее на порядок действий.

ВАЖНО. Пропуск приведёт к неверной работе или к дополнительной работе по исправлению.

ОПАСНО. Последствия необратимы. Утрата данных или утрата доступа к ним.

2. Термины

Таблица 2.1 — Термины, применяемые в документе

Термин	Значение
Рабочий сервер	Сервер, на котором система работает для сотрудников предприятия. В обиходе «прод», «продакшн»
Проверочный стенд	Отдельный сервер с той же системой для проверки изменений до выкладывания на рабочий. В обиходе «стенд», «стейдж»

Термин	Значение
Контейнер	Изолированная среда, в которой запускается одна часть системы. Части не мешают друг другу и не требуют установки в операционную систему
Образ	Заготовка, из которой запускается контейнер. Собирается из исходного кода один раз, затем запускается сколько угодно раз
Том	Хранилище данных контейнера, живущее отдельно от него. Пересоздание контейнера данные не затрагивает
Обратный прокси	Часть системы, принимающая соединения снаружи и распределяющая их между остальными частями
Сертификат	Электронный документ, которым сервер подтверждает браузеру свою подлинность и обеспечивает защищённое соединение
Удостоверяющий центр	Сторона, подписывающая сертификаты. Браузер доверяет сертификату, если доверяет подписавшему его центру
Файл параметров	Файл .env в каталоге системы, содержащий пароли, ключи и настройки конкретной установки

3. Требования к оборудованию и программному обеспечению

3.1. Конфигурация сервера

Конфигурация рассчитана на устойчивую работу при 1000-1500 одновременно работающих пользователях. Параметры базы данных и прикладного сервера, поставляемые в комплекте, подобраны именно под неё. Значение получено расчётом; нагрузочные испытания на целевом оборудовании подтвердят или уточнят его.

Таблица 3.1 — Рекомендуемая конфигурация сервера

Параметр	Значение
Процессор	6 физических ядер с частотой от 3,4 ГГц, например Intel Xeon E-2236
Оперативная память	32 ГБ с коррекцией ошибок
Дисковая подсистема	Два твердотельных накопителя от 480 ГБ в зеркальном массиве
Сеть	Один адрес, пропускная способность от 100 Мбит/с

ВАЖНО. Зеркальный массив обязателен. В базе хранятся персональные данные, и при отказе одиночного накопителя восстановление возможно только из резервной копии, то есть с потерей всех изменений, сделанных после её создания.

Минимальная конфигурация для пробной эксплуатации и проверочного стенда: 4 ядра, 8 ГБ памяти, 100 ГБ дискового пространства.

При такой конфигурации параметры базы данных из комплекта поставки требуется уменьшить, иначе службе не хватит памяти. Порядок изменения описан в подразделе 6.5.

3.2. Дисковое пространство

Таблица 3.2 — Ориентировочное потребление дискового пространства

Потребитель	Оценка
Образы контейнеров и операционная система	15-20 ГБ
База данных без журналов	1-3 ГБ за год работы
Журнал запросов	Основной потребитель. При высокой активности подробные записи за 30 суток занимают десятки гигабайт
Загруженные файлы	Фотографии, шаблоны бланков, приложения к заявкам
Резервные копии	Не менее трёх объёмов базы данных

Журнал запросов растёт быстрее остального, поэтому глубина хранения подробных записей вынесена в параметр `REQUEST_LOG_DETAIL_DAYS`. Уменьшение до 7-14 суток кратно снижает занимаемый объём и на работу системы не влияет.

Служебные записи, обесценивающиеся сами, система удаляет ежесуточно без участия человека. Историю, слепки таблиц и суточные итоги журнала при нехватке места удаляют командой из подраздела 9.9 «Очистка накопленных данных».

3.3. Программное обеспечение сервера

Таблица 3.3 — Требования к программному обеспечению

Компонент	Требование
Операционная система	Любой дистрибутив Linux с поддержкой контейнеров: Ubuntu Server 22.04 и новее, Debian 12 и новее, RHEL-совместимые (Rocky, Alma), Astra Linux, РЕД ОС
Docker Engine	Версия 25 и новее
Docker Compose	Версия 2.24 и новее, вызывается как <code>docker compose</code>
openssl	Генерация секретов и сертификата
certbot	Только при выпуске сертификата через общедоступный удостоверяющий центр

Отдельно устанавливать Go, Node.js, PostgreSQL или nginx не требуется: всё необходимое собирается и работает внутри контейнеров.

3.4. Требования к рабочим местам

Браузер актуальной версии: Chrome, Yandex Browser, Firefox, Edge. Разрешение экрана от 1280 точек по ширине для рабочих мест бюро и постов. Интерфейс приспособлен и к мобильным устройствам.

Дополнительная установка чего-либо на рабочие места не требуется, за одним исключением: если сертификат сервера выпущен собственным удостоверяющим центром организации, потребуется однократно установить его корневой сертификат. Подробнее в подразделе 7.4.

3.5. Сетевые требования

Наружу открываются только два порта. Остальные порты частей системы существуют исключительно во внутренней сети контейнеров и не должны быть доступны с рабочих мест.

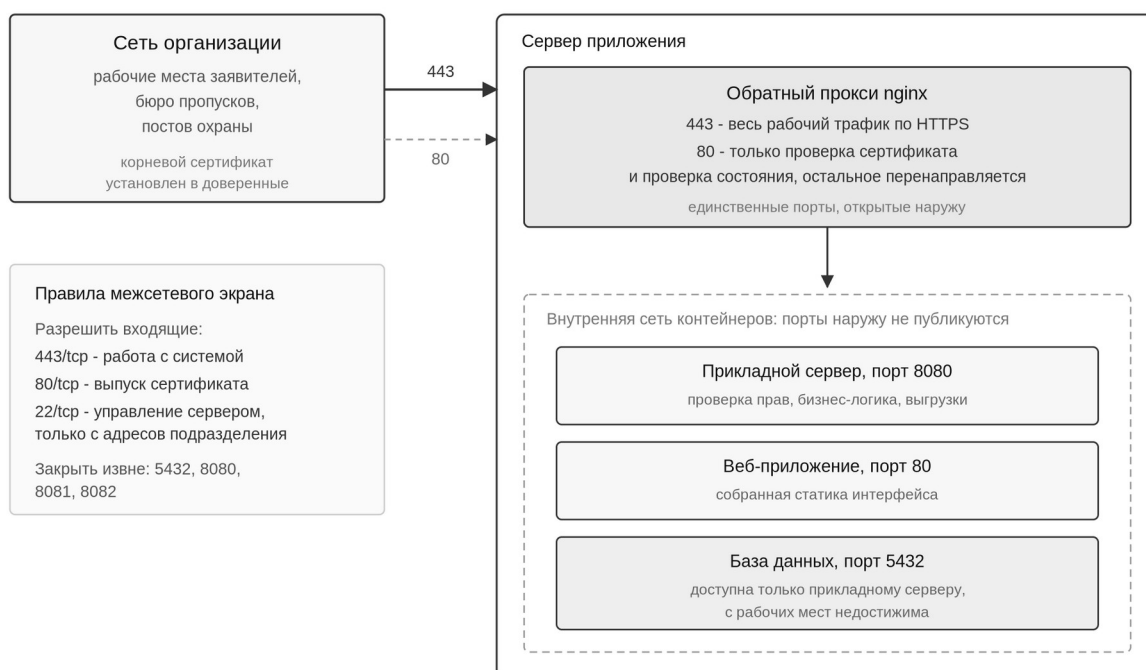


Рисунок 3.1 — Разграничение сетевых доступов

Исходящее соединение с сервера требуется, если настроена отправка писем: прикладной сервер подключается к почтовому серверу по адресу и порту из параметров SMTP_HOST и SMTP_PORT, обычно это порт 587 или 465. Соединение открывается в сторону почтового сервера, входящих

подключений оно не создаёт. Если правила межсетевого экрана его не пропускают, отправка заканчивается истечением срока ожидания, а письма остаются в очереди. Подробнее в подразделе 6.6.

Полный перечень портов с указанием области доступности приведён в приложении А.

4. Состав поставки

4.1. Что передаётся

Передаётся исходный код системы и все файлы, необходимые для её сборки и запуска. Готовые собранные образы не передаются: они собираются на сервере при установке, что исключает несовместимость с конкретной операционной системой.

Таблица 4.1 — Состав поставки

Элемент	Назначение
Исходный код серверной части и интерфейса	Из него на сервере собираются образы контейнеров
Файлы описания контейнеров	Определяют состав частей системы, их связи, ограничения ресурсов
Конфигурация обратного прокси	Правила распределения запросов, защищённое соединение, заголовки безопасности
Сборочный файл	Набор коротких команд управления вместо длинных команд Docker
Сценарий подготовки параметров	Создаёт файл параметров и генерирует пароли и ключи
Сценарий подготовки сертификата	Выпуск и продление сертификата, три способа на выбор
Сценарии резервного копирования и восстановления	Снятие копии, расписание, состояние, проверка восстановимости, восстановление
Эксплуатационная документация	Настоящий документ, техническое описание и руководства пользователей

Перечень конкретных файлов, без которых система не запустится, приведён в приложении В.

Как передаётся код. Исходный код хранится в системе контроля версий Git, в репозитории `git@github.com:buropropuskov/systemburo.git` на площадке GitHub.

Репозиторий закрытый: его содержимое видно только тем, кому выдан доступ.

И рабочий сервер, и проверочный стенд получают код прямо из репозитория. При установке каталог системы создаётся командой `git clone` (подраздел 5.3), при обновлении и при возврате к предыдущей версии тот же каталог переключается на нужную версию (подразделы 10.5 и 10.7). Обе операции требуют, чтобы каталог оставался рабочей копией репозитория, то есть содержал служебный подкаталог `.git`.

Как выдаётся доступ. Доступ выдаёт владелец репозитория со стороны разработчика по заявке ответственного за сервер. Способов два, и выбирают один.

Таблица 4.2 — Способы доступа к репозиторию

Способ	Что это	Когда применяется
Ключ развёртывания	Открытый ключ SSH, привязанный к одному репозиторию и по умолчанию действующий только на чтение	Доступ для сервера. Ничего, кроме этого репозитория, ключ не открывает
Машинная учётная запись	Отдельная учётная запись GitHub, включённая в организацию с правом чтения	Когда одному серверу нужны несколько репозиториев сразу

Для сервера предпочтителен ключ развёртывания. Он ограничен одним репозиторием и не связан с личной учётной записью сотрудника, поэтому увольнение никого из работников доступ сервера не рвёт, а сам ключ, попав в чужие руки, не даёт ничего сверх чтения этого репозитория.

Пара ключей создаётся на самом сервере, от того пользователя, под которым работает система. Наружу передаётся только открытая часть.

Листинг 4.1 — Создание ключа доступа к репозиторию

```
ssh-keygen -t ed25519 -C "systemburo-prod" -f ~/.ssh/id_ed25519 -N ""
cat ~/.ssh/id_ed25519.pub
```

Ожидаемый результат: выведена одна строка, начинающаяся с `ssh-ed25519`. Её передают владельцу репозитория, который добавляет её в настройки репозитория как ключ развёртывания. Закрытая часть остаётся на сервере и никуда не пересылается: она такой же секрет, как содержимое

файла параметров, и на неё распространяется правило хранения секретов из подраздела 5.4.

Листинг 4.2 — Проверка доступа

```
ssh -T git@github.com
```

Ожидаемый результат: приветствие с именем учётной записи или сообщение о том, что доступ к оболочке не предоставляется. Отказ по правам означает, что ключ ещё не добавлен либо добавлен не в тот репозиторий.

Как отзывается доступ. Ключ развёртывания отзывается удалением из настроек репозитория, машинная учётная запись - исключением из организации. Отзыв действует сразу: сервер перестаёт получать обновления, но уже полученный код и работающая система не затрагиваются. Доступ отзывают при выводе сервера из работы, при смене подрядчика и при любом подозрении, что закрытая часть ключа стала известна посторонним. После отзыва ключ на сервере удаляют, иначе команды раздела 10 будут завершаться отказом по правам без внятного объяснения.

Площадка без доступа в сеть общего пользования. Если сервер по требованиям безопасности не имеет выхода наружу, доступ к GitHub невозможен, и код передаётся архивом того же содержимого. Порядок установки от этого не меняется, кроме подраздела 5.3, где вместо получения из репозитория архив распаковывается в рабочий каталог. Следствие одно, но существенное: каталог перестаёт быть рабочей копией репозитория, поэтому команды обновления и возврата к предыдущей версии из подразделов 10.5 и 10.7 на нём не выполняются. Порядок обновления такой установки описан в подразделе 10.5 отдельно.

ВАЖНО. Смешивать способы нельзя. Если система развёрнута из архива, а затем в тот же каталог выполнить `git clone`, каталог окажется непустым и команда завершится ошибкой. Переход с архива на репозиторий выполняется как перенос на другой сервер, см. раздел 14.

4.2. Структура каталога системы

После получения исходного кода в рабочем каталоге образуется следующая структура. Знать её требуется для изменения настроек и для диагностики.

Листинг 4.3 — Структура каталога системы

/opt/systemburo/	
├─ docker-compose.base.yml	состав служб, общая часть
├─ docker-compose.prod.yml	наложение: рабочий сервер
├─ docker-compose.staging.yml	наложение: стенд
├─ docker-compose.yml	локальная разработка
├─ Dockerfile	образ прикладного сервера
├─ Makefile	команды управления
├─ .env	параметры и секреты
├─ .git/	рабочая копия репозитория
├─ cmd/ internal/ docs/	код серверной части
├─ frontend/	
│ └─ Dockerfile	образ веб-приложения
│ └─ nginx.conf	отдача статики в образе
│ └─ src/ package.json	код интерфейса
├─ nginx/	
│ └─ nginx.conf	прокси рабочего сервера
│ └─ staging.conf	прокси стенда
│ └─ Dockerfile.staging	образ прокси для стенда
│ └─ certs/	сертификат и ключ
│ └─ acme-webroot/	выпуск сертификата
├─ scripts/	
│ └─ init-env.sh	создание файла параметров
│ └─ init-tls.sh	выпуск и продление сертификата
│ └─ maintenance-off.sh	аварийное снятие режима технических работ
│ └─ backup.sh	снятие резервной копии
│ └─ backup-install.sh	постановка копирования на расписание
│ └─ backup-status.sh	состояние копий и итог последнего запуска
│ └─ backup-verify.sh	проверка восстановимости копии
│ └─ restore.sh	восстановление из копии

Пять сценариев копирования составляют один механизм, описанный в разделе 11: постановка на расписание берёт каталог копий из файла параметров, состояние читает то, что записал сценарий копирования, а восстановление работает с созданными им файлами. Убирать из каталога какой-либо из них по отдельности нельзя.

Каталог `.git` присутствует только при установке из репозитория. На площадке без доступа к нему, где код распакован из архива, каталога нет, и это меняет порядок обновления, см. подраздел 4.1.

4.3. Принцип наложения файлов описания

Ни рабочий сервер, ни стенд не имеют самостоятельного файла описания. Состав служб задан один раз в базовом файле, а различия среды добавляются наложением поверх него.

Листинг 4.4 — Порядок указания файлов описания

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
ps
```

Именно поэтому во всех командах настоящего документа указываются два файла подряд. Порядок существенен: базовый идёт первым, наложение вторым, значения из второго заменяют значения из первого.

ВАЖНО. Команда, в которой указан только файл наложения, работать не будет. Служба базы данных определена в базовом файле, и без него Docker сообщит, что такой службы не существует. Это частая причина ошибок при копировании команд из посторонних источников.

Сокращённые команды из сборочного файла (make deploy-up, make deploy-logs и прочие) подставляют оба файла самостоятельно, поэтому при их использовании об этом думать не требуется.

4.4. Чего в поставке нет

В поставку намеренно не входят пароли, ключи шифрования и сертификаты. Они создаются на сервере при установке и остаются только у организации, где развёрнута система. Это означает, что разработчик не имеет доступа к данным работающей системы.

Не входят и данные: справочники, учётные записи, заявки. Система разворачивается пустой, после чего заполняется силами бюро пропусков через интерфейс.

5. Установка

Раздел описывает установку с нуля на сервер с установленной операционной системой. Результат: работающая система, доступная по защищённому соединению, с заведённой учётной записью администратора.

Команды выполняются от имени отдельного пользователя, заведённого для работы с системой: обращения к контейнерам и цели сборочного файла он выполняет через `sudo` с вводом пароля. Порядок описан в подразделе 5.1. Настройка самого сервера - установка пакетов, межсетевой экран, служба удалённого доступа, расписание резервного копирования - требует полных прав суперпользователя и выполняется при вводе сервера в работу.

5.1. Подготовка сервера

Установите служебные утилиты.

Листинг 5.1 — Установка служебных пакетов

```
# Ubuntu, Debian, Astra Linux
sudo apt update && sudo apt install -y openssl curl ca-certificates

# RHEL-совместимые, РЕД ОС
sudo dnf install -y openssl curl ca-certificates
```

Задайте часовой пояс: от него зависят отметки времени в журналах.

Листинг 5.2 — Установка часового пояса

```
sudo timedatectl set-timezone Europe/Moscow
```

Учётная запись для работы с системой. Создайте отдельного пользователя. Под учётной записью суперпользователя систему не устанавливают и не сопровождают: ошибочная команда там ничем не ограничена, а в журнале сервера не остаётся имени того, кто её выполнил.

Листинг 5.3 — Создание пользователя

```
sudo useradd -m -s /bin/bash buro
sudo passwd buro
```

Ожидаемый результат: пользователь заведён, пароль запрошен дважды и принят. Пароль потребуется при каждом обращении к системе, поэтому он

должен быть известен тому, кто её сопровождает, и храниться по правилу из подраздела 5.4.

Почему не группа ``docker``. В эту группу пользователя не добавляют. Членство в ней равносильно правам суперпользователя: служба Docker работает от суперпользователя, а член группы обращается к ней напрямую, без пароля и без записи в журнале. Достаточно запустить контейнер, подключив к нему корневой каталог сервера, чтобы получить полный доступ к машине: к базе данных, к файлу параметров с ключом шифрования персональных данных и к резервным копиям.

Вместо членства в группе выдаётся разрешение выполнять две команды через `sudo`. Правила записываются отдельным файлом в каталоге `/etc/sudoers.d/`, а не правкой основного файла: отдельный файл переживает обновление системы, и ошибка в нём не ломает разбор правил целиком.

Листинг 5.4 — Создание файла правил

```
sudo visudo -f /etc/sudoers.d/systemburo
```

Листинг 5.5 — Содержимое файла `/etc/sudoers.d/systemburo`

```
buro ALL=(root) /usr/bin/docker, /usr/bin/make
```

Редактор `visudo` проверяет запись при сохранении и не даёт сохранить файл с ошибкой; он же выставляет права 440. Файл правил, доступный на запись кому-либо помимо суперпользователя, `sudo` не принимает и отказывается работать вовсе.

Листинг 5.6 — Проверка правил

```
sudo visudo -c
```

Ожидаемый результат: строка `/etc/sudoers: parsed OK` и такая же строка для `/etc/sudoers.d/systemburo`. Ошибка называется вместе с номером строки, в которой она найдена.

Правило сверяет полный путь исполняемого файла, поэтому пути в нём должны совпадать с фактическими. Проверить это можно после установки Docker, подраздел 5.2.

Листинг 5.7 — Проверка путей и действующих разрешений

```
command -v docker
command -v make
sudo -l -U buro
```

Ожидаемый результат: первые две команды выводят /usr/bin/docker и /usr/bin/make; если пути другие, подставьте фактические в файл правил. Третья печатает перечень разрешённого пользователю buro - те же две команды. Пустой перечень означает, что файл правил не подхвачен: проверьте его имя, точки в нём быть не должно, такие файлы sudo пропускает.

Каталог установки. Каталог системы принадлежит этому пользователю: под ним получают исходный код, обновляют его и правят файлы описания. На новой установке каталог создаётся сразу с нужным владельцем в подразделе 5.3, и передавать ничего не требуется.

Передача нужна, когда система уже работает, а модель доступа приводится к описанной здесь. Каталог файлового архива при этом не трогают: бланки в нём принадлежат служебному пользователю прикладного сервера с идентификатором 1001, и смена владельца остановит запись, см. подраздел 9.6.

Листинг 5.8 — Передача каталога установки, минуя каталог архива

```
sudo find /opt/systemburo -path /opt/systemburo/archive -prune \
-o -exec chown buro:buro {} +
ls -ld /opt/systemburo /opt/systemburo/archive
```

Ожидаемый результат: у каталога системы владелец buro, у каталога архива - 1001. В установке по умолчанию архив рабочего сервера лежит вне каталога системы, и тогда исключение ни на что не влияет.

Исключение для системы контроля версий. Git отказывается работать в каталоге, принадлежащем другому пользователю. После смены

владельца суперпользователь на первой же команде `git` получает отказ со словами `detected dubious ownership`, и обновление системы останавливается на этом месте. Исключение добавляется обоим учётным записям - и той, под которой ведут повседневную работу, и суперпользователю.

Листинг 5.9 — Исключение каталога установки

```
git config --global --add safe.directory /opt/systemburo
sudo git config --global --add safe.directory /opt/systemburo
```

Ожидаемый результат: обе команды завершаются молча, `git -C /opt/systemburo log -1` выводит последнее изменение и под тем, и под другим пользователем.

Как выглядит повседневная работа. На сервер заходят под `buro`. Команды к системе - запуск, остановка, журналы, резервные копии - выполняются с `sudo`: на первую за сеанс запрашивается пароль, следующие четверть часа он не спрашивается.

Листинг 5.10 — Обычное обращение к системе

```
sudo make deploy-logs
```

Ожидаемый результат: запрошен пароль пользователя `buro`, затем выведен журнал. Каждое такое обращение записывается: в Ubuntu, Debian и Astra Linux - в `/var/log/auth.log`, в RHEL-совместимых и в РЕД ОС - в `/var/log/secure`. В записи имя пользователя, время, рабочий каталог и полная команда.

Работы по самому серверу двумя разрешёнными командами не покрываются и выполняются с полными правами суперпользователя. Они разовые: установка пакетов, межсетевой экран, служба удалённого доступа, расписание резервного копирования, правка файлов описания служб.

Чего эта модель не даёт. Сказанное ниже важно понимать до того, как её примут за преграду для злоумышленника.

ВАЖНО. Разрешение выполнять docker через sudo в конечном счёте равнозначно правам суперпользователя. Контейнер запускает служба, работающая от суперпользователя, и запускающий вправе подключить внутри любой каталог сервера, включая корневой. Тот, кто вошёл под buro и знает его пароль, полный доступ к машине получит, и правила sudo его не остановят. Это свойство Docker, а не недоработка системы: любой доступ к его сокету равнозначен правам суперпользователя, и членство в группе docker отличается от описанной модели лишь тем, что не спрашивает пароль и не оставляет записи в журнале.

Ценность настройки в другом, и она невелика, но реальна. Повседневная работа не ведётся под суперпользователем, поэтому ошибочная команда - не в том каталоге, не с тем ключом - останавливается на запросе пароля, а не выполняется молча. Обращения к системе видны в журнале: известно, кто и когда их делал. Перечень из двух команд отделяет работу с системой от работы с сервером: переустановить пакеты или поправить настройки службы удалённого доступа под этой учётной записью не выйдет, для этого приходится осознанно брать полные права.

Защита от того, кто добрался до самой учётной записи buro, обеспечивается не здесь, а тем, что описано в подразделе 5.10: закрытыми портами, входом по ключу вместо пароля и блокировкой подбора.

5.2. Установка Docker

Версия из штатных репозиториев дистрибутива нередко устарела и может не поддерживать применяемый формат файлов описания. Устанавливайте из репозитория разработчика.

Листинг 5.11 — Установка Docker

```
# Ubuntu, Debian
curl -fsSL https://get.docker.com | sudo sh

# RHEL-совместимые
sudo dnf config-manager --add-repo \
  https://download.docker.com/linux/centos/docker-ce.repo
sudo dnf install -y docker-ce docker-ce-cli containerd.io \
  docker-compose-plugin
sudo systemctl enable --now docker
```

Для Astra Linux и РЕД ОС используйте пакеты из репозитория дистрибутива, если политика организации запрещает подключение внешних репозиториях.

Проверьте установку.

Листинг 5.12 — Проверка установки Docker

```
docker --version
docker compose version
```

Ожидаемый результат: обе команды выводят номер версии, у Docker Compose не ниже 2.24. Вторая обязана вызываться именно как `docker compose`, через пробел. Если она сообщает об ошибке, а работает `docker-compose` через дефис, установлена устаревшая версия, и файлы описания системы обработаны не будут.

ВАЖНО. Версия Docker Compose ниже 2.24 не понимает применяемый в описании рабочего сервера синтаксис снятия ограничений памяти и прервёт запуск сообщением о неверном формате файла. Версия из штатного репозитория дистрибутива нередко оказывается старше.

5.3. Размещение поставки

Код получают из репозитория. Доступ к нему должен быть выдан заранее, порядок - в подразделе 4.1.

Листинг 5.13 — Получение исходного кода

```
sudo mkdir -p /opt/systemburo
sudo chown buro:buro /opt/systemburo
git clone git@github.com:buropropuskov/systemburo.git /opt/systemburo
cd /opt/systemburo
```

Ожидаемый результат: каталог заполнен, команда `git log -1` выводит последнее изменение. Отказ по правам означает, что ключ доступа не выдан или выдан не для этого сервера, см. подраздел 4.1.

ПРИМЕЧАНИЕ. Команда `git clone` требует, чтобы каталог назначения был пустым. Каталог, созданный первыми двумя строками, пуст, поэтому порядок выполняется как есть.

На площадке без доступа в сеть общего пользования код передан архивом, и вместо получения из репозитория он распаковывается в тот же каталог.

Листинг 5.14 — Распаковка поставки на площадке без доступа к репозиторию

```
sudo mkdir -p /opt/systemburo
sudo chown buro:buro /opt/systemburo
tar -xzf systemburo-<версия>.tar.gz -C /opt/systemburo --strip-components=1
cd /opt/systemburo
```

Все дальнейшие команды выполняются из этого каталога.

ВАЖНО. Имя каталога определяет имена томов с данными. Если каталог впоследствии переименовать, Docker посчитает установку новой и создаст пустые тома, а система запустится с пустой базой. Данные при этом не теряются, а от самой ситуации избавляет параметр `COMPOSE_PROJECT_NAME`: сценарий подготовки параметров задаёт ему значение `systemburo`, и имена томов перестают зависеть от имени каталога. Если файл параметров заполнялся вручную, проверьте, что эта строка в нём есть, и добавьте её до первого запуска.

5.4. Создание файла параметров

Файл параметров создаётся сценарием, который сам генерирует стойкие случайные пароли и ключи. Задавать их вручную не следует.

Листинг 5.15 — Создание файла параметров

```
make init-production DOMAIN=<адрес системы>
```

Вместо `<адрес системы>` подставьте доменное имя, по которому система будет доступна, либо её сетевой адрес.

Ожидаемый результат: создан файл `.env`, на экран выведены путь к нему, фактические права доступа и перечень созданных секретов - по именам, без самих значений.

Права на файл и вывод сценария. Файл параметров создаётся с правами 600: читает его только владелец. Права выставляет сам сценарий, отдельной команды для этого не требуется. Выставляет он их до записи содержимого, поэтому файл не бывает общедоступным даже на те доли секунды, пока его заполняют.

Листинг 5.16 — Проверка прав на файл параметров

```
stat -c %a .env
```

Ожидаемый результат: 600. Другое значение означает, что файл создавался не сценарием или права меняли после него.

Кому принадлежит файл. Сценарий выполняется от имени пользователя, которому принадлежит каталог системы, и файл параметров остаётся в его собственности. Через `sudo` его запускают в одном случае: когда на сервере нет средства `age` и пару ключей шифрования файлового архива приходится создавать одноразовым контейнером, для чего нужен доступ к Docker. Тогда файл достаётся суперпользователю, и его возвращают владельцу каталога - иначе дальнейшие действия с файлом, запись ключа резервного копирования в подразделе 11.4 и проверка действующих значений в подразделе 13.6, потребуют прав, которых у оператора нет.

Листинг 5.17 — Возврат файла параметров владельцу каталога

```
sudo chown buro:buro /opt/systemburo/.env
```

Значения секретов на экран не выводятся намеренно. Сценарий запускается в том числе по сети из конвейера выпуска, и всё, что он печатает, оседает в журнале запуска конвейера и в истории терминала - там, где права на файл уже ничего не значат. Поэтому вывод называет только то, что создано: `DB_PASSWORD`, `JWT_SECRET`, `JWT_REFRESH_SECRET`, `DATA_ENCRYPTION_KEY`, а для рабочего сервера ещё и пару ключей файлового архива.

ВАЖНО. Перенесите секреты в хранилище секретов организации, взяв их из самого файла `.env`. Из этого следует обратное требование: файл `.env` содержит пароли и ключи открытым текстом, его нельзя копировать в общедоступные каталоги, прикладывать к обращениям и включать в резервные копии общего доступа.

Чем отличается набор параметров рабочего сервера. Одна и та же команда для рабочего сервера и для стенда заполняет файл по-разному.

Различия не косметические: часть из них меняет поведение системы при запуске.

Таблица 5.1 — Отличия набора параметров рабочего сервера от стенда

Параметр	Рабочий сервер	Стенд
REQUIRE_ENCRYPTION	true: без ключей шифрования система не запускается	false
LOG_LEVEL	info	debug
ARCHIVE_HOST_PATH	/srv/systemburo/archive, отдельный каталог вне установки	./archive в каталоге установки
ARCHIVE_AGE_RECIPIENT, ARCHIVE_AGE_IDENTITY	Пара ключей создаётся сценарием	Создаётся, если получится; иначе бланки пишутся открытыми
PGADMIN_EMAIL, PGADMIN_PASSWORD	Не записываются	Записываются
BASIC_AUTH_USER, BASIC_AUTH_PASS	Не записываются	Записываются

Панель управления базой данных и запрос имени и пароля на входе описаны только в наложении стенда, поэтому на рабочем сервере соответствующие строки были бы лишними паролями в файле: заданные, но ничего не открывающие. Их там и нет.

Ключи шифрования файлового архива. Для рабочего сервера сценарий создаёт пару ключей средством age - тем же, которым шифруются резервные копии. Устанавливать его в систему не требуется: если средства нет, пара создаётся одноразовым контейнером. Открытая часть записывается в ARCHIVE_AGE_RECIPIENT, закрытая в ARCHIVE_AGE_IDENTITY.

Пока ключ принимающей стороны не известен, в ARCHIVE_AGE_RECIPIENT стоит открытая часть ключа самой системы: бланки лежат зашифрованными, и система их читает. Когда ключ принимающей стороны появится, строку заменяют, а записанные ранее файлы остаются читаемыми. Подробности - в подразделе 9.6.

Если ключ принимающей стороны известен заранее, его подставляют при запуске сценария.

Листинг 5.18 — Создание файла параметров с готовым ключом принимающей стороны

```
ARCHIVE_AGE_RECIPIENT=age1... ./scripts/init-env.sh production <адрес системы>
```

Свою пару сценарий в этом случае всё равно создаёт: закрытая часть нужна системе, чтобы читать собственный архив, - но открытая берётся из переданного значения, а не из созданной пары. Если переданы обе части, сценарий не создаёт ничего и записывает их как есть.

ВАЖНО. Если создать пару ключей не удалось - в системе нет age и недоступен реестр образов, - для рабочего сервера сценарий останавливается и файла параметров не создаёт вовсе. Это не сбой сценария: прод-профиль включает REQUIRE_ENCRYPTION=true, и с ним система всё равно не запустится, пока ключи не заданы, а в бланках заявок фамилии, сведения документов и номера патентов. Сценарий печатает три способа исправить: установить age, открыть доступ к реестру образов либо подставить готовые ключи, как в листинге выше. Для стенда та же неудача останавливающей не является - сценарий предупреждает, что бланки будут записываться открытым текстом, и продолжает.

Каталог файлового архива. По окончании работы сценарий печатает команды, которыми создаётся каталог архива. Выполнить их нужно до первого запуска: прикладной сервер работает под непривилегированным пользователем и чужой каталог себе не присвоит. Порядок и последствия описаны в подразделе 9.6.

Особое внимание к параметру DATA_ENCRYPTION_KEY. Им зашифрованы сведения документов, удостоверяющих личность.

ОПАСНО. При утрате ключа шифрования расшифровать персональные данные невозможно. Резервная копия базы не поможет: она содержит те же зашифрованные значения. Ключ должен храниться отдельно от сервера и отдельно от резервных копий.

Сценарий намеренно отказывается перезаписывать существующий файл параметров.

ОПАСНО. Не запускайте создание параметров повторно на работающей системе. Будет сгенерирован новый ключ шифрования, и ранее зашифрованные персональные данные перестанут читаться.

Правило хранения секретов. Оно одинаково для всех тайных значений системы: ключа шифрования персональных данных, паролей базы, ключей подписи маркеров доступа и закрытого ключа резервных копий.

Таблица 5.2 — Как хранить секреты системы

Требование	Причина
Не менее двух копий в разных местах	Единственная копия - такая же точка отказа, как единственный сервер: отказ носителя или потеря доступа к хранилищу означают безвозвратную утрату
Хранить отдельно от того, что они защищают	Ключ рядом с резервной копией или с базой обесценивает шифрование: получивший доступ получает и данные, и ключ
Обновлять копию при каждом изменении	Копия устаревшего файла параметров не откроет данные, зашифрованные новым ключом
Передавать защищённым каналом	Пересылка секрета обычной почтой или в переписке равносильна его публикации
Ограничить круг лиц	Секрет знают те, кому он нужен для работы, и этот список пересматривается при смене сотрудников

ОПАСНО. Утрата ключа шифрования персональных данных необратима. База восстановится, но сведения документов, удостоверяющих личность, останутся нечитаемыми. Восстановить их невозможно ни средствами системы, ни силами разработчика.

Что делать, если секрет утрачен. Восстановить его нельзя, но систему в большинстве случаев можно вернуть в рабочее состояние. Порядок зависит от того, что именно потеряно.

Таблица 5.3 — Действия при утрате секрета

Что утрачено	Что потеряно безвозвратно	Порядок действий
Закрытый ключ резервных копий, система работает	Все ранее снятые зашифрованные копии	Создать новую пару ключей по подразделу 11.4, заменить BACKUP_AGE_RECIPIENT, немедленно снять свежую копию и проверить её восстановимость, старые копии удалить: они больше не расшифровываются
Закрытый ключ копий и сама система одновременно	Данные и копии	Разворачивать систему заново по разделу 5 и вводить данные повторно
Файл параметров на сервере, копия в хранилище есть	Ничего	Вернуть файл из хранилища в каталог системы и перезапустить: <code>sudo make deploy-up</code>

Что утрачено	Что потеряно безвозвратно	Порядок действий
Файл параметров и его копия, база цела	Сведения документов, удостоверяющих личность	Система продолжит работать; зашифрованные поля не читаются и вводятся заново. Заявки, реестры, учётные записи не пострадают
Пароль базы данных	Ничего	Задать новый в файле параметров и в самой базе, перезапустить систему

ВАЖНО. Обнаружив утрату, сначала снимите свежую копию и убедитесь, что она разворачивается. Работа с системой без проверенной копии - это работа без страховки, и любая следующая ошибка станет необратимой.

5.5. Выбор имени базы данных

Имя базы задаётся параметром `DB_NAME` в файле параметров. Если требуется имя, отличное от заданного по умолчанию, измените его **до первого запуска**: тогда база сразу создастся с нужным именем.

Листинг 5.19 — Пример изменения имени базы до первого запуска

```
DB_NAME=buropropuskov
DATABASE_URL=postgres://postgres:<пароль>@db/buropropuskov
```

Переименование уже работающей базы описано в подразделе 9.8.

5.6. Подготовка сертификата

Сертификат готовится до первого запуска: обратный прокси не стартует, если файла сертификата нет. Способы выпуска и выбор между ними описаны в разделе 7. Для установки внутри сети организации достаточно выполнить:

Листинг 5.20 — Выпуск сертификата для внутренней сети

```
./scripts/init-tls.sh self <адрес системы> <IP-адрес сервера>
```

Ожидаемый результат: на экран выведены сведения о выпущенном сертификате, включая срок действия, и указан путь к корневому сертификату для установки на рабочие места.

5.7. Первый запуск

Сборка образов выполняется на сервере и занимает от нескольких минут до получаса в зависимости от производительности.

Листинг 5.21 — Сборка и запуск

```
sudo make deploy-build
sudo make deploy-up
```

Первый запуск дольше последующих: создаётся схема базы данных, устанавливаются расширения, строятся индексы.

Листинг 5.22 — Наблюдение за запуском

```
sudo make deploy-logs
```

Ожидаемый результат: в журнале нет сообщений уровня error, последние строки сообщают о запуске сервера.

5.8. Создание учётной записи администратора

Листинг 5.23 — Создание администратора

```
sudo make deploy-seed PASS=<пароль администратора>
```

Команда создаёт учётную запись `buropropuskov` с правами супер-администратора и заводит для неё организацию и компанию «Бюро пропусков».

Обязательные справочники - типы работников и разделы встроенного руководства - заполняются раньше, при первом запуске прикладного сервера. Поэтому команда выполняется только после успешного запуска: без справочника типов она завершится ошибкой.

ВАЖНО. Аргумент `PASS` обязателен. Без него будет установлен пароль по умолчанию, известный из состава поставки.

Пароль хранится в виде необратимой свёртки и в открытом виде нигде не сохраняется.

Команда спрашивает подтверждение и ждёт слова `ПЕРЕЗАПИСАТЬ`: при первой установке вопрос лишний, зато он останавливает случайный

повторный запуск на работающей системе, где пароль администратора давно сменили. Порядок подтверждения описан в подразделе 9.1.

Демонстрационное наполнение (`make deploy-seed-demo`) на рабочем сервере запускать не следует: оно создаёт вымышленные заявки, организации и транспорт, которые придётся удалять вручную. Оно тоже спрашивает подтверждение, словом НАЛИТЬ.

5.9. Проверка после установки

Выполните проверки последовательно. Каждая проверяет свой уровень, и успех предыдущей не гарантирует успех следующей.

Таблица 5.4 — Проверки после установки

Проверка	Команда или действие	Ожидаемый результат
Части системы запущены	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml ps</code>	Четыре службы в состоянии Up, база в состоянии healthy
Сервер отвечает	<code>curl -s http://localhost/health</code>	<code>{"status":"ok"}</code>
Защищённое соединение работает	<code>curl -sI https://<адрес>/</code>	Код 200, присутствует заголовок Strict-Transport-Security
Незащищённое перенаправляется	<code>curl -sI http://<адрес>/</code>	Код 301, заголовок Location начинается с https://
Вход выполняется	Открыть систему в браузере, войти под администратором	Открывается главный экран
Права применяются	Открыть раздел администрирования	Разделы управления доступны

ПРИМЕЧАНИЕ. Проверка `/health` подтверждает только то, что процесс жив. К базе данных она не обращается, поэтому успешный ответ при недоступной базе возможен. Полноценной проверкой является вход в систему.

5.10. Ограничение доступа к серверу

Предыдущие подразделы описывали установку самой системы. Последний шаг относится к серверу, на котором она работает, и выполняется до того, как в системе появятся настоящие данные.

Зачем это нужно. Сервер с внешним адресом перебирают постоянно: программы обходят адреса подряд и пробуют пары имени и пароля из готовых списков. Это фоновый шум, а не целевая атака, и сам по себе он

безобиден. Опасен он в сочетании с разрешённым входом по паролю: одной угаданной пары достаточно, чтобы получить полный доступ к машине, а вместе с ним прямой доступ к базе со всеми персональными данными и к файлу параметров, где лежит ключ их шифрования. Никакая защита внутри системы в этом случае уже не работает. На проверочном стенде системы журнал за четыре месяца насчитал около 22 тысяч неудачных попыток входа - обычная величина для сервера, доступного из сети общего пользования.

Настройка делается в три приёма: закрыть лишние порты, замедлить перебор и убрать сам его предмет, отключив вход по паролю. Запрос имени и пароля на входе в проверочный стенд, описанный в подразделе 8.5, к этому отношения не имеет: он закрывает веб-интерфейс стенда, а здесь речь о доступе к самой машине.

ПРИМЕЧАНИЕ. Команды приведены для Ubuntu и Debian. В RHEL-совместимых и в РЕД ОС межсетевым экраном управляет `firewalld`, а служба удалённого доступа называется `sshd`. Смысл настройки тот же, точная форма команд берётся из документации дистрибутива.

Межсетевой экран. Снаружи оставляют три порта: порт SSH для управления сервером, 80 и 443 для работы с системой. Всё остальное закрывается политикой по умолчанию. Область доступности каждого порта приведена в приложении А.

ВАЖНО. Правило для порта SSH добавляется **до** включения экрана. Экран, включённый первым, обрывает текущее подключение и закрывает вход: вернуть доступ получится только через консоль управления у поставщика услуг или физически у машины.

Листинг 5.24 — Настройка межсетевого экрана

```
sudo ufw allow 22/tcp
sudo ufw allow 80/tcp
sudo ufw allow 443/tcp
sudo ufw --force enable
```

Ключ `--force` снимает вопрос о подтверждении: без него команда спрашивает согласия и предупреждает, что включение может разорвать соединение.

Листинг 5.25 — Проверка правил экрана

```
sudo ufw status verbose
```

Ожидаемый результат: первая строка `Status: active`, строка политик по умолчанию содержит `deny (incoming)` и `allow (outgoing)`, а в перечне ровно три разрешённых порта: 22, 80 и 443. Каждый из них показан двумя строками, отдельно для IPv4 и IPv6: это одно правило, а не дубль.

Если сервером управляют с известных адресов, правило для SSH сужают до них, и перебор перестаёт доходить до службы вовсе.

Листинг 5.26 — Разрешение SSH только из заданной сети

```
sudo ufw allow from <сеть подразделения ИТ> to any port 22 proto tcp  
sudo ufw delete allow 22/tcp
```

Ожидаемый результат: в выводе `ufw status verbose` строка для порта 22 указывает источник вместо `Anywhere`. Вторая команда удаляет прежнее общее разрешение и выполняется только после того, как проверено подключение из разрешённой сети.

Сужение применимо там, где у обслуживающего персонала постоянные адреса. Если администраторы подключаются с меняющихся адресов, порт управления остаётся открытым отовсюду, и защита держится на двух следующих частях настройки - входе по ключу и средстве блокировки подбора. На проверочном стенде системы сделано именно так, поэтому строка для порта 22 в его правилах указывает `Anywhere`.

Особенность: порты, опубликованные Docker. Правила `ufw` не закрывают порты, которые публикуют контейнеры. Docker правит правила фильтрации напрямую, и его цепочки просматриваются раньше правил экрана, поэтому порт, указанный в разделе `ports` описания контейнера, остаётся доступен снаружи, даже если экран его запрещает. Рабочему серверу это не мешает: наружу публикует порты только обратный прокси, 80 и 443, а база данных, прикладной сервер и веб-приложение не публикуют ничего и живут во внутренней сети контейнеров.

ВАЖНО. Из этой особенности следует, что закрыть порт базы данных правилом `ufw deny` невозможно. Если публикация порта появится - на сервере запустят описание для разработки, где порт 5432 публикуется намеренно, либо публикацию добавят вручную для разбора неисправности, - база окажется доступна из сети, а `ufw status` будет по-прежнему показывать порт запрещённым. Закрывается он только удалением публикации из описания контейнера.

Защита от подбора пароля. Средство `fail2ban` читает журнал входов и временно закрывает доступ адресам, с которых идут неудачные попытки.

Листинг 5.27 — Установка защиты от подбора

```
sudo apt install -y fail2ban
```

Настройки записываются в отдельный файл `/etc/fail2ban/jail.local`. Штатный файл настроек пакета при обновлении перезаписывается, а этот остаётся нетронутым.

Листинг 5.28 — Файл `/etc/fail2ban/jail.local`

```
[sshd]
enabled = true
maxretry = 5
findtime = 10m
bantime = 1h
```

Значения читаются так: пять неудачных попыток с одного адреса за десять минут закрывают этому адресу доступ к серверу на час. Администратору, ошибшемуся паролем, такого запаса хватает, а перебору по списку нет: вместо тысяч паролей в час он успевает попробовать пять. Блокировку входа в саму систему, описанную в техническом описании, эта настройка не заменяет и не отменяет: та закрывает учётную запись работника, эта - доступ к машине с конкретного адреса.

Листинг 5.29 — Применение настроек

```
sudo systemctl enable fail2ban
sudo systemctl restart fail2ban
```

Листинг 5.30 — Проверка состояния защиты

```
systemctl is-active fail2ban
sudo fail2ban-client status sshd
```


Ожидаемый результат: первая команда отвечает одним словом `active`. Вторая выводит состояние правила `sshd` двумя частями: в разделе `Filter` - сколько неудачных попыток замечено (`Currently failed`, `Total failed`), в разделе `Actions` - сколько адресов закрыто (`Currently banned`, `Total banned`) и перечень этих адресов строкой `Banned IP list`. Ненулевые значения означают, что средство работает и уже отсекает перебор.

Ответ `inactive` у первой команды либо сообщение о неизвестном правиле у второй означают, что служба не запущена или файл настроек содержит ошибку. Причина видна в `journalctl -u fail2ban`.

Вход по ключу вместо пароля. Пока вход по паролю разрешён, перебор имеет смысл, и средство защиты лишь замедляет его. Ключ убирает саму возможность: подобрать его нельзя. Порядок из четырёх шагов, и он выполняется именно в этой последовательности.

ОПАСНО. Отключение парольного входа до того, как проверен вход по ключу, оставит сервер недоступным. Восстановить доступ можно будет только через консоль управления у поставщика услуг или физически у машины.

Шаг 1. На рабочем месте администратора создаётся пара ключей, если её ещё нет.

Листинг 5.31 — Создание ключа для входа на сервер

```
ssh-keygen -t ed25519 -C "admin@buro"
```

Закрытая часть остаётся на рабочем месте и никуда не пересылается: на неё распространяется правило хранения секретов из подраздела 5.4. Наружу передаётся только открытая часть.

Шаг 2. Открытая часть кладётся на сервер.

Листинг 5.32 — Перенос открытой части ключа на сервер

```
ssh-copy-id buro@<адрес сервера>
```

Команда запрашивает пароль - в последний раз - и дописывает ключ в файл `~/.ssh/authorized_keys` на сервере.

Шаг 3. Вход по ключу проверяется **отдельным** подключением, не закрывая текущее. Для этого открывается второе окно терминала.

Листинг 5.33 — Проверка входа по ключу

```
ssh buro@<адрес сервера>
```

Ожидаемый результат: подключение открывается без запроса пароля. Если пароль всё же запрашивается, ключ не принят, и дальше идти нельзя: сначала проверяются права на сервере - каталог `~/.ssh` должен быть с правами 700, файл `authorized_keys` с правами 600.

Шаг 4. Только после успешной проверки отключается вход по паролю. В файле `/etc/ssh/sshd_config` строка `PasswordAuthentication` приводится к виду:

Листинг 5.34 — Строка файла `/etc/ssh/sshd_config`

```
PasswordAuthentication no
```

Листинг 5.35 — Проверка настроек и перезапуск службы

```
sudo sshd -t
sudo systemctl restart ssh
```

Ожидаемый результат: первая команда не печатает ничего, это значит, что файл настроек читается без ошибок; вторая завершается молча. Уже открытые подключения перезапуск не разрывает, поэтому текущее окно терминала остаётся рабочим.

Листинг 5.36 — Проверка действующего значения

```
sudo sshd -T | grep passwordauthentication
```

Ожидаемый результат: `passwordauthentication no`. Команда показывает значение, с которым служба работает на самом деле, а не то, что записано в основном файле.

ПРИМЕЧАНИЕ. Если проверка показывает `yes`, значение переопределено файлом из каталога `/etc/ssh/sshd_config.d/`. В образах, подготовленных поставщиками услуг, там нередко лежит файл, разрешающий вход по паролю. Действует первое встреченное значение, а этот каталог подключается в начале основного файла, поэтому правку вносят именно туда.

Как убедиться, что подбор идёт. Число неудачных попыток входа считается по журналу.

Листинг 5.37 — Подсчёт неудачных попыток входа

```
sudo journalctl -u ssh --since "30 days ago" | grep -c "Failed password"
```

Ожидаемый результат: одно число. Ненулевое, вплоть до нескольких тысяч, - это норма для сервера, доступного из сети общего пользования, а не признак того, что сервер взломан. Оно показывает ровно то, ради чего выполнялась настройка: попытки идут постоянно, и защита от подбора вместе с отключённым паролем входом оставляет их безрезультатными.

ПРИМЕЧАНИЕ. Глубина журнала ограничена его настройками хранения, поэтому за более давний срок число окажется меньше фактического. Средство защиты от подбора считает свои попытки с момента последнего запуска службы, и его счётчик с этим числом не совпадает.

Соответствующие пункты вынесены в проверочный лист ввода в эксплуатацию, приложение Г.

6. Параметры конфигурации

6.1. Как задаются параметры

Параметры передаются прикладному серверу переменными окружения. Файл `.env` в каталоге системы подставляет значения в описание контейнеров.

ВАЖНО. Описание рабочего сервера передаёт в контейнер не весь файл параметров, а только явно перечисленный набор. Параметры вне этого набора в контейнер не попадают и работают на встроенных значениях, даже если прописаны в `.env`.

Таблица 6.1 — Параметры, действующие через файл параметров

Назначение	Параметры
Подключение к базе	DB_USER, DB_PASSWORD, DB_NAME
Маркеры доступа	JWT_SECRET, JWT_REFRESH_SECRET, JWT_ACCESS_TTL, JWT_REFRESH_TTL

Назначение	Параметры
Журнал и программный интерфейс	LOG_LEVEL, SWAGGER_ENABLED, CORS_ALLOWED_ORIGINS
Шифрование	DATA_ENCRYPTION_KEY, REQUIRE_ENCRYPTION, ARCHIVE_AGE_RECIPIENT, ARCHIVE_AGE_IDENTITY
Загрузка файлов	UPLOAD_MAX_FILE_SIZE, UPLOAD_ALLOWED_IMAGE_TYPES, UPLOAD_ALLOWED_DOC_TYPES
Ограничения обращений	RATE_LIMIT_PER_MINUTE, RATE_LIMIT_WINDOW_SEC, PAGINATION_MAX_LIMIT
Уведомления в браузер	VAPID_PUBLIC_KEY, VAPID_PRIVATE_KEY, VAPID_SUBJECT, PUSH_SUBSCRIPTION_RETENTION_DAYS
Каталог файлового архива	ARCHIVE_HOST_PATH

Два параметра из этой таблицы ведут себя не так, как остальные, и это важно при правке файла руками.

Строка подключения DATABASE_URL в файле параметров есть, но в контейнер попадает не она: описание собирает строку заново из DB_USER, DB_PASSWORD и DB_NAME. Правка одной только DATABASE_URL ни на что не влияет, менять нужно эти три значения. Каталог ARCHIVE_HOST_PATH тоже не переменная окружения прикладного сервера: он задаёт, какой каталог хоста подключается к контейнеру, а внутри контейнера архив всегда виден по пути /app/archive (ARCHIVE_PATH).

Остальные параметры сценарий записывает в файл отдельным блоком под заголовком о том, что до контейнера они пока не доходят. Значения в этом блоке совпадают со встроенными, то есть система работает ровно так, как там написано, но правка строки ничего не изменит, пока параметр не добавлен в описание.

Чтобы изменить такой параметр, добавьте его в раздел environment службы backend файла docker-compose.prod.yml и перезапустите систему.

Листинг 6.1 — Изменение параметра, не передаваемого через файл параметров

```
backend:
  environment:
    RESET_TIMEZONE: "Asia/Yekaterinburg"
    REQUEST_LOG_DETAIL_DAYS: "14"
```

Листинг 6.2 — Применение изменений

```
sudo make deploy-up
```

Ожидаемый результат: контейнер прикладного сервера пересоздан, новые значения действуют. Проверить можно командой из подраздела 13.6.

6.2. Обязательные параметры

Три параметра обязательны. При их отсутствии или недопустимом значении прикладной сервер завершает работу с ошибкой, а не запускается в ослабленном режиме.

Таблица 6.2 — Обязательные параметры

Параметр	Проверка при запуске
DATABASE_URL	Должен начинаться с postgres:// или postgresql://
JWT_SECRET	Не короче 32 символов
JWT_REFRESH_SECRET	Не короче 32 символов

Раздельные ключи для маркера доступа и маркера продления принципиальны: при совпадении маркер продления можно было бы предъявить вместо маркера доступа и продлить сеанс бесконечно. Сценарий подготовки параметров генерирует их независимо, поэтому при штатной установке они заведомо различны.

ВАЖНО. Совпадение этих двух ключей система при запуске не проверяет. Задавая их вручную, убедитесь, что они разные.

6.3. Основные параметры

Полный перечень приведён в приложении Б. Здесь перечислены параметры, которые чаще всего требуется изменять.

Таблица 6.3 — Часто изменяемые параметры

Параметр	По умолчанию	Назначение
LOG_LEVEL	info	Подробность журнала: debug, info, warn, error
RESET_TIMEZONE	Europe/Moscow	Часовой пояс суточного сброса территориальных статусов
REQUEST_LOG_DETAIL_DAYS	30	Глубина хранения подробных записей журнала запросов
RATE_LIMIT_PER_MINUTE	200	Допустимое число запросов в минуту от одного работника

Параметр	По умолчанию	Назначение
UPLOAD_MAX_FILE_SIZE	10485760	Наибольший размер загружаемого файла, 10 МБ
SWAGGER_ENABLED	false	Публикация описания программного интерфейса
REQUIRE_ENCRYPTION	false	Запрет запуска без ключей шифрования: персональных данных и файлового архива

Значение false в столбце умолчаний - встроенное значение прикладного сервера. В файле параметров рабочего сервера сценарий задаёт REQUIRE_ENCRYPTION=true, поэтому выставлять его руками при обычной установке не требуется.

ВАЖНО. На рабочем сервере REQUIRE_ENCRYPTION должен оставаться в значении true. Это исключает ситуацию, когда система запустилась без ключа шифрования и записала персональные данные в открытом виде. Проверка охватывает и ключи файлового архива: незаполненные ARCHIVE_AGE_RECIPIENT и ARCHIVE_AGE_IDENTITY означают, что бланки и приложения к заявкам файлы лягут на диск открытыми, а заметить это можно только по именам файлов в каталоге. Снятие требования, чтобы «система хотя бы запустилась», лечит симптом и оставляет данные незащищёнными: разбираться нужно с ключами.

6.4. Параметры базы данных

Заданы в файле описания рабочего сервера и подобраны под конфигурацию из подраздела 3.1.

Таблица 6.4 — Параметры базы данных и среды выполнения

Параметр	Значение	Смысл
shared_buffers	8GB	Память под собственный кэш страниц базы
effective_cache_size	20GB	Оценка доступной памяти под кэш, влияет на выбор плана запроса
work_mem	32MB	Память на одну операцию сортировки или соединения
maintenance_work_mem	1GB	Память под построение индексов и обслуживание
max_connections	150	Наибольшее число одновременных подключений
max_wal_size	4GB	Объём журнала предзаписи между контрольными точками

Параметр	Значение	Смысл
random_page_cost	1.1	Стоимость произвольного чтения, значение для твердотельных накопителей
effective_io_concurrency	200	Число параллельных операций ввода-вывода
GOMAXPROCS	6	Число ядер, используемых прикладным сервером
GOMEMLIMIT	6GiB	Порог, при котором усиливается освобождение памяти

6.5. Пересчёт параметров под другую конфигурацию

При установке на сервер с иными характеристиками параметры базы данных требуется пересчитать, иначе службе не хватит памяти либо она не использует доступную.

Таблица 6.5 — Правила пересчёта

Параметр	Правило
shared_buffers	Около четверти оперативной памяти
effective_cache_size	Около двух третей оперативной памяти
maintenance_work_mem	Около 1/32 оперативной памяти
GOMAXPROCS	Равно числу ядер процессора
GOMEMLIMIT	Около одной пятой оперативной памяти

Пример для сервера с 8 ГБ памяти и 4 ядрами: shared_buffers=2GB, effective_cache_size=5GB, maintenance_work_mem=256MB, GOMAXPROCS=4, GOMEMLIMIT=1600MiB.

6.6. Почтовые уведомления

Как устроена отправка

Собственный почтовый сервер система не поднимает. Она подключается к чужому почтовому серверу как обычный почтовый клиент: под учётной записью ящика, по защищённому соединению, теми же параметрами, которые задают в любой почтовой программе. Подойдёт ящик у поставщика услуг связи, ящик в корпоративном сервисе или почтовый сервер самой организации.

Письмо отправляется не сразу в момент события. Оно записывается в очередь в базе данных, а фоновая задача раз в 15 секунд забирает накопившееся и передаёт почтовому серверу. Промежуточная очередь нужна, чтобы письмо не пропало: событие и задание на письмо сохраняются вместе, и сбой сети или недоступность почтового сервера откладывают отправку, а не отменяют её. Непринятое сервером письмо повторяется с нарастающей паузой: через минуту, пять минут, пятнадцать минут, дальше раз в час. Исчерпав установленное число попыток (`MAIL_RETRY_ATTEMPTS`, по умолчанию пять), система перестаёт пытаться, помечает письмо недоставленным и записывает причину отказа в журнал прикладного сервера.

Что будет, если не настраивать

Отправку включает единственный параметр: непустой `SMTP_HOST`. Пока он пуст, почта выключена целиком, и это допустимое состояние системы, а не ошибка. Фоновая задача разбора очереди при запуске не стартует и сообщает об этом в журнал, очередь не наполняется, а возможности, которым требуется письмо, отказываются выполняться с явным сообщением о ненастроенной почте. Видимости отправленных писем система при этом не создаёт.

ВАЖНО. Почта выключается пустым адресом сервера, а не отдельным выключателем. Если в файле параметров `SMTP_HOST` заполнен, а остальные значения оставлены пустыми, прикладной сервер откажется запускаться: полуготовая настройка обнаружилась бы только на первом письме. Проверяются режим защиты соединения, номер порта, наличие и правильность адреса отправителя, парность логина и пароля и положительность числовых параметров.

Куда записываются параметры

Параметры почты записываются в файл параметров `.env` рядом с остальными, см. подраздел 5.4, и попадают в прикладной сервер обычным порядком. После правки файла систему перезапускают.

Листинг 6.3 — Применение изменений

```
make deploy-up
```

Ожидаемый результат: контейнер прикладного сервера пересоздан. Проверить, что значения дошли, можно командой из подраздела 13.6, подставив в неё SMTP_HOST.

Настройка для трёх типовых случаев

Набор параметров один и тот же во всех случаях, различаются только значения. Полный перечень с умолчаниями приведён в приложении Б.

Таблица 6.6 — Параметры для типовых почтовых сервисов

Параметр	Джино.Почта	Яндекс 360 для бизнеса	Почтовый сервер организации
SMTP_HOST	smtp.jino.ru	smtp.yandex.ru	Адрес сервера организации
SMTP_PORT	587 либо 465	465	По настройке сервера
SMTP_TLS_MODE	starttls для 587, tls для 465	tls	По настройке сервера
SMTP_USERNAME	Полный адрес ящика	Полный адрес ящика	Учётная запись ящика
SMTP_PASSWORD	Пароль ящика	Пароль приложения	Пароль ящика
SMTP_FROM	Тот же адрес ящика	Тот же адрес ящика	Тот же адрес ящика

Порядок настройки одинаков для всех трёх случаев.

1. Завести отдельный ящик для системы, а не использовать личный ящик работника. Ящик, привязанный к человеку, перестаёт работать при его увольнении вместе со сменой пароля.
2. Записать параметры из таблицы в файл параметров и передать их прикладному серверу, как показано выше.
3. Перезапустить систему и убедиться, что она поднялась: неверное значение останавливает запуск с сообщением о том, какой параметр не принят.
4. Отправить проверочное письмо и получить его.

Особенности отдельных случаев.

Джино.Почта. Логин совпадает с полным адресом ящика вида `passes@organization.ru`. Работают оба порта: 587 с переходом на защищённое соединение после подключения (`starttls`) и 465 с шифрованием с первого байта (`tls`). Если поставщик услуг по заявке открыл отправку через свой почтовый сервер, предел отправки выше обычного, см. ниже.

Яндекс 360 для бизнеса. Пароль от учётной записи здесь не подходит: сервис принимает только пароль приложения, который создаётся в настройках учётной записи отдельно для почтовых программ. Обычный пароль отвергается ошибкой 535, и выглядит это как неверно набранный пароль. Порт 465 с режимом `tls`.

Почтовый сервер организации. Единственный доступный вариант для контура без выхода в сеть общего пользования. Адрес, порт и режим защиты соединения берутся у администратора почтового сервера. Если сервер стоит во внутренней сети и не требует входа по учётной записи, `SMTP_USERNAME` и `SMTP_PASSWORD` оставляют пустыми обоими: заполненный логин без пароля система считает ошибкой. Режим `none` без шифрования допустим только внутри закрытого контура, где защиту канала обеспечивает сама сеть; для сервера в сети общего пользования он недопустим, поскольку логин, пароль и содержимое писем передавались бы открытым текстом.

ВАЖНО. Адрес в `SMTP_FROM` обязан совпадать с ящиком, под которым система входит на почтовый сервер. Отправку от чужого адреса почтовые серверы отвергают ошибкой 550, причём настройка выглядит рабочей ровно до первого письма: подключение и вход проходят успешно, а отказ приходит на этапе передачи письма.

Проверочное письмо

Проверочное письмо отправляется мимо очереди и отвечает сразу: система дожидается ответа почтового сервера и возвращает либо подтверждение отправки, либо разбор причины отказа. Это единственный

способ убедиться в правильности настройки, не дожидаясь первого настоящего письма.

Отправку выполняет метод программного интерфейса POST /api/settings/mail/test. Обращение к нему выполняется с маркером доступа работника, у которого есть право на раздел настроек.

Листинг 6.4 — Получение маркера доступа

```
curl -s -X POST https://<адрес>/api/login \
-H 'Content-Type: application/json' \
-d '{"username":"<логин>","password":"<пароль>"}'
```

Ожидаемый результат: ответ содержит поле token - это и есть маркер доступа. Значение поля подставляется в следующую команду.

Листинг 6.5 — Отправка проверочного письма

```
curl -s -X POST https://<адрес>/api/settings/mail/test \
-H 'Authorization: Bearer <маркер доступа>' \
-H 'Content-Type: application/json' \
-d '{"to":"<адрес получателя>"}'
```

Ожидаемый результат: ответ {"success":true,"data":{"sent":true,"to":"<адрес получателя>"}}, а на указанный адрес приходит письмо с темой «Проверка почтовой рассылки». При неудаче ответ содержит "success":false и объяснение причины: непринятый логин, несовпадающий отправитель, истёкшее ожидание или ошибка защищённого соединения. Разбор ответов приведён в подразделе 13.13.

Проверить, считает ли система почту настроенной, можно методом GET /api/settings/mail/status: он отвечает признаком configured, который равен true только при заданном адресе почтового сервера.

Записи SPF и DKIM в описании домена

Отправить письмо мало, его нужно ещё доставить. Почтовые службы получателей проверяют, разрешено ли этому серверу отправлять письма от имени домена организации, и письмо без такого подтверждения попадает в папку со спамом либо отклоняется молча.

Таблица 6.7 — Записи, требуемые в описании домена отправителя

Запись	Что подтверждает	Кто выдаёт значение
SPF	Список серверов, которым разрешено отправлять письма от имени домена	Поставщик почтовой услуги
DKIM	Подпись письма ключом домена, подтверждающая отправителя и неизменность письма	Поставщик почтовой услуги

Значения записей выдаёт поставщик почтовой услуги, а вносит их в описание домена тот, кто этим доменом управляет. У Джино и Яндекс 360 записи создаются в панели управления доменом, зачастую одним действием при подключении домена к почте.

ВАЖНО. Отсутствие записей SPF и DKIM не даёт никакой видимой ошибки. Проверочное письмо уйдёт успешно, система отчитается об отправке, а получатель писем не увидит: они лягут в папку со спамом или будут отброшены его почтовой службой. Именно поэтому проверку настройки завершают не ответом системы, а полученным письмом во входящих.

Исходящий порт и пределы отправки

На арендованных виртуальных серверах исходящий порт 25 закрыт поставщиком услуг по умолчанию: так борются с рассылками с захваченных серверов. У Джино он закрыт и открывается по заявке в службу поддержки. Система по этому порту не работает: она использует 587 или 465, которые обычно открыты. Проверять доступность порта следует с самого сервера, а не с рабочего места.

Листинг 6.6 — Проверка доступности почтового сервера с сервера системы

```
curl -v --connect-timeout 10 telnet://smtp.jino.ru:587
```

Ожидаемый результат: соединение установлено, сервер отвечает приветственной строкой. Прерывание по истечении срока ожидания означает, что соединение не пропускают правила межсетевого экрана организации либо поставщик услуг.

У поставщиков услуг связи действуют пределы числа отправленных писем. У Джино на обычной отправке это 500 писем в час и 2000 в сутки, а при отправке через почтовый сервер поставщика предел выше, до 5000 писем

в час. Точные значения уточняют у своего поставщика: они меняются и зависят от тарифа.

Собственный предел системы задаётся параметром SMTP_RATE_PER_HOUR (по умолчанию 400 писем в час) и должен оставаться заведомо ниже предела поставщика. Достигнув его, система не теряет письма, а откладывает остаток очереди до следующего часа. Растянутая рассылка безобиднее упора в чужой предел: превысив его, ящик получает отказ на все письма подряд, а при повторных нарушениях поставщик услуг ограничивает отправку целиком.

7. Защищённое соединение и сертификат

7.1. Зачем это нужно

Система работает только по защищённому соединению. Причина не формальная: через неё передаются пароли и персональные данные, которые по незащищённому соединению видны любому, кто имеет доступ к сети между рабочим местом и сервером.

Кроме того, продление сеанса технически работает только по защищённому соединению: браузеру запрещено сохранять маркер продления, полученный по обычному протоколу. Поэтому без сертификата вход в систему не заработает вовсе.

ПРИМЕЧАНИЕ. Сертификат нужен серверу, а не пользователям. Сотрудникам выдаются обычные имя и пароль. Никаких персональных сертификатов сотням работников выдавать не требуется.

7.2. Выбор способа получения сертификата

Сертификат должен быть подписан стороной, которой доверяет браузер. Отсюда три возможных способа, различающихся тем, кто подписывает.

Таблица 7.1 — Способы получения сертификата

Способ	Когда подходит	Что потребуется на рабочих местах
Собственный удостоверяющий центр	Система работает внутри сети, внешнего доменного имени нет	Однократная установка одного корневого сертификата, централизованно групповой политикой
Общедоступный удостоверяющий центр	У организации есть доменное имя, которым она владеет	Ничего, доверие настроено в браузерах изначально
Удостоверяющий центр организации	В организации развёрнута собственная служба сертификатов	Ничего, корневой сертификат уже установлен на машинах домена

ПРИМЕЧАНИЕ. Второй способ часто оказывается удобнее первого, и он применим, даже когда сервер стоит внутри сети и недоступен извне. Владение доменом подтверждается записью в системе доменных имён, а не доступом к серверу. Если у организации есть свой домен, этот путь избавляет от установки чего-либо на рабочие места.

7.3. Выпуск сертификата

Собственный удостоверяющий центр. Применяется при работе внутри сети организации.

Листинг 7.1 — Выпуск сертификата собственным центром

```
./scripts/init-tls.sh self <адрес системы> <IP-адрес сервера>
```

Сценарий создаёт корневой сертификат удостоверяющего центра и подписанный им сертификат сервера. Указание сетевого адреса вторым аргументом позволяет обращаться к системе и по имени, и по адресу.

Ожидаемый результат: выведены сведения о сертификате и путь к корневому сертификату `nginx/certs/ca/ca.crt`.

ВАЖНО. Обратный прокси сценарий перезагружает сам, но обращается для этого к Docker. Запущенный без `sudo`, он не отличает отказ в доступе от незапущенного контейнера и печатает «Контейнер nginx не запущен - перезагрузка не требуется», хотя тот работает. Сертификат при этом заменён, а прокси продолжает отдавать прежний, и предупреждение о недоверенном сертификате никуда не денется. Поэтому на работающей системе прокси перезагружают отдельной командой, как в подразделе 7.5.

Общедоступный удостоверяющий центр. Применяется при наличии доменного имени, доступного из сети общего пользования, и открытого порта 80.

Листинг 7.2 — Выпуск сертификата общедоступным центром

```
./scripts/init-tls.sh self <домен>
sudo make deploy-up
./scripts/init-tls.sh acme <домен> <адрес электронной почты>
```

Порядок двухшаговый: сначала создаётся временный сертификат, чтобы прокси смог запуститься, затем выпускается настоящий. Без первого шага прокси не стартует, а без работающего прокси невозможно подтвердить владение доменом.

Готовый сертификат. Применяется, если сертификат приобретён либо выпущен удостоверяющим центром организации.

Листинг 7.3 — Установка готового сертификата

```
./scripts/init-tls.sh import <файл цепочки> <файл ключа>
```

Сценарий сверяет соответствие ключа сертификату и отказывается устанавливать несовпадающую пару. Это защищает от типичной ошибки, при которой прокси перестаёт запускаться уже после перезапуска, когда разбираться некогда.

7.4. Установка корневого сертификата на рабочие места

Шаг обязателен **только** при выпуске сертификата собственным удостоверяющим центром.

ВАЖНО. Без этого шага работники увидят предупреждение о недоверенном сертификате и не смогут его пропустить. Кнопки «перейти всё равно» не будет: система требует обязательного защищённого соединения, а это запрещает браузеру такой обход. Установка корневого сертификата снимает предупреждение полностью.

Файл для установки: nginx/certs/ca/ca.crt. Он одинаков для всех рабочих мест.

Централизованно в домене. Групповая политика: «Конфигурация компьютера» → «Политики» → «Конфигурация Windows» → «Параметры безопасности» → «Политики открытого ключа» → «Доверенные корневые центры сертификации», импорт файла. Политика применится на рабочих местах при очередном обновлении.

Отдельная машина Windows. Из командной строки с правами администратора:

Листинг 7.4 — Установка корневого сертификата в Windows

```
certutil -addstore -f Root ca.crt
```

Рабочее место Linux.

Листинг 7.5 — Установка корневого сертификата в Linux

```
sudo cp ca.crt /usr/local/share/ca-certificates/buro-ca.crt
sudo update-ca-certificates
```

ОПАСНО. Приватный ключ удостоверяющего центра `nginx/certs/ca/ca.key` позволяет выпустить сертификат на любое имя, которому будут доверять все рабочие места организации. Он не должен покидать сервер и попадать в резервные копии общего доступа.

7.5. Продление сертификата

Сертификат, выпущенный собственным центром, действует 825 суток. За месяц до истечения выпустите новый той же командой: корневой сертификат переиспользуется, поэтому повторно устанавливать его на рабочие места не потребуется.

Листинг 7.6 — Продление сертификата собственного центра

```
./scripts/init-tls.sh self <адрес системы> <IP-адрес сервера>
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec nginx nginx -s reload
```

Сертификат общедоступного центра действует 90 суток и требует регулярного продления. Настройте задание в планировщике суперпользователя, `sudo crontab -e`: продление ведёт `certbot`, а он

работает с каталогом `/etc/letsencrypt`, куда обычному пользователю доступа нет.

Листинг 7.7 — Задание на автоматическое продление

```
30 3 * * * cd /opt/systemburo && ./scripts/init-tls.sh renew \
>> /var/log/systemburo-tls.log 2>&1
```

Команда безопасна для ежедневного запуска: она обращается за новым сертификатом только когда до истечения остаётся менее 30 суток, и перезагружает прокси лишь при фактическом обновлении файла.

Листинг 7.8 — Проверка срока действия

```
openssl x509 -in nginx/certs/fullchain.pem -noout -dates
```

Ожидаемый результат: две строки с датами начала и окончания действия.

8. Проверочный стенд

8.1. Назначение

Проверочный стенд представляет собой второй экземпляр системы, развёрнутый отдельно от рабочего сервера. Он нужен, чтобы проверять изменения и настройки до их применения на рабочем сервере, обучать сотрудников без риска для данных и воспроизводить обращения пользователей.

ВАЖНО. Не разворачивайте стенд на том же сервере, где работает рабочий экземпляр. Они разделят память и дисковую подсистему, и проверка нагрузки на стенде скажется на работе сотрудников.

8.2. Отличия от рабочего сервера

Таблица 8.1 — Отличия стенда от рабочего сервера

Свойство	Стенд	Рабочий сервер
Доступ	Закрыт запросом имени и пароля на входе, кроме программного интерфейса и проверки состояния, см. подраздел 8.5	Открыт, разграничение внутри системы
Подробность журнала	debug	info

Свойство	Стенд	Рабочий сервер
Панель управления базой данных	Поднимается по требованию командой <code>sudo docker compose --profile tools up -d pgadmin</code> , затем доступна по адресу <code>/pgadmin/</code>	Не разворачивается
Наполнение	Допустимы демонстрационные данные	Только рабочие данные
Обновление	Автоматическое: забирает готовые образы из хранилища	Вручную, со сборкой образов на сервере

ПРИМЕЧАНИЕ. Запрос имени и пароля на входе в стенд решает одну задачу, не пустить посторонних. Он не заменяет разграничение прав внутри системы.

8.3. Развёртывание стенда

Порядок совпадает с рабочим сервером, отличаются вызываемые команды.

Листинг 8.1 — Развёртывание стенда

```
make init-staging DOMAIN=<адрес стенда>
sudo make staging-build
sudo make staging-up
sudo make staging-seed PASS=<пароль администратора>
```

Ожидаемый результат: стенд доступен по указанному адресу, при открытии запрашивает имя и пароль, выведенные сценарием подготовки параметров.

ПРИМЕЧАНИЕ. Приведённые команды собирают образы на самом стенде и требуют времени. Последующие автоматические обновления идут иначе - стенд забирает уже собранные образы из хранилища и укладывается примерно в полторы минуты.

ПРИМЕЧАНИЕ. Обратный прокси стенда принимает соединения по незащищённому протоколу и сертификата не требует - выпускать его командой из раздела 7 не нужно. Если стенд должен быть доступен по защищённому соединению, оно обеспечивается внешним прокси перед ним.

Демонстрационное наполнение добавляется отдельно:

Листинг 8.2 — Добавление демонстрационных данных

```
sudo make staging-seed-demo PASS=<пароль администратора>
```

8.4. Наполнение стенда вымышленными данными

Демонстрационный набор из предыдущего раздела невелик и неизменен. Чтобы проверять поведение системы на объёме - списки, поиск, отбор, показатели работы, печатные формы - стенд наполняют вымышленными данными: организациями, работниками, машинами, заявками и отметками проезда. Записи заводятся тем же путём, что и при работе руками, поэтому связаны между собой: у заявки есть организация, заявитель, согласующие, вложения с людьми и машинами из справочников, история обработки и отметки на постах.

ВАЖНО. Наполнение предназначено только для стенда. На рабочем сервере команда для него не предусмотрена, а сама она отказывается работать, пока экземпляр не отмечен как проверочный стенд.

Отметка ставится один раз:

Листинг 8.3 — Отметка экземпляра как проверочного стенда

```
sudo make staging-fake ARGS="-mark-stand"
```

Ожидаемый результат: сообщение о том, что экземпляр отмечен, с указанием имени базы данных.

Перед наполнением команда показывает, что будет создано, и ничего не записывает:

Листинг 8.4 — Предварительный показ

```
sudo make staging-fake ARGS="-profile=medium"
```

Наполнение выполняется отдельным запуском:

Листинг 8.5 — Наполнение стенда

```
sudo make staging-fake ARGS="-profile=medium -apply"
```

Ожидаемый результат: перечень созданного по видам записей, пароль заведённых работников и значение источника случайности. Повторный запуск с тем же значением источника даёт тот же набор данных - это позволяет воспроизвести обстоятельства, при которых обнаружилось замечание.

Отметки проезда и прохода в этот перечень не входят и показываются отдельной таблицей: они ставятся на уже созданных машинах и работниках, новых записей не добавляют и вместе с партией не удаляются отдельно - машина и работник принадлежат заявке и уходят вместе с ней. В предварительном показе их число приблизительное. Через пост проходят только те, чью заявку приняли в работу и чей пропуск на тот момент ещё действовал, зато отмечаются машины и работники в заявках, а одна запись справочника попадает в несколько заявок, поэтому отмеченных бывает и меньше обещанного, и больше.

Таблица 8.2 — Объём наполнения по заготовкам

Заготовка	Организаций	Работников	Заявок	Период дат
small	3	10	30	30 суток
medium	10	50	300	180 суток
large	50	500	5000	365 суток

Отдельные значения заменяются флагами: -applications, -users, -cars, -employees, -days-back. Полный перечень флагов выводит make staging-fake ARGS="-help".

ПРИМЕЧАНИЕ. Работники заводятся с общим паролем, который печатается в конце наполнения. Он предназначен для входа на стенде и не должен сохраняться в обращениях и постоянных журналах.

За каждого заведённого работника наполнение сразу расписывается в согласии на обработку персональных данных - той редакции текста, которая на стенде действует сейчас. Без этого стенд с включённым обязательным согласием при входе встречал бы каждого вымышленного работника окном согласия и дальше не пускал: данные в списках есть, а войти под ними нельзя. В записи согласия видно, что его проставило наполнение, а не человек из браузера.

Каждое наполнение образует партию с меткой. Партии перечисляются и удаляются целиком:

Листинг 8.6 — Перечень и удаление партий

```
sudo make staging-fake ARGS="-list"
sudo make staging-fake ARGS="-purge=<метка партии>"
sudo make staging-fake ARGS="-purge=<метка партии> -apply"
```

Ожидаемый результат: удаление снимает записи партии и сведения об их изменении. Данные, заведённые на стенде руками, остаются нетронутыми. Справочники и образцы вложений, которыми пользуются другие партии, тоже сохраняются и показываются в отчёте отдельным столбцом.

8.5. Ограничение доступа к стенду

Стенд доступен из сети, и его содержимое показывается только после ввода имени и пароля: браузер запрашивает их при первом открытии адреса. Проверку выполняет обратный прокси стенда. До прикладного сервера этот запрос не доходит, с учётными записями системы он никак не связан, и войти в систему всё равно потребуется отдельно. На рабочем сервере такого запроса нет.

Как устроено. Имя и пароль задаются параметрами BASIC_AUTH_USER и BASIC_AUTH_PASS в файле параметров стенда. При каждом запуске контейнера прокси из них создаётся файл `/etc/nginx/.htpasswd`, в котором пароль хранится необратимой свёрткой. Готовит этот файл сценарий `nginx/staging-entrypoint.sh`, правило проверки записано в `nginx/staging.conf`, средство расчёта свёртки добавлено в образ прокси файлом `nginx/Dockerfile.staging`.

Начальные значения создаёт сценарий подготовки параметров: имя `admin`, пароль случайный, оба выводятся на экран при выполнении `make init-staging`.

ВАЖНО. Если обоих параметров в файле не окажется, прокси поднимется с именем и паролем из состава поставки, известными каждому, кто видел исходный код.

ВАЖНО. Браузер передаёт этот пароль в каждом запросе, и защищает его только само соединение. Пароль стенда не должен совпадать ни с одним паролем рабочего сервера.

Что закрыто, а что нет. Пароль спрашивается при обращении к веб-приложению и к панели управления базой данных. Часть адресов отвечает без него.

Таблица 8.3 — Адреса стенда, отвечающие без запроса пароля

Адрес	Почему открыт
/health	Проверка состояния мониторингом и конвейером сборки, выполняется без учётных данных
/api/	Программный интерфейс: обращения к нему предъявляют маркер доступа, полученный при входе в систему
/api/events	Поток событий, открывается тем же маркером
/swagger/	Описание программного интерфейса, отдаётся только при SWAGGER_ENABLED=true

ВАЖНО. Запрос пароля закрывает интерфейс, но не программный интерфейс. Данные стенда защищены входом в систему ровно так же, как на рабочем сервере, поэтому переносить на стенд рабочие персональные данные нельзя.

Сколько действует однажды введённый пароль. После верного ввода прокси выдаёт браузеру признак `staging_auth` сроком на семь суток, и всё это время пароль не запрашивается. При неверном вводе признак не выдаётся. С самим паролем он не связан: смена пароля не закрывает доступ тому, кто уже вошёл, до истечения этого срока. Значение признака постоянное и подписью не защищено, поэтому запрос пароля отсекает случайного посетителя, а не подготовленного.

ПРИМЕЧАНИЕ. Признак помечен как передаваемый только по защищённому соединению. Если стенд открывается по незащищённому адресу, браузер его не сохранит, и пароль будет запрашиваться при каждом обращении.

Смена имени и пароля. Значения правятся в файле параметров стенда.

Листинг 8.7 — Строки файла параметров

```
BASIC_AUTH_USER=<имя>
BASIC_AUTH_PASS=<пароль>
```

Листинг 8.8 — Применение изменений

```
sudo make staging-up
```

Ожидаемый результат: контейнер прокси пересоздан, прежняя пара больше не принимается.

Листинг 8.9 — Проверка на сервере стенда

```
curl -sI -u <имя>:<пароль> http://localhost/
curl -sI http://localhost/
```

Ожидаемый результат: первая команда отвечает кодом 200, вторая - кодом 401 с заголовком WWW-Authenticate.

ВАЖНО. Если стенд обходится автоматической проверкой страниц из конвейера сборки, новые значения нужно внести и в её настройки. Иначе проверка остановится на запросе пароля и начнёт сообщать о недоступности стенда.

Отключение и обратное включение. Отдельного параметра для этого нет, запрос пароля снимается правкой конфигурации прокси. В файле `nginx/staging.conf` в блоке `server` строка `auth_basic $staging_realm;` заменяется на `auth_basic off;`.

Листинг 8.10 — Перезапуск прокси стенда

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.staging.yml \
restart nginx
```

Ожидаемый результат: `curl -sI http://localhost/` отвечает кодом 200 без запроса пароля. Обратное включение - вернуть прежнюю строку и повторить перезапуск. Файл конфигурации подключён к контейнеру напрямую, пересобирать образ не требуется.

ВАЖНО. Снимать запрос пароля допустимо, только если стенд закрыт от посторонних сетевыми средствами. Иначе открытым окажется всё, включая панель управления базой данных.

9. Эксплуатация рабочего сервера

9.1. Основные команды

Таблица 9.1 — Команды управления системой

Действие	Команда
Запуск	<code>sudo make deploy-up</code>
Остановка	<code>sudo make deploy-down</code>

Действие	Команда
Пересборка образов	<code>sudo make deploy-build</code>
Просмотр журналов	<code>sudo make deploy-logs</code>
Состояние служб	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml ps</code>
Резервная копия сейчас	<code>sudo make deploy-backup</code>
Состояние копий	<code>sudo make deploy-backup-status</code>
Обзор занятого места	<code>sudo make deploy-storage</code>
Очистка накопленных данных	<code>sudo make deploy-cleanup</code>
Настройка файлового архива	<code>sudo make deploy-archive ARGS="show"</code>

Команды выполняются под учётной записью, заведённой в подразделе 5.1, и требуют `sudo`: доступ к Docker выдан через него, а не членством в группе. Пароль спрашивается на первой команде и затем четверть часа не запрашивается.

Остановка прерывает работу пользователей. Прикладной сервер завершается корректно: перестаёт принимать новые запросы, даёт до 10 секунд на завершение текущих и только затем останавливается, поэтому незавершённых операций записи при штатной остановке не остаётся.

Команды, которые спрашивают подтверждение. Пароль, не запрашиваемый четверть часа, снимает последнюю преграду перед опечаткой: набранное не то имя команды выполняется молча, а двум командам из перечня ниже для порчи данных не нужно ни одного аргумента. Поэтому перед работой они спрашивают слово. Пока его набирают, читают, что именно произойдёт и почему этого не отменить.

Таблица 9.2 — Команды, требующие подтверждения

Команда	Что произойдёт	Слово
<code>sudo make deploy-seed</code>	Перезаписывается пароль супер-администратора, прежний перестаёт работать	ПЕРЕЗАПИСАТЬ
<code>sudo make deploy-seed-demo</code>	На рабочий сервер наливается вымышленные организации, заявки, работники и машины	НАЛИТЬ
<code>sudo make deploy-cleanup ARGS="... -apply"</code>	Записи, попавшие под условия очистки, удаляются безвозвратно	УДАЛИТЬ

Слово сверяется целиком. Любой другой ответ, в том числе пустой, прекращает работу строкой «Отменено, ничего не выполнено», и до самой операции дело не доходит. Запуск без человека за клавиатурой отвечает пустой строкой, то есть тоже прекращается. Очистка спрашивает только в режиме применения: предварительный показ ничего не удаляет, а вопрос на безопасном вызове приучал бы отвечать не глядя. Восстановление из копии устроено так же и спрашивает слово ВОССТАНОВИТЬ, подраздел 11.7.

Подтверждение снимается переменной CONFIRM=yes, заданной перед командой, - это нужно для запусков по расписанию и из сценариев. На рабочем сервере воспользоваться этим под учётной записью сопровождения не выйдет: sudo очищает окружение, поэтому запись CONFIRM=yes sudo make deploy-seed до цели не дойдёт, а задать переменную после sudo разрешение на две команды не позволяет. Обойтись без вопроса можно только с полными правами суперпользователя, где sudo в самой команде не участвует.

ВАЖНО. Подтверждение защищает от опечатки и невнимательности, но не от умысла. То же самое делается обращением к контейнеру напрямую, минуя make, и там никто ничего не спрашивает. Тот, кто вошёл под учётной записью сопровождения и знает её пароль, по-прежнему может всё, о чём сказано в подразделе 5.1.

9.2. Повседневные операции

Таблица 9.3 — Регламент повседневных работ

Операция	Периодичность	Кто выполняет
Контроль состояния служб	Ежедневно	Подразделение ИТ
Просмотр журнала на ошибки	Ежедневно	Подразделение ИТ
Просмотр журнала отказов в доступе	Еженедельно	Подразделение ИТ либо оператор системы с правом просмотра
Свежесть резервной копии	Ежедневно	Подразделение ИТ; полных прав на сервере для этого не требуется, подраздел 11.5
Контроль свободного места	Еженедельно	Подразделение ИТ

Операция	Периодичность	Кто выполняет
Контроль срока действия сертификата	Ежемесячно	Подразделение ИТ
Проверка восстановления из резервной копии	Ежемесячно	Подразделение ИТ

ПРИМЕЧАНИЕ. Наблюдение за журналами системы и разбор обращений пользователей доступны не только подразделению ИТ, но и операторам бюро пропусков, если им выдано соответствующее право. Журналы открываются прямо в интерфейсе системы, доступ к серверу для этого не нужен.

9.3. Управление учётными записями

Заведение и блокировка работников выполняются в интерфейсе системы и описаны в руководстве администратора. С точки зрения эксплуатации существенны три обстоятельства.

Блокировка действует немедленно: заблокированный работник теряет все права, а его сеансы прекращаются, поэтому продолжить работу в уже открытой вкладке он не сможет.

Блокировку входа после неудачных попыток пароля не следует путать с блокировкой работника: первая временная и снимается сама по истечении срока. Срок растёт с каждой новой серией из пяти неудач - минута, пять, пятнадцать, тридцать минут, час, - поэтому работник, который перебирает забытый пароль, ждёт всё дольше. Чтобы не заставлять его ждать, администратор снимает такую блокировку кнопкой в карточке работника; обращение к серверу для этого не нужно.

Изменение прав вступает в силу с задержкой до 30 секунд, поскольку результат вычисления прав кэшируется. Для открытых страниц с автообновлением задержка может достигать 10 минут.

Заведение учётной записи и первый вход

Пароль новому работнику придумывает система, а не человек, который его заводит. В форме создания поле пароля можно оставить пустым: тогда система придумает пароль по действующим требованиям и вышлет его

работнику письмом вместе с логином и адресом системы. Тот, кто заводит учётную запись, пароля не видит и передавать его не должен.

Пустое поле допустимо не всегда, и отказ объясняет причину. Без указанного адреса почты придуманный пароль доставить нечем - система откажет и попросит либо заполнить адрес, либо задать пароль вручную. То же самое при ненастроенной почте: отправлять некуда, даже если адрес заполнен. Настройка почты описана в разделе 6.6.

Пароль, заданный администратором вручную, работает и остаётся способом завести учётную запись человеку без адреса почты - например, охраннику на посту. Передать такой пароль работнику придётся лично.

Свой пароль работник задаёт при первом входе - в обоих случаях. И придуманный системой, и заданный администратором пароль прошёл через чужие руки, а высланный письмом ещё и лежит в почтовом ящике открытым текстом. До тех пор, пока работник не задаст свой, система отвечает отказом на всё, кроме самой формы смены пароля: войти он войдёт, но работать не начнёт.

Порядок первого входа, когда включено требование согласия на обработку персональных данных (раздел 13.2): сначала работник соглашается с текстом, затем задаёт свой пароль, и только после этого система открывается. Оба окна появляются сами, идти за ними никуда не нужно.

Таблица 9.4 — Что происходит при заведении учётной записи

Адрес почты	Поле пароля	Что делает система
Указан, почта настроена	Оставлено пустым	Придумывает пароль, шлёт работнику письмо с логином и паролем, требует сменить пароль при первом входе
Указан, почта настроена	Заполнено	Сохраняет заданный пароль, шлёт работнику письмо с логином и этим паролем, требует сменить при первом входе
Указан, почта не настроена	Оставлено пустым	Отказывает: доставить пароль нечем
Не указан	Оставлено пустым	Отказывает: прочитать пароль работнику будет негде

Адрес почты	Поле пароля	Что делает система
Не указан	Заполнено	Сохраняет пароль, письма нет, требует сменить при первом входе

Срок действия паролей

Система умеет требовать от работников смены пароля по истечении заданного срока. В поставке эта возможность выключена: включать её должен человек осознанно. Паролей она не меняет и по почте не рассылает - работник, у которого срок вышел, входит своим прежним паролем, после чего система просит задать новый и до этого никуда его не пускает.

Включение. Раздел «Настройки», вкладка «Безопасность», блок «Срок действия паролей». Настроенная почта для включения не требуется: без неё не уйдут только предупреждения о скором истечении, а сама проверка сроков работает. Настроек четыре.

Таблица 9.5 — Настройки срока действия паролей

Настройка	Допустимые значения	Что задаёт
Требовать смену пароля по истечении срока	Включено, выключено	Общий выключатель. По умолчанию выключен
Срок действия пароля, суток	От 30 до 120, по умолчанию 90	Через сколько суток после последней смены пароль считается истёкшим. Верхняя граница - требование приказа ФСТЭК России N 21 для информационных систем персональных данных
Предупреждать заранее, суток	От 0 до 30, по умолчанию 7	За сколько суток до истечения работник получает письмо и уведомление. Ноль - не предупреждать. Требуется настроенной почты и указанного у работника адреса
Требовать сменить пароль при первом входе	Включено, выключено	Относится к паролям, которые придумывает сама система: обновлению паролей всем работникам и смене из карточки. Такой пароль годится ровно на один вход - до тех пор, пока работник не задаст свой, система в остальном ему отказывает. Включено по умолчанию, выключать не следует: это единственное, что ограничивает срок жизни пароля, лежащего в почтовом ящике открытым текстом. По истечении срока действия смена требуется всегда, независимо от этой настройки

Проверка сроков выполняется ежесуточно в 04:00 по часовому поясу из параметра RESET_TIMEZONE. Отдельный планировщик в операционной системе для этого не нужен. Повторный проход того же дня никого не выберет заново: уже помеченные из отбора исключены.

Что показывает блок состояния. Числа в блоке считаются по тем же условиям, по которым отбирает работников сама проверка, поэтому увиденное на экране совпадает с тем, что произойдёт.

Таблица 9.6 — Показания блока состояния

Показание	Толкование
Ближайшая проверка	Когда планировщик проснётся в следующий раз
Срок действия пароля вышел у работников	У скольких работников срок уже истёк, то есть скольким система при следующем входе покажет форму смены пароля. Часть из них могла быть помечена в прошлые сутки, поэтому это не размер ближайшего прогона
Учётных записей с почтой	Действующие незаблокированные записи с указанным адресом. Столько писем уйдёт при обновлении паролей всем работникам
Без почты	Действующие незаблокированные записи без указанного адреса. Проверки сроков это не касается, но предупредить их заранее не получится

Обновление паролей всем работникам. Кнопка «Обновить пароль всем работникам» в том же блоке - отдельный инструмент, к сроку действия отношения не имеющий. Она придумывает новый пароль **всем** действующим незаблокированным работникам с указанным адресом почты, а не только тем, у кого срок вышел, и каждому высылает его письмом. Заблокированных и перенесённых в архив прогон не затрагивает. Кнопка показывается только при настроенной почте: доставить придуманный пароль без неё нечем. Прогон закрыт отдельным правом «Смена паролей всем работникам»: право на раздел настроек его не включает, поэтому работник, которому разрешено править контактный телефон бюро, сбрасывать пароли всей организации может быть не вправе. Администраторы получают это право вместе с полным доступом. Перед выполнением система показывает окно подтверждения с числом затрагиваемых работников.

ВАЖНО. Это исключительная мера, а не способ планового обновления. Прогон обрывает работу всех, кого он затронул: смена пароля аннулирует маркеры продления сеанса на всех устройствах, поэтому работники теряют открытые сеансы и входят заново - уже новым паролем из письма, а при включённом требовании смены сразу задают свой. Уместен он при подозрении на утечку паролей, при первичной раздаче паролей после ввода системы в эксплуатацию и после переноса на другой сервер. В рабочее время его выполнять не следует. Для повседневного обновления паролей служит срок действия, описанный выше: он ничего не рассылает и работу не прерывает.

ПРИМЕЧАНИЕ. Письма уходят очередью и с оглядкой на предел отправки (SMTP_RATE_PER_HOUR, по умолчанию 400 писем в час), поэтому при большом числе работников рассылка растягивается на часы: остаток очереди откладывается до следующего часа, но не теряется. Пароль при этом сменён сразу, а письмо к нему может прийти позже - учитывать это при выборе времени прогона.

Смена пароля одному работнику выполняется без общего прогона: в разделе «Пользователи», в карточке работника, кнопка «Сменить пароль и отправить письмом». Система придумает пароль по действующим требованиям и отправит его на указанный в карточке адрес. Это порядок для случая «работник потерял пароль», и он тоже исключение, а не повседневность: пароль, придуманный системой, уходит по почте открытым текстом.

Работники без адреса почты. Проверке сроков адрес не нужен, и такие учётные записи она берёт наравне со всеми. Пропускают их только два действия выше - выслать придуманный пароль некуда, - и предупреждение о скором истечении: оно приходит письмом. Полный список открывается в разделе «Пользователи» переключателем режима списка в положение «Без почты». По итогам каждого прогона работники с правом на раздел настроек получают уведомление внутри системы, а при настроенной почте ещё и письмо с итогом. После проверки сроков в нём число помеченных истёкшими; после обновления паролей всем - сколько паролей сменено,

сколько пропущено без адреса и перечень таких логинов (в письме первые двадцать, полный список смотрят в разделе «Пользователи»).

Свой пароль работник меняет сам в личном кабинете кнопкой «Сменить пароль», подтверждая действие текущим паролем. Сменив пароль заранее, работник начинает отсчёт срока заново, и требование смены его не застанет - именно к этому и подталкивает предупреждение, приходящее за несколько суток до истечения.

Запрет повторного использования паролей

Вернуться к паролю, которым учётная запись уже пользовалась, система не даёт. Проверяются десять последних паролей работника; попытка задать любой из них отклоняется сообщением «Этот пароль уже использовался. Придумайте пароль, которым вы раньше не пользовались». Действующий пароль при отклонённой попытке не меняется.

Правило одинаково для всех путей смены и обойти его, зайдя с другой стороны, нельзя: оно работает и когда работник меняет пароль сам, и когда пароль задаёт администратор из карточки, и при обновлении паролей всем работникам. Пароль, придуманный системой, тоже запоминается - иначе работник, получив письмо, смог бы «сменить» пароль на тот же самый. Первый пароль запоминается вместе с заведением учётной записи.

Глубина в десять паролей - осознанный предел, а не круглое число. Пароли хранятся не в открытом виде, а хешами, и сравнение с перечнем означает вычисление хеша заново на каждую запись. Проверка всех паролей за всю историю работника заставила бы форму смены думать секундами; на десяти она укладывается в доли секунды. Пароль, ушедший за десятую позицию, снова разрешён.

Перечень прежних паролей закрыт: он не показывается ни в истории работника, ни в выгрузках, и не отдаётся ни одним методом. Хранятся только хеши - восстановить из них пароль нельзя. Записи глубже десятой удаляются сразу при смене пароля, поэтому перечень не растёт и отдельной уборки по

расписанию не требует. Вместе с удалением учётной записи исчезает и её перечень.

ПРИМЕЧАНИЕ. Запрет распространяется на пароли одной учётной записи, а не на все пароли системы. Совпадение паролей у разных работников система не отслеживает и отследить не может - хеши считаются с разной солью и между собой не сравниваются.

Вход в систему от имени работника

Работник жалуется, что раздел не открывается, список пуст или кнопка не работает, а на экране администратора всё в порядке. Чтобы увидеть систему его глазами, знать его пароль не нужно: администратор входит от его имени, а система пишет в журнал, что за этими действиями стоял он.

Как войти. Раздел «Пользователи», карточка работника, кнопка «Войти как пользователь» рядом с кнопкой «Права доступа». Открывается «Обзор и новости» - уже от имени выбранного работника: меню, разделы и списки те же, что видит он. Кнопка показывается только при праве «Вход от имени пользователя»; её нет для самого себя, для архивных и заблокированных учётных записей и для тех, от чьего имени входить не положено по полномочиям: от имени супер-администратора не входит никто, от имени администратора - только супер-администратор.

Отказ при нажатии означает одно из двух. Либо у выбранного работника есть право, которого нет у самого администратора, - войти от имени более полномочного система не даёт. Либо работнику назначена обязательная смена пароля: до неё его учётная запись закрыта и для него самого, и войти от его имени значило бы упереться в то же окно смены пароля. Так бывает у работников с истёкшим сроком действия пароля, а сразу после обновления паролей всем работникам - у каждого, кому пароль сменили, до тех пор, пока он не задаст свой.

Что на экране. Внизу постоянно висит полоса «Вы работаете от имени» с фамилией и именем работника, остатком времени сеанса и кнопкой «Вернуться в свою учётную запись». Полоса видна на любом экране и ничем

не перекрывается - это единственный признак, отличающий чужой экран от своего.

Как вернуться. Кнопкой на полосе; открывается «Обзор и новости» уже под своей учётной записью. Права при возврате пересчитываются, поэтому раздел, открытый глазами работника, может оказаться недоступен - это ожидаемо. Сеанс заканчивается и сам: маркер действует 30 минут и не продлевается, по истечении система сообщает, что режим истёк, и возвращает администратора в его учётную запись. Если разбор не завершён, в режим входят заново.

Что в режиме не работает. Смотреть можно всё, что видит работник, менять - не всё. Закрыты смена паролей (своего, чужого и рассылкой всем), общесистемные настройки, перенос учётных записей в архив и восстановление, смена типа, роли, признака администратора и групп прав, правка прав и ролей, блокировка и разблокировка, снятие блокировки входа, подтверждение и отзыв согласия на обработку персональных данных, а также вход от имени третьего работника. На такую попытку система отвечает отказом и предлагает вернуться в свою учётную запись. Перечень с обоснованием приведён в техническом описании системы, подраздел 13.3.

Что остаётся в журнале. Вход в режим и выход из него записываются в историю той учётной записи, от чьего имени работали, с указанием администратора, открывшего сеанс. Действия, выполненные внутри режима, дополнительно несут в журнале отметку об инициаторе - по ней они отличимы от действий самого работника.

ВАЖНО. Режим не заменяет смену пароля и не предназначен для неё. Работнику, потерявшему пароль, меняют пароль кнопкой «Сменить пароль и отправить письмом» в той же карточке - система придумает пароль сама и отправит письмом. Заходить от имени работника, чтобы «проверить пароль» или задать ему новый, бессмысленно: пароль в режиме не проверяется, а смена пароля в нём запрещена.

9.4. Восстановление доступа супер-администратора

Супер-администратор в системе один. При утрате доступа к нему восстановление выполняется повторным запуском команды создания учётной записи: она не создаёт вторую запись, а обновляет пароль существующей.

Листинг 9.1 — Смена пароля супер-администратора

```
sudo make deploy-seed PASS=<новый пароль>
```

Прежде чем что-либо менять, команда спрашивает слово ПЕРЕЗАПИСАТЬ и показывает, что именно перезапишет. Вопрос задаётся до обращения к базе, поэтому запуск, прекращённый на этом месте, не меняет ничего.

Ожидаемый результат: команда завершается без ошибок, вход выполняется с новым паролем. Прочие данные не затрагиваются.

9.5. Режим технических работ

Режим включается супер-администратором в разделе системного управления. При включённом режиме все работники, кроме супер-администратора, попадают на страницу технических работ и не могут выполнять действия.

Режим следует включать перед обновлением и любыми работами, затрагивающими целостность данных. Он не останавливает фоновые задачи и не прерывает уже выполняющиеся запросы.

При включении заполняются четыре поля. Все они видны пользователю на странице технических работ, поэтому заполнять их следует так, как если бы вы отвечали на вопрос «когда всё заработает и к кому обращаться».

Таблица 9.7 — Данные, объявляемые при включении режима

Поле	Назначение
Сообщение	Что именно делается и чего ждать пользователю. Показывается крупно, первым
Начало работ	Дата и время начала. Отображается как срок, не как момент включения

Поле	Назначение
Окончание работ	Дата и время окончания. Задаёт срок и одновременно служит предохранителем
Почта и телефон поддержки	Куда обращаться, пока система недоступна. Незаполненное поле не показывается

Начало и окончание задаются целиком: система не примет одну половину окна и не примет окончание раньше начала. По объявленному окну страница считает, сколько времени осталось, и показывает долю прошедшего времени.

Режим снимается сам, когда объявленное окончание прошло. Проверка выполняется при любом обращении к признаку режима, отдельная фоновая задача для этого не нужна. Снятие записывается в журнал событий как `maintenance_auto_disabled`. Поэтому даже забытый включённым режим отпускает пользователей в назначенный срок.

Вход супер-администратора при включённом режиме. Пока режим активен, обычного пользователя уводит на страницу технических работ с любого адреса, включая форму входа. Для супер-администратора на странице технических работ есть ссылка «Вход для администратора» (адрес `/?admin`) — она открывает форму входа. Обычному работнику эта ссылка не поможет: его учётной записи система откажет во входе, пока идут работы.

Аварийное снятие режима. Если войти в систему не удаётся вовсе — утрачен пароль супер-администратора или недоступен интерфейс, — режим снимается на сервере одной командой. Прикладной сервер перезапускать не нужно: признак режима хранится не дольше десяти секунд.

Листинг 9.2 — Снятие режима технических работ на рабочем сервере

```
sudo make deploy-maintenance-off
```

Ожидаемый результат: команда печатает текущее значение признака (`maintenance.enabled = false`), пользователи возвращаются в систему в течение десяти секунд. Для проверочного стенда команда называется `make staging-maintenance-off`, для локальной установки — `make maintenance-off`.

Восстановление самого доступа супер-администратора выполняется отдельно, порядок описан в подразделе 9.4.

9.6. Файловый архив бланков

В папке каждой заявки лежат её бланки, машиночитаемое описание и подпапка «Приложения» с файлами, которые заявитель приложил при подаче. Имена приложенных файлов приходят от заявителя, поэтому они отделены от бланков: иначе одноимённый файл затёр бы печатную форму.

Система выкладывает сформированные бланки в каталог на диске сервера. Путь задаётся параметром `ARCHIVE_HOST_PATH`, раскладка внутри каталога и пределы занимаемого места - командой `server archive` на сервере. Раздел администрирования «Файловый архив» действующие значения показывает, но не меняет.

ОПАСНО. Каталог архива должен лежать вне каталога загруженных файлов, а каталог загруженных файлов - вне архива. Прикладной сервер проверяет это при запуске и с вложенным каталогом не стартует. Причина в том, что загруженные файлы раздаются по прямой ссылке без входа в систему: архив внутри них означал бы, что заполненный бланк со сведениями документов открывается любым, кто угадает адрес. Проверка ведётся по фактическому пути с разворачиванием символических ссылок, поэтому подложить каталог ссылкой не получится.

Каталог создаёт администратор до включения выгрузки и отдаёт его владельцу, под которым работает прикладной сервер: процесс не имеет права менять владельца файлов и на чужом каталоге остановится. Система создаёт подкаталоги правами 0750, файлы - 0640, поэтому содержимое читают только этот пользователь и его группа.

Листинг 9.3 — Подготовка каталога архива

```
sudo mkdir -p /srv/buro-archive
sudo chown 1001:1001 /srv/buro-archive
sudo chmod 0750 /srv/buro-archive
```

Ожидаемый результат: каталог существует, владелец совпадает с пользователем прикладного сервера.

ВАЖНО. Если `ARCHIVE_HOST_PATH` не задан, каталог создаётся сам при первом запуске - рядом с файлами системы и от имени администратора машины. Владелец у него окажется чужой, и запись не пойдёт: строки очереди уйдут в состояние ошибки с сообщением о запрете доступа. Проверить владельца и при необходимости выдать каталог прикладному серверу нужно и в этом случае, командами из листинга выше с путём фактического каталога.

Проверить, что каталог виден прикладному серверу под нужным владельцем, можно не заходя в файловую систему хоста:

Листинг 9.4 — Проверка владельца изнутри контейнера

```
sudo make deploy-archive ARGS="show"
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml exec backend ls -ld /app/archive
```

Ожидаемый результат: первая команда печатает каталог архива, вторая - строку, в которой владелец и группа совпадают с пользователем прикладного сервера.

Шифрование архива

По умолчанию бланки лежат в архиве открытыми: так их читает принимающая сторона без дополнительных средств. Если каталог отдаётся в сеть или хранится на носителе, который может быть утрачен, включите шифрование - файлы станут нечитаемыми ни при доступе к папке, ни при краже копии.

Порядок такой. Принимающая сторона создаёт пару ключей командой `age-keygen -o receiver.key`; открытый ключ (строка вида `age1...`) передаётся вам, закрытый остаётся у неё и никуда не пересылается. На сервере создаётся вторая пара - для самой системы: `age-keygen -o /opt/systemburo/archive.key`. Затем в файле параметров заполняются `ARCHIVE_AGE_RECIPIENT` открытым ключом принимающей стороны и `ARCHIVE_AGE_IDENTITY` закрытым ключом системы, после чего службы перезапускаются.

Оба параметра задаются только вместе: открытый ключ без ключа системы служба отвергает при запуске, потому что иначе стала бы писать

файлы, которые сама не прочитает, и выгрузка архива по кнопке в карточке заявки перестала бы работать.

После включения новые файлы получают имя с окончанием `.age` и открываются командой `age -d -i receiver.key -o бланк.xlsx 'бланк.xlsx.age'`. Ранее записанные файлы остаются как были и продолжают читаться.

Ключ нужен только тому, кто берёт файлы прямо из каталога. Через систему они по-прежнему скачиваются обычным способом: и выгрузка за период, и отдельный файл из раздела «Файловый архив», и сохранённый бланк в карточке заявки приходят расшифрованными, под своим именем и без окончания `.age`. Расшифровка идёт на лету, на диске файл остаётся закрытым.

Перевести их в зашифрованный вид можно двумя способами, и один другой не заменяет. Выгрузка задним числом за нужный период из раздела администрирования пересобирает бланки заново, и пересобранный файл пишется уже зашифрованным. Замороженные файлы она не трогает: их содержимое окончательно и повторно не формируется. Такие файлы закрывает отдельная команда - она берёт лежащий на диске файл и шифрует его как есть, не меняя содержимого.

```
sudo make deploy-archive ARGS="encrypt"  
sudo make deploy-archive ARGS="encrypt -apply"
```

Ожидаемый результат: первая команда только считает и печатает, сколько открытых файлов найдено; вторая закрывает их и сообщает итог. Без ключа `-apply` не изменяется ничего. Повторный запуск безопасен: уже закрытые файлы в работу не берутся, поэтому прерванный прогон достаточно повторить.

ВАЖНО. Команда нужна один раз - когда ключи задали позже, чем начали писать архив. Если ключи заполнены до первого запуска системы, открытых файлов в архиве не появляется вовсе. Чтобы такое не прошло незамеченным, при `REQUIRE_ENCRYPTION=true` служба отказывается запускаться с незаполненными ключами архива: требование шифрования, заявленное однажды, распространяется и на архив.

ОПАСНО. Закрытый ключ системы хранится там же, где ключ шифрования персональных данных, и на тех же условиях - вне резервных копий архива. При его утрате ранее записанные файлы читает только принимающая сторона своим ключом; если утрачены оба, содержимое не восстанавливается.

Шифрование файлов не отменяет защиты носителя. Раздел, на котором лежит архив, рекомендуется шифровать средствами операционной системы (для Linux это LUKS): это закрывает не только сами файлы, но и имена, размеры и структуру каталогов, по которым видно, сколько заявок и от каких организаций проходит через бюро.

Место сторожат три настройки, задаваемые командой `server archive set` на сервере. Порог предупреждения задаёт долю заполнения раздела, после которой ответственным за архив уходит уведомление; по умолчанию это 80 процентов. Наименьший остаток свободного места (по умолчанию два гигабайта) и предельный объём самого архива (по умолчанию не ограничен) - жёсткие пределы, при которых запись останавливается. Действующие значения показывает `server archive show` и раздел администрирования «Файловый архив».

Настройки архива задаются на сервере, а не через интерфейс: раскладка каталогов определяет, где физически лежат документы со сведениями работников, и менять её должен тот, кто отвечает за сервер. Команда выполняется в контейнере прикладного сервера, запускает её `make deploy-archive`, а подкоманда и её ключи передаются в ARGV.

Таблица 9.8 — Настройка файлового архива

Команда	Назначение
<code>sudo make deploy-archive ARGV="show"</code>	Действующие настройки, каталог из переменных окружения и пример готового пути

Команда	Назначение
<code>sudo make deploy-archive ARGS="preview -dir Ш -file Ш"</code>	Путь по новым шаблонам на примере последней заявки, перечень плейсхолдеров, замечания к ошибочным
<code>sudo make deploy-archive ARGS="set ..."</code>	Изменение настроек: -dir, -file, -quota, -min-free, -warn, -recheck, -freeze, -zip-max
<code>sudo make deploy-archive ARGS="on" и ARGS="off"</code>	Включение и выключение выгрузки
<code>sudo make deploy-archive ARGS="encrypt"</code>	Подсчёт файлов, записанных до включения ключей шифрования; с ключом -apply - их закрытие

Размеры принимаются числом байт либо с единицей: 2G, 512M, 750K. Перед изменением шаблона стоит посмотреть результат командой предпросмотра: шаблон без номера заявки сложит все заявки дня в один каталог, а неизвестный плейсхолдер команда отклонит. Каждое изменение записывается в журнал изменений с прежним и новым значением.

ВАЖНО. Путь ограничен по длине, чтобы файл открывался по сети с рабочего места. Русские буквы занимают в этом пределе вдвое больше латинских, поэтому длинные значения помещаются не всегда: наименование организации и в имени папки, и в имени файла предел исчерпывает. Когда места не хватает, система укорачивает имя самой глубокой папки - в предпросмотре это видно сразу, обрезанным окончанием. Одно и то же значение дважды в путь не ставят: организацию оставляют либо в папке, либо в имени файла. Справку по всем подкомандам печатает `make deploy-archive ARGS="help"`; на проверочном стенде та же операция называется `make staging-archive`.

Пример: увеличить срок заморозки до двух месяцев и поднять запас свободного места.

```
sudo make deploy-archive ARGS="set -freeze 60 -min-free 4G"
```

Ожидаемый результат: команда печатает сохранённые настройки и пример пути.

Уведомление о заполнении отправляется один раз на переход через порог, а не при каждой проверке. Когда место освободится и заполнение опустится ниже порога, отметка снимается, и следующее приближение снова вызовет уведомление.

ВАЖНО. При достижении жёсткого предела очередь выгрузки останавливается: строки переходят в состояние остановки и повторяются каждые пятнадцать минут, пока место не появится. Уже выложенные файлы не трогаются. Подача и обработка заявок не затрагиваются вовсе: архив не должен доедать место, нужное базе данных. Состояние видно в разделе администрирования.

Запись идёт фоновой очередью, отдельно от работы пользователя, поэтому файл появляется в каталоге не мгновенно, а в течение нескольких секунд после изменения заявки. Сорвавшаяся запись повторяется сама, а ночью система сверяет свой реестр с содержимым каталога и дописывает недостающее. Периодичность разбора очереди и повторов задают параметры `ARCHIVE_WORKER_TICK` и `ARCHIVE_SWEEP_INTERVAL`; менять их в обычной работе не требуется.

Файлы закрытой заявки через заданный срок замораживаются: они считаются окончательными и больше не переписываются, что бы ни правили в системе. Изначально это месяц с того дня, когда заявка перестала действовать; срок задаётся флагом `-freeze` той же команды.

Состояние архива смотрят в разделе администрирования «Файловый архив». Вкладка «Обзор» показывает занятое место, отдельно число заявок, бланков и машиночитаемых описаний, свободное место на разделе, момент последней записи, число ошибок записи и число вложений, оставшихся без бланка; ниже архив разложен по месяцам и по типам вложений. Вкладка «Лента» перечисляет записи целиком с отбором по состоянию и счётчиком очереди - по ней видно, что уже записано и что ещё ждёт разбора. Заявка в строке названа своим номером, вложение - наименованием типа, поэтому запись читается без обращения к базе. Оттуда же разбирают ошибки и запускают выгрузку задним числом за выбранный период - она понадобится после первого включения архива, чтобы выложить ранее поданные заявки, и после правки шаблона бланка, чтобы пересобрать печатные формы этого типа.

У каждого бланка есть состояние выгрузки. Оно видно и в ленте раздела администрирования, и рядом с вложением в карточке заявки, но подписи там короче - в таблице они приведены обе.

Первым столбцом идёт подпись в ленте, в скобках - подпись у вложения в карточке заявки, если она короче.

Таблица 9.9 — Состояния выгрузки бланка

Состояние	Что означает	Что делать
Ждёт очереди (в карточке «В очереди»)	Заявка поставлена в очередь, обработчик до неё ещё не дошёл	Ничего: файл появляется в течение нескольких секунд. Очередь, стоящая часами, - повод посмотреть журнал прикладного сервера
Записан (в карточке «В архиве»)	Файл записан, размер и контрольная сумма отвечают содержимому	Ничего
Ошибка выгрузки (в карточке «Ошибка»)	Запись сорвалась по временной причине: занятый файл, отказ диска, сбой формирования	Повторяется само с растущей паузой - от минуты до шести часов; срок следующей попытки подписан в строке ленты. Если состояние держится, разобрать причину: она записана там же
Нет шаблона	У типа вложения нет действующего Excel-бланка, формировать нечего	Приложить шаблон типу вложения и запустить выгрузку задним числом. Это пробел в архиве, а не решение администратора, поэтому он показывается отдельным счётчиком
Остановлено местом (в карточке «Нет места»)	Выгрузка остановлена нехваткой места на разделе или исчерпанной квотой	Освободить место либо поднять квоту. После этого очередь пойдёт дальше сама, повторять вручную не нужно
Вложение удалено	Вложения в системе больше нет, а файл в каталоге остался	Система такие файлы не удаляет: решение за человеком, с оглядкой на срок хранения документов
Пропущено	Выгрузка выключена целиком либо у этого типа вложения выключено автосохранение	Ничего, если так задумано. Выгрузка включается командой <code>sudo make deploy-archive ARGS="on"</code> , автосохранение типа - тумблером в карточке типа вложения

Оттуда же файлы забирают, не открывая каталог на сервере: за выбранный период всё выдаётся одним архивом. Объём одной такой выгрузки ограничен, по умолчанию двумя гигабайтами; перед запуском система показывает оценку и при превышении предлагает сузить период. Архив собирается на лету и отдаётся потоком, на диске сервера он не

накапливается, поэтому места под него не требуется. Скачивание закрыто отдельным правом, а каждое обращение записывается в журнал обращений к персональным данным. Файлы одной заявки забирают из её карточки: там бланк вложения скачивается по отдельности, а все сохранённые файлы заявки - одним архивом.

ВАЖНО. Не удаляйте и не правьте файлы каталога мимо системы. Система считает выложенным то, что записала сама, и после ручного вмешательства её перечень перестаёт отвечать содержимому каталога. Ночная сверка перепроверяет заявки за последние 30 суток (глубина задаётся командой `server archive set -recheck`) и записывает недостающие файлы заново; для более ранних заявок то же делает выгрузка задним числом за нужный период. Замороженные бланки не восстанавливает ни то, ни другое: их содержимое окончательно и повторно не формируется, поэтому удалённый замороженный файл возвращается только из резервной копии.

9.7. Доступ к архиву по сети

Смысл файлового архива в том, что бланк открывается без входа в систему, поэтому каталог отдают работникам бюро сетевой папкой. Средства файлового доступа в поставку не входят: общий ресурс поднимается штатными средствами операционной системы, а система о нём ничего не знает и работает с каталогом как с обычным путём на диске.

ОПАСНО. Ресурс открывается только на чтение. Система считает выложенным то, что записала сама: правка файла снаружи будет затёрта при следующей выгрузке этой заявки, а удаление рассогласует перечень с содержимым каталога, см. подраздел 9.6.

Читать содержимое может владелец каталога и его группа, поэтому доступ выдаётся включением учётной записи файлового доступа в группу владельца, а не смягчением прав на сами файлы. Права файлов система выставляет заново при каждой записи, и ослабленные вручную она вернёт к прежним. Права уже существующих каталогов система, наоборот, не трогает: каталог, открытый администратором под сетевой доступ, таким и останется.

ОПАСНО. В бланках и в машиночитаемых слепках заявок сведения документов записаны открытым текстом. Каталог архива - такое же хранилище персональных данных, как база: круг допущенных ограничивается наравне с доступом к самой системе, ресурс не выкладывается в общедоступные сетевые папки, а порт файлового доступа наружу не публикуется и ограничивается сетью организации. Перечень портов, открываемых системой, приведён в приложении А.

ВАЖНО. Обращения через сетевую папку система не видит и в журнал обращений к персональным данным не записывает - в нём учитывается только то, что выгружено через интерфейс. Если учёт таких обращений требуется, он ведётся средствами файлового доступа операционной системы.

9.8. Переименование базы данных

Если имя базы требуется изменить уже после запуска системы, порядок такой.

Листинг 9.5 — Переименование базы данных

```
sudo make deploy-down
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  up -d db
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec db psql -U postgres \
  -c 'ALTER DATABASE auto_registry RENAME TO buropropuskov;'
```

Затем измените в файле параметров DB_NAME и имя базы в конце строки DATABASE_URL, после чего запустите систему.

Листинг 9.6 — Запуск после переименования

```
sudo make deploy-up
```

Ожидаемый результат: система запускается, данные на месте. Операция мгновенная, данные не копируются.

ВАЖНО. Переименование выполняется при остановленном прикладном сервере. При активных подключениях база откажется переименовываться.

9.9. Очистка накопленных данных

Часть служебных записей система убирает сама, ежедневно и без участия человека: недействительные маркеры продления сеанса,

уведомления и подписки устройств на доставку вне системы, которым ни разу не удалось доставить. Сроки задаются параметрами `REFRESH_TOKEN_RETENTION_DAYS`, `READ_NOTIFICATION_RETENTION_DAYS` и `NOTIFICATION_RETENTION_DAYS`. У первых двух по умолчанию 30 суток, у последнего 90: непрочитанное уведомление человек ещё может открыть, поэтому оно живёт дольше прочитанного. Менять сроки обычно не требуется: уборка касается записей, которыми уже нельзя воспользоваться.

ВАЖНО. Эти параметры не входят в набор, передаваемый через файл параметров. Чтобы изменить срок, добавьте их в раздел `environment` службы `backend` и перезапустите систему, как описано в подразделе 6.1. Значение, прописанное только в `.env`, не действует.

Всё остальное удаляется только по команде. Разделения на автоматическое и ручное здесь два основания: сама по себе история ценна, а удаление необратимо, и вернуть удалённое можно лишь из резервной копии.

Таблица 9.10 — Группы данных, доступные команде очистки

Группа	Что удаляется	Срок по умолчанию
<code>tokens</code>	Недействительные маркеры продления сеанса	30 суток
<code>notifications</code>	Прочитанные уведомления	30 суток
<code>audit</code>	История действий над сущностями	36 месяцев
<code>snapshots</code>	Суточные слепки таблиц постов	12 месяцев
<code>request-aggregates</code>	Суточные итоги журнала запросов	24 месяца

Команда без указания групп берёт две первые. Значение `all` берёт все пять. Срок задаётся видом `30d` для суток и `12m` для месяцев и заменяет значение по умолчанию для всех выбранных групп.

Ключ `-except` вычитает группы из выбранных. Он избавляет от перечисления: чтобы почистить всё, кроме истории действий, достаточно `-targets=all -except=audit`.

Выборку внутри группы сужают три ключа.

Таблица 9.11 — Ключи сужения выборки

Ключ	Что задаёт	Где применим
-from	Начало периода в виде 2023-01-01. Вместе со сроком хранения задаёт отрезок: всё, что старше начала, остаётся нетронутым	Во всех группах
-entity	Тип сущности: car, employee, application и другие	Только в группе audit
-table	Номер таблицы поста	Только в группе snapshots

Ключ, неприменимый к выбранной группе, команда отклоняет и объясняет почему. Это сделано намеренно: если бы такой ключ молча игнорировался, оператор просил бы сузить удаление, а получил бы удаление всей группы. По той же причине проверяется написание типа сущности, а при ошибке выводится перечень допустимых значений.

Без явного разрешения на удаление команда ничего не трогает и только показывает, сколько записей попало бы под условие. Это основной режим: сначала смотрят числа.

Разрешением служит ключ -apply, и с ним на рабочем сервере команда спрашивает подтверждение - слово УДАЛИТЬ, порядок в подразделе 9.1. Предварительный показ подтверждения не спрашивает: удалять ему нечего, а вопрос на безопасном вызове приучал бы отвечать не глядя. На проверочном стенде make staging-cleanup не спрашивает ничего и в режиме применения.

В отчёте по каждой группе видно, сколько в ней всего записей, сколько места она занимает и сколько освободит удаление. Оценка освобождаемого объёма приблизительная: записи внутри одной группы разного размера.

Листинг 9.7 — Что будет удалено

```
sudo make deploy-cleanup ARGS="-targets=all"
```

Ожидаемый результат: таблица с числом записей по каждой группе и напоминание, что ничего не удалено.

Листинг 9.8 — Удаление истории старше трёх лет

```
sudo make deploy-cleanup ARGS="-targets=audit -older-than=36m -apply"
```

Ожидаемый результат: та же таблица и строка с числом удалённых записей.

Листинг 9.9 — Очистка всего, кроме истории действий

```
sudo make deploy-cleanup ARGS="-targets=all -except=audit -apply"
```

Ожидаемый результат: в таблице четыре группы вместо пяти, история не затронута.

Листинг 9.10 — История только по транспорту, за отрезок времени

```
sudo make deploy-cleanup ARGS="-targets=audit -entity=car -from=2023-01-01 -older-than=24m"
```

Ожидаемый результат: под удаление попадают записи о машинах за отрезок от начала 2023 года до границы срока. История людей и заявок не затрагивается, записи старше начала отрезка остаются.

Листинг 9.11 — Слпки одного поста

```
sudo make deploy-cleanup ARGS="-targets=snapshots -table=3 -apply"
```

Ожидаемый результат: удаляются суточные слпки только указанного поста. Номер поста виден в адресной строке при открытии его таблицы.

Справка по всем ключам выводится командой `make deploy-cleanup ARGS="-help"`. На проверочном стенде та же операция называется `make staging-cleanup`.

ВАЖНО. Удаление строк не возвращает место операционной системе. Освободившийся объём остаётся в файлах базы и используется под новые записи, поэтому после очистки размер каталога с данными сразу не уменьшится. Это нормально: место не потеряно, оно просто отдано базе, а не диску.

ВАЖНО. Удаление необратимо. Выполняйте его после создания резервной копии, иначе при ошибке в сроке восстанавливать будет нечего.

ПРИМЕЧАНИЕ. Историю сущностей команда чистит с оговорками. Записи об удалении строк таблиц постов сохраняются независимо от срока: по ним работает корзина. Последние отметки въезда и выезда каждой машины и каждого человека тоже сохраняются: из них берётся время последнего выезда в карточке, и у редко приезжающей машины такая отметка бывает старше любого разумного срока хранения.

ПРИМЕЧАНИЕ. Слепки таблиц, снятые вручную кнопкой в интерфейсе, команда не удаляет никогда. Под срок попадают только суточные, снимаемые системой перед сбросом статусов.

10. Порядок внесения изменений в систему

Раздел описывает полный путь изменения: от получения исходного кода до его появления на рабочем сервере.

10.1. Общая схема

Таблица 10.1 — Этапы внесения изменения

Этап	Где выполняется	Результат
1. Получение исходного кода	Рабочее место разработчика	Локальная копия проекта
2. Внесение правки	Рабочее место разработчика	Изменённый код в отдельной ветке
3. Автоматическая проверка	Конвейер сборки	Отчёт о прохождении проверок
4. Проверка на стенде	Проверочный стенд	Подтверждение работы вживую
5. Выкладывание на рабочий сервер	Рабочий сервер	Изменение доступно пользователям

10.2. Получение исходного кода и внесение правки

Исходный код хранится в системе контроля версий Git, в репозитории `git@github.com:buropropuskov/systemburo.git`. Порядок выдачи доступа описан в подразделе 4.1; на рабочем месте разработчика он выдаётся на его личную учётную запись, а не ключом развёртывания сервера. Работа ведётся в отдельной ветке, а не в основной: это позволяет проверить изменение до того, как оно попадёт к другим.

Листинг 10.1 — Получение кода и создание ветки

```
git clone git@github.com:buropropuskov/systemburo.git systemburo
cd systemburo
git checkout -b fix/kratkoe-opisanie
```

Локальный запуск для разработки поднимает систему с отдельной базой и не затрагивает ни стенд, ни рабочий сервер.

Листинг 10.2 — Локальный запуск для разработки

```
make up
make seed
```

Ожидаемый результат: интерфейс доступен на порту 8081, программный интерфейс на 8080, вход под учётной записью, созданной командой заполнения.

10.3. Проверка изменения до выкладывания

Перед отправкой изменения прогоняются тесты. Локально достаточно прогнать те, что относятся к изменённой части.

Листинг 10.3 — Прогон проверок

```
make test # бэкенд-тесты
cd frontend && npm run test:run # фронтенд-тесты
cd frontend && npx playwright test # E2E-сценарии
```

Ожидаемый результат: все тесты завершаются успешно. Упавший тест выводит своё имя и расхождение ожидаемого с фактическим.

После отправки изменения конвейер запускает полный набор тестов автоматически, включая сборку образов и сканирование уязвимостей. Изменение, не прошедшее тесты, к выкладыванию не допускается.

10.4. Проверка на стенде

После прохождения тестов и включения изменения в основную ветку оно автоматически выкладывается на проверочный стенд.

На стенде проверяются сценарии, которые автоматика не покрывает: внешний вид, удобство, поведение на реальных данных.

Таблица 10.2 — Проверяемые на стенде сценарии

Сценарий	Что подтверждает
Вход администратора и рядового работника	Проверку подлинности и выдачу прав
Подача заявки со всеми типами вложений	Основной рабочий процесс
Приём в работу, согласование, завершение	Переходы состояний и запись решений
Открытие таблицы поста, отметка въезда и выезда	Работу постов
Формирование печатной формы по заявке	Работу шаблонов бланков
Выгрузка отчёта	Формирование электронных таблиц
Открытие панели показателей	Расчёт аналитики

10.5. Выкладывание на рабочий сервер

ОПАСНО. Перед выкладыванием создайте резервную копию базы данных. Это единственный способ вернуться назад гарантированно, см. подраздел 10.7.

Порядок действий на рабочем сервере.

1. Предупредить пользователей, при длительном обновлении включить режим технических работ (подраздел 9.5).
2. Получить новую версию исходного кода в каталог системы.

Листинг 10.4 — Обновление исходного кода на рабочем сервере

```
cd /opt/systemburo
git fetch origin
git checkout <версия>
```

1. Пересобрать образы и перезапустить систему.

Листинг 10.5 — Пересборка и перезапуск

```
sudo make deploy-build
sudo make deploy-up
```

1. Проследить за журналом запуска.

Листинг 10.6 — Наблюдение за запуском после обновления

```
sudo make deploy-logs
```

Ожидаемый результат: в журнале нет сообщений уровня `error`. Схема базы приводится в соответствие автоматически именно на этом шаге, и здесь же проявятся несовместимости, если они есть.

1. Выполнить проверки из подраздела 5.9.

2. Снять режим технических работ.

Пользователи не смогут работать с момента перезапуска до успешного старта, обычно это одна-две минуты.

Обновление на площадке без доступа к репозиторию. Если система развёрнута из архива, второй шаг выполняется иначе: команды `git` в таком каталоге не работают, потому что рабочей копии репозитория там нет. Новая версия передаётся архивом и распаковывается поверх прежнего каталога, после чего порядок продолжается с третьего шага без изменений.

Листинг 10.7 — Обновление кода из архива

```
cd /opt/systemburo
tar -xzf systemburo-<новая версия>.tar.gz --strip-components=1
```

ВАЖНО. Распаковка поверх заменяет файлы кода, но не удаляет лишние. Файл параметров `.env`, каталог сертификатов `nginx/certs` и каталог `nginx/асме-webroot` в архиве отсутствуют и остаются нетронутыми - именно поэтому распаковывают поверх, а не в очищенный каталог. Обратная сторона в том, что файлы, удалённые в новой версии, остаются на диске. Если есть основания думать, что это мешает, сохраните `.env` и `nginx/certs` в стороне, разверните новую версию в пустой каталог и верните их на место.

10.6. Изменения схемы базы данных

Схема приводится в соответствие автоматически при каждом запуске прикладного сервера, отдельной команды не требуется. Практические следствия:

- изменения применяются в момент запуска, и если они объёмны, запуск затянется;
- изменения носят добавляющий характер: создаются таблицы, столбцы и индексы, удаления не выполняются;
- при ошибке приведения схемы прикладной сервер завершает работу и не запускается в частично обновлённом состоянии.

10.7. Возврат к предыдущей версии

Возврат кода выполняется получением прежней версии и повторной сборкой. Прежнюю версию находят по журналу изменений рабочей копии: он лежит в самом каталоге системы, поэтому перечень доступен и при недоступном репозитории.

Листинг 10.8 — Перечень последних версий

```
cd /opt/systemburo  
git log --oneline -10
```

Ожидаемый результат: десять последних изменений, у каждого свой определитель в начале строки. Его и подставляют в команду возврата.

Листинг 10.9 — Возврат к предыдущей версии кода

```
cd /opt/systemburo  
git checkout <предыдущая версия>  
sudo make deploy-build  
sudo make deploy-up
```

ВАЖНО. На площадке без доступа к репозиторию возврата этими командами нет: рабочей копии в каталоге не существует, а вместе с ней и перечня прежних версий. Возврат там выполняется распаковкой прежнего архива поверх каталога, как описано в подразделе 10.5. Поэтому предыдущий архив поставки хранят до тех пор, пока новая версия не отработает без замечаний.

ВАЖНО. Приведение схемы базы выполняется только вперёд. Изменения схемы, внесённые новой версией, при откате кода не отменяются. Поскольку они носят добавляющий характер, прежняя версия обычно продолжает работать. Но если обновление изменило смысл существующих данных, потребуется восстановление базы из копии, созданной до обновления.

11. Резервное копирование и восстановление

11.1. Устройство

Копирование выполняется средствами системы: набор команд в составе поставки снимает копию, раскладывает её по срокам хранения, удаляет устаревшие и проверяет, что копия пригодна для восстановления. Запускается по расписанию, участия человека не требует.

Резервное копирование, предоставляемое как услуга хостинга, работает на уровне образа сервера целиком. Оно позволяет вернуть сервер в прежнее состояние, но не заменяет копию базы: из образа нельзя извлечь отдельную таблицу, отменить последствия ошибочной операции или перенести данные на другой сервер. Одно другому не мешает: образ защищает от отказа сервера, копия базы - от ошибки в данных.

11.2. Что входит в копию

Копирования одной базы данных недостаточно.

Таблица 11.1 — Состав данных для резервного копирования

Элемент	Где расположен	В копии	Последствия утраты
База данных	Том pgdata	Ежедневно	Полная утрата заявок, реестров, журналов, учётных записей
Загруженные файлы	Том uploads	По расписанию файлов	Утрата фотографий, шаблонов бланков, приложений к заявкам. Записи в базе останутся со ссылками на отсутствующие файлы
Файловый архив бланков	Каталог ARCHIVE_HOST_PATH	По расписанию файлов	Утрата сформированных бланков, доступных снаружи системы
Файл параметров	.env в каталоге системы	Не входит	Утрата ключа шифрования персональных данных
Сертификат удостоверяющего центра	nginx/certs/	Не входит	Потребуется повторный выпуск и повторная установка корневого сертификата на все рабочие места

База выгружается каждый раз, а файлы - раз в неделю: полный архив файлов, снимаемый ежедневно, умножается на число хранимых копий и

занимает место несоразмерно своей ценности. Если объём файлов невелик, режим переключается параметром `BACKUP_UPLOADS_MODE` в значение `daily`.

Сначала выгружается база, затем архивируются файлы. Порядок существенен: при обратном файл, загруженный между двумя шагами, попал бы в базу, но не в архив, и после восстановления заявка ссылалась бы на отсутствующий файл.

ОПАСНО. Файл параметров в копию не входит намеренно. В нём ключ шифрования персональных данных, и хранение его вместе с копией базы означает, что кража архива равносильна краже персональных данных в открытом виде. Скопируйте `.env` отдельно, в хранилище секретов организации, и обновляйте эту копию при каждом изменении параметров, соблюдая правило хранения секретов из подраздела 5.4. Без ключа восстановленная база не отдаст ни одного паспорта.

11.3. Сроки хранения

Таблица 11.2 — Сроки хранения копий

Каталог	Что попадает	Сколько хранится
<code>daily</code>	Каждая копия	7 последних
<code>weekly</code>	Копия за воскресенье	4 последних
<code>monthly</code>	Копия за первое число	6 последних

Одна и та же копия попадает в несколько каталогов и занимает место один раз: используется жёсткая ссылка, а не второй экземпляр файла. Числа задаются параметрами `BACKUP_KEEP_DAILY`, `BACKUP_KEEP_WEEKLY`, `BACKUP_KEEP_MONTHLY`.

11.4. Настройка

Настройка выполняется один раз, на самом сервере системы. Все команды подраздела вводятся в каталоге `/opt/systemburo`. Установка расписания ставит службы и таймеры в систему, поэтому требует полных прав суперпользователя: разрешение на две команды, выданное в подразделе 5.1, её не покрывает. На проверочном стенде порядок тот же, отличаются только имена команд: вместо `deploy-backup` вводится `staging-backup`.

Шаг 1. Создайте пару ключей шифрования. Открытая часть остаётся на сервере и шифрует копии, закрытая нужна только для восстановления и на сервере не хранится.

Шаг обязателен. Пока открытый ключ не записан в параметр `BACKUP_AGE_RECIPIENT`, копирование отказывается работать: оно останавливается до первого обращения к базе, копию не создаёт вовсе и печатает, чего ему не хватает. Проверка стоит именно в начале, чтобы незашифрованной выгрузки не появилось даже на минуту.

ОПАСНО. В выгрузке базы и в архиве бланков фамилии, сведения документов, удостоверяющих личность, и номера патентов. Без шифрования кража архива копий равносильна краже самой базы, причём незаметной: копии никто не открывает, пока не понадобится восстановление. Поэтому отсутствие ключа останавливает копирование, а не отмечается предупреждением, которое читают уже при разборе аварии.

Листинг 11.1 — Создание ключей шифрования копий

```
age-keygen -o buro-backup.key
```

Ожидаемый результат: выведена строка вида `Public key: age1...`, создан файл `buro-backup.key`.

Если средство `age` на сервере не установлено, ставить его не требуется: та же пара ключей создаётся одноразовым контейнером.

Листинг 11.2 — Создание ключей без установки средства

```
sudo docker run --rm alpine:3.20 sh -c \
  'apk add --no-cache -q age && age-keygen' > buro-backup.key
grep 'public key' buro-backup.key
```

Ожидаемый результат: в файле две строки - открытый ключ в комментарии и закрытый ключ. Открытый ключ выводится второй командой.

ПРИМЕЧАНИЕ. Сами копии тоже шифруются без установки `age` на сервер - скрипт запускает его в одноразовом контейнере. Установка средства в систему лишь ускоряет работу и убирает зависимость от доступа к реестру образов.

Файл `buro-backup.key` содержит обе части пары. Строка `# public key: age1...` - открытый ключ, он же выводится на экран при создании;

строка AGE-SECRET-KEY-1... - закрытый. Открытый шифрует копии и остаётся на сервере в параметре BACKUP_AGE_RECIPIENT, закрытый нужен только для восстановления.

ОПАСНО. Закрытый ключ хранится вне сервера. Скопируйте buro-backup.key на рабочее место, положите в хранилище секретов организации и удалите файл с сервера. Если он останется рядом с копиями, шифрование теряет смысл: тот, кто получит доступ к серверу, получит и архивы, и ключ к ним. Без закрытого ключа копии не восстановить - утратив его, вы утратите и все копии. Держите не менее двух копий ключа в разных местах, как требует правило хранения секретов из подраздела 5.4.

Листинг 11.3 — Перенос закрытого ключа на рабочее место

```
scp <пользователь>@<адрес сервера>:/opt/systemburo/buro-backup.key .
grep AGE-SECRET-KEY buro-backup.key
```

Обе команды выполняются на рабочем месте, не на сервере. Ожидаемый результат: файл скачан, вторая команда выводит строку закрытого ключа. После этого удалите файл на сервере командой `rm /opt/systemburo/buro-backup.key`.

ВАЖНО. Удаляйте ключ с сервера после того, как проверите восстановимость копии по подразделу 11.5 - проверке он нужен.

Если от шифрования отказываются осознанно. Такой отказ возможен, но требует явного разрешения: параметр BACKUP_ALLOW_UNENCRYPTED в значении yes, единственном, которое принимается. Тогда копия создаётся незашифрованной, и видно это сразу в трёх местах: в выводе команды копирования, в журнале строкой «копия НЕ шифруется по явному разрешению BACKUP_ALLOW_UNENCRYPTED=yes и содержит персональные данные в открытом виде» и в поле encrypted файла состояния, откуда его берёт команда состояния (подраздел 11.5).

Разрешение уместно там, где за сохранность копий отвечает само хранилище: зашифрованный носитель, изолированный сервер копий с ограниченным кругом допущенных. Там, где копии уезжают во внешнее

хранилище или лежат на обычном диске рядом с системой, его применять не следует.

Шаг 2. Впишите открытую часть в файл параметров /opt/systemburo/.env. Строка BACKUP_AGE_RECIPIENT= в файле уже есть, оставленная пустой сценарием подготовки параметров: значение подставляется в неё, а не дописывается второй строкой в конец файла.

Листинг 11.4 — Запись открытого ключа в параметры

```
cd /opt/systemburo
grep -n '^BACKUP_' .env
```

Ожидаемый результат: перечень строк резервного копирования с номерами; BACKUP_AGE_RECIPIENT среди них пуста. Откройте файл любым редактором и подставьте в неё значение, полученное на шаге 1, - строку вида age1... целиком.

Листинг 11.5 — Проверка записанного ключа

```
grep -c '^BACKUP_AGE_RECIPIENT=' .env
grep '^BACKUP_AGE_RECIPIENT=' .env
```

Ожидаемый результат: первая команда выводит 1, вторая - строку с вашим ключом. Если первая вывела 2, значение дописали второй строкой: лишнюю удалите. Копирование при двух строках отработает, потому что берёт последнюю, но при следующей правке легко исправить не ту, и копии будут шифроваться ключом, который считали заменённым.

ВАЖНО. Без этого параметра копирование не выполняется вовсе - скрипт останавливается до первого обращения к базе, чтобы незашифрованная выгрузка с персональными данными не появилась на диске. Если копии сознательно снимаются открытыми, это разрешается отдельным параметром BACKUP_ALLOW_UNENCRYPTED=yes, и тогда каждое копирование пишет об этом предупреждение в журнал.

Шаг 3. Поставьте копирование на расписание.

Листинг 11.6 — Постановка на расписание

```
cd /opt/systemburo
sudo ./scripts/backup-install.sh production
```

Для проверочного стенда контур указывается явно: `sudo ./scripts/backup-install.sh staging`.

Ожидаемый результат: сообщение об установке двух таймеров - ежедневного копирования в 03:30 и ежемесячной проверки восстановимости. Время задаётся вторым аргументом, например `sudo ./scripts/backup-install.sh production 04:15`.

Доступ оператора к состоянию копирования. Копии закрыты наглухо: в выгрузке базы персональные данные, и открывать их вправе только суперпользователь. Но следить за тем, что копирование идёт, приходится ежедневно (подраздел 9.2), и делать это из-под полных прав необязательно. Поэтому каталогу копий выставляется право прохода для группы, названной параметром `BACKUP_OPERATOR_GROUP`: вместо 700 у него становится 710. Члену этой группы открываются ровно два файла - отчёт о последнем запуске `status.json` и журнал `backup.log`, оба на чтение. Перечислить содержимое каталога, войти в подкаталоги сроков хранения и открыть саму копию он по-прежнему не может: подкаталоги остаются с правами 700, файлы копий - с правами 600 у суперпользователя.

По умолчанию параметр указывает на группу `buo`, которая заводится вместе с учётной записью сопровождения в подразделе 5.1. Сценарий подготовки параметров эту строку в файл не пишет, и её отсутствие означает как раз умолчание. Чтобы от такого доступа отказаться, строку добавляют пустой: `BACKUP_OPERATOR_GROUP=` без значения - осознанный отказ, и тогда каталог остаётся закрытым целиком.

Права выставляет и установщик расписания, и каждое копирование, поэтому заведённая позже группа подхватывается сама, повторно ставить расписание не нужно. Как настроен доступ, установщик сообщает строкой оператор: в конце вывода.

Таблица 11.3 — Строка «оператор» в выводе установщика расписания

Строка	Что означает
состояние копирования открыто группе <имя>, сами копии ей недоступны	Группа найдена, право прохода выставлено. Ниже установщик печатает две команды, которыми состояние читается без sudo
группы <имя> на сервере нет, состояние копирования увидит только суперпользователь	Такой группы на сервере не заведено. Каталог остался закрытым целиком; ошибкой это не считается, копирование работает как прежде
доступ отключён параметром BACKUP_OPERATOR_GROUP	Параметр задан пустым, то есть от доступа отказались осознанно

Шаг 4. Проверьте, что копия снимается.

Листинг 11.7 — Проверка копирования вручную

```
sudo make deploy-backup
sudo make deploy-backup-status
```

Ожидаемый результат: копирование завершается сообщением об успехе, состояние показывает свежую копию и её объём.

Метка копии. Перед работами, после которых может понадобится откат, копию удобно пометить: метка попадает в имя файла и избавляет от поиска нужной копии по времени.

Листинг 11.8 — Копия с меткой

```
sudo make deploy-backup ARGS=pered-obnovleniem
```

Ожидаемый результат: файл вида buro-db-2026-08-01-1612-pered-obnovleniem.dump.age. В метке допустимы латинские буквы, цифры, дефис и подчёркивание: имя файла попадает в команды восстановления и во внешнее хранилище, где пробелы и кириллица создают трудности.

ВАЖНО. Пока внешнее хранилище не настроено, копии лежат на том же сервере, и отказ его диска уничтожит их вместе с системой. Скрипт предупреждает об этом при каждом запуске. Настройка выгрузки - подраздел 11.6.

11.5. Проверка и наблюдение

Копия, из которой ни разу не восстанавливались, резервной копией не является: повреждение обнаружится тогда, когда она окажется единственной надеждой. Поэтому раз в месяц система сама разворачивает последнюю

копию во временную базу рядом с рабочей, сверяет наполнение ключевых таблиц и удаляет временную базу. Рабочая база при этом не затрагивается.

Листинг 11.9 — Проверка восстановимости вручную

```
AGE_IDENTITY=/путь/к/buro-backup.key make deploy-backup-verify
```

Ожидаемый результат: строка «копия пригодна для восстановления» и числа восстановленных учётных записей, заявок и таблиц постов.

ВАЖНО. Путь к закрытому ключу передаётся переменной окружения, а `sudo` окружение очищает. Запись `AGE_IDENTITY=... sudo make deploy-backup-verify` до сценария не дойдёт, а задать переменную после `sudo` разрешение на две команды не позволяет. Проверку зашифрованной копии выполняет с полными правами суперпользователя тот же, кто ставил расписание. Незашифрованной копии ключ не нужен, и для неё достаточно `sudo make deploy-backup-verify`.

Все команды раздела выполняются на сервере системы, в каталоге `/opt/systemburo`, с `sudo`: доступ к Docker выдан через него, подраздел 5.1. Исключение одно - чтение состояния копирования без полных прав, о нём сказано ниже.

Таблица 11.4 — Где смотреть состояние

Что нужно узнать	Где смотреть
Свежесть, объём и состав копий	<code>sudo make deploy-backup-status</code>
Что делал скрипт и на чём остановился	файл <code>/var/backups/systemburo/backup.log</code>
Итог последнего запуска в машинном виде	файл <code>/var/backups/systemburo/status.json</code>
Как отработал запуск по расписанию	<code>journalctl -u systemburo-backup -n 50</code>
Когда будут ближайшие запуски	<code>systemctl list-timers 'systemburo-*</code>
Сами файлы копий	каталоги <code>/var/backups/systemburo/daily</code> , <code>weekly</code> , <code>monthly</code>

Пути даны для значения `BACKUP_DIR` по умолчанию. Если параметр изменён, каталог другой, а команда состояния всё равно покажет верный путь первой строкой.

Посмотреть можно и хранилище, к системе не относящееся: копии, принесённые с другого сервера, или примонтированный внешний диск. Каталог передаётся перед командой и на файл параметров не влияет.

Листинг 11.10 — Состояние копий в стороннем каталоге

```
BACKUP_DIR=/mnt/disk/systemburo bash scripts/backup-status.sh production
```

Ожидаемый результат: тот же вывод, но по указанному каталогу; первая строка называет его, чтобы не спутать с рабочим.

Что видно оператору. Ежедневный контроль свежести копии не требует полных прав, и команда состояния работает без `sudo` - показывает она при этом меньше. Каталог копий, настройку внешнего хранилища и шифрования, время и итог последнего запуска член группы оператора видит целиком, вместе с предупреждениями о незашифрованной копии и о копии старше двух суток. Дальше вместо перечня копий печатаются три строки.

Листинг 11.11 — Чем вывод оператора отличается от полного

```
Перечень копий доступен только суперпользователю: сами копии закрыты, оператору видны состояние и журнал.
Полный перечень:  sudo ./scripts/backup-status.sh production
Журнал:           /var/backups/systemburo/backup.log
```

Те же сведения читаются и напрямую, двумя командами - их печатает установщик расписания сразу после установки, подставляя действующий каталог копий.

Листинг 11.12 — Состояние копирования без полных прав

```
cat /var/backups/systemburo/status.json
tail /var/backups/systemburo/backup.log
```

Ожидаемый результат: первая команда выводит отчёт о последнем запуске - время окончания, итог, метку времени копии, объём, признак шифрования и причину сбоя, если он был. Вторая показывает конец журнала: по нему видно, до какого шага дошло последнее копирование.

Разница между командой и этими двумя в том, что команда состояния читает ещё и файл параметров `/opt/systemburo/.env`, закрытый от посторонних правами 600. Учётной записи сопровождения он принадлежит, поэтому команда ей доступна и без `sudo`; отдельной учётной записи, которую

лишь включили в группу оператора, остаются две команды выше - они обращаются прямо к файлам и параметров не касаются.

Если каталог копий для учётной записи закрыт - группа не задана, не заведена или запись в неё не входит, - команда состояния говорит об этом прямо, вместо того чтобы промолчать.

Листинг 11.13 — Каталог копий закрыт для этой учётной записи

```
Каталог копий /var/backups/systemburo закрыт для учётной записи buro.
Состояние копирования читает суперпользователь: sudo ./scripts/backup-status.sh production
Оператору доступ выдаётся группой BACKUP_OPERATOR_GROUP, её выставляет scripts/backup-install.sh.
```

Различать здесь есть что: закрытый каталог и каталог, которого нет вовсе, дают разные сообщения намеренно. Сведения о самом каталоге читаются по правам родительского, поэтому закрытый выглядел бы как «копирование ни разу не выполнялось» - то есть команда врала бы ровно в том случае, ради которого её и открывают оператору.

ВАЖНО. Копия старше двух суток означает, что запуск не состоялся. Команда состояния сообщает об этом строкой «свежей копии нет более двух суток». Разбираться следует сразу: пока копирование не работает, система живёт без страховки.

Про шифрование команда состояния говорит дважды, и это разные утверждения. Строка «Шифрование» в шапке описывает настройку на сейчас, а предупреждение под итогом последнего запуска - то, что фактически лежит на диске: ключ могли задать уже после снятия последней копии, и тогда шапка покажет «включено», а последняя копия останется незашифрованной.

Таблица 11.5 — Строки о шифровании в команде состояния

Строка	Что означает
Шифрование: включено	Ключ задан, новые копии шифруются
Шифрование: ВЫКЛЮЧЕНО по явному разрешению, копии содержат персональные данные в открытом виде	Задано BACKUP_ALLOW_UNENCRYPTED=yes. Копии снимаются, но открытыми
Шифрование: ключ не задан - копирование останавливается с ошибкой, пока не задан BACKUP_AGE_RECIPIENT	Ни ключа, ни разрешения. Копий не будет вовсе, пока это не исправлено

Строка	Что означает
ВНИМАНИЕ: последняя копия снята БЕЗ шифрования	Читается из файла состояния и относится к последней снятой копии, а не к настройке. У копий, снятых прежними версиями сценария, признака нет, и строка не печатается

Кроме свежести команда показывает состав каждой копии: вошли ли в неё загруженные файлы и файловый архив бланков. Копия без них выглядит в перечне так же благополучно, как полная, и разница обнаруживается в момент восстановления, поэтому состав вынесен отдельной колонкой, а сами архивы печатаются строками под своей выгрузкой базы. Подробно перечень разобран в подразделе 11.7.

При недельном режиме архивации состав «только база» у копий за остальные дни ожидаем - файлы снимаются по воскресеньям и первого числа. В ежедневном режиме такая копия означает, что архивация файлов не отработала, и команда пишет об этом отдельной строкой.

Таблица 11.6 — Сообщения о полноте копии

Сообщение команды состояния	Что означает
Файлы архивируются раз в неделю	Пояснение к составу только база: заданный режим, а не сбой
ВНИМАНИЕ: режим BACKUP_UPLOADS_MODE=daily, но в последнюю копию файлы не вошли	Архивация файлов не отработала при ежедневном режиме. Причина - в журнале копирования, порядок разбора ниже

Как выяснить причину, если копия не снялась. Скрипт не падает молча: он записывает причину в журнал строкой со словом ОШИБКА и дублирует её в файл состояния. Отказ выполнять копирование записывается так же, но словом ОТКАЗ: это не сбой, а сознательная остановка до начала работы. Порядок разбора - три шага.

Шаг 1. Посмотрите итог последнего запуска.

Листинг 11.14 — Итог последнего запуска

```
cd /opt/systemburo
sudo make deploy-backup-status
```

Ожидаемый результат при сбое: строка «Итог: СБОЙ» и текст причины.

Шаг 2. Откройте журнал: в нём видно, до какого шага скрипт дошёл.*Листинг 11.15 — Последние записи журнала копирования*

```
tail -30 /var/backups/systemburo/backup.log
```

Шаг 3. Найдите причину в таблице ниже. Тексты в ней - те же, что выводит скрипт.

Таблица 11.7 — Причины сбоя копирования

Сообщение в журнале	Что произошло	Что делать
не задан BACKUP_AGE_RECIPIENT: копия содержала бы персональные данные в открытом виде	Копирование отказалось выполняться: ключ шифрования копий не задан. Копия не создавалась, старые не тронуты	Завести ключ по шагу 1 подраздела 11.4. Если копии сознательно снимаются без шифрования, задать BACKUP_ALLOW_UNENCRYPTED=yes
не удалось выгрузить базу	Служба базы данных не отвечает	Проверить состояние служб, подраздел 13.1
выгрузка базы не читается: повреждена или пуста	Выгрузка получилась битой, на диске могло кончиться место	Проверить свободное место <code>df -h</code> , повторить копирование
не удалось зашифровать выгрузку базы	Средство шифрования недоступно: нет age и не скачивается образ	Проверить доступ в сеть с сервера либо установить age в систему
не удалось разложить копию по каталогам	Нет прав на каталог копий либо он на другом разделе	Проверить владельца и права <code>ls -ld /var/backups/systemburo</code>
не удалось выполнить ротацию	Нет прав на удаление старых копий	Проверить права на подкаталоги daily, weekly, monthly
не удалось заархивировать загруженные файлы	Не прочитался том или каталог загруженных файлов	Проверить <code>sudo docker volume ls</code> и права на каталог; копия базы при этом снята
не удалось зашифровать архив файлов	Средство шифрования недоступно на шаге файлов	Так же, как при сбое шифрования выгрузки базы
не удалось заархивировать файловый архив бланков	Не прочитался каталог архива бланков	Проверить наличие и права каталога, заданного ARCHIVE_HOST_PATH
не удалось зашифровать файловый архив	Средство шифрования недоступно на шаге архива бланков	Так же, как при сбое шифрования выгрузки базы

Сообщение в журнале	Что произошло	Что делать
не удалось выгрузить копии во внешнее хранилище	Хранилище недоступно или неверны реквизиты	Проверить настройку rclone; копии на сервере при этом сняты
не задан BACKUP_AGE_RECIPIENT: копия содержала бы персональные данные в открытом виде	Копирование остановлено до обращения к базе: ключ шифрования не задан, а незашифрованные копии не разрешены	Задать ключ по подразделу 11.4 либо, если копии сознательно снимаются без шифрования, разрешить это параметром BACKUP_ALLOW_UNENCRYPTED=yes
прервано на строке	Непредусмотренный сбой	Прислать разработчику журнал и вывод journalctl -u systemburo-backup -n 100

Отдельно от сбоев скрипт пишет предупреждения - они не прерывают копирование, но означают, что защита неполная.

Таблица 11.8 — Предупреждения в журнале

Сообщение	Что означает
копия НЕ шифруется по явному разрешению BACKUP_ALLOW_UNENCRYPTED=yes и содержит персональные данные в открытом виде	Шифрование отключено осознанно: копии лежат открытыми, и доступ к каталогу копий равнозначен доступу к персональным данным
ни тома, ни каталога загруженных файлов не найдено	Загруженные файлы в копию не вошли: тома нет или его имя изменено. База при этом скопирована
внешнее хранилище не настроено	Копии лежат только на этом сервере и погибли вместе с его диском
каталог копий не открыт группе <имя> (проверьте, что такая группа заведена)	Группа оператора из BACKUP_OPERATOR_GROUP на сервере не заведена. Копии снимаются как обычно, но состояние копирования увидит только суперпользователь
не удалось открыть <файл> на чтение группе <имя>	Отчёт или журнал не удалось открыть группе оператора, хотя каталог ей открыт. Копирование при этом выполнено; читать состояние до выяснения причины придётся с полными правами

Проверка восстановимости останавливается со своим сообщением - оно печатается в вывод команды.

Таблица 11.9 — Сообщения проверки восстановимости

Сообщение	Что произошло	Что делать
копий для проверки не найдено	В суточном каталоге нет ни одной копии	Разобраться, почему не снимается копия, - порядок выше

Сообщение	Что произошло	Что делать
копия зашифрована, но AGE_IDENTITY не задан	Проверке не передан закрытый ключ, которым копия расшифровывается	Передать путь к ключу перед командой проверки, как показано выше
в копии нет ни одной учётной записи	Копия развернулась, но пуста: выгрузка снималась с пустой или чужой базы	Проверить имя базы в файле параметров и повторить копирование
Сообщение самой базы об ошибке разбора файла	Копия повреждена или дописана не до конца: обрыв при снятии, сбой диска, неполная передача во внешнее хранилище	Проверить предыдущую копию той же командой. Прошла - неисправна только последняя, снять копию заново и следить за журналом. Не прошла ни одна - неисправно копирование, а не отдельный файл: разобрать причину по журналу, как описано выше

ОПАСНО. Копия, не прошедшая проверку, восстановлению не подлежит и до выяснения причины не годится как единственная. Пока причина не найдена, сохраняйте более старые копии: срок хранения удалит их по расписанию, и вместе с ними исчезнет последняя пригодная.

Если журнала нет вовсе. Значит скрипт ни разу не запускался: не установлено расписание либо таймер остановлен. Проверьте его и посмотрите вывод последнего запуска.

Листинг 11.16 — Проверка расписания

```
systemctl list-timers 'systemburo-*'
systemctl status systemburo-backup.timer
journalctl -u systemburo-backup -n 100 --no-pager
```

Ожидаемый результат: таймер в состоянии active (waiting), в списке указано время следующего запуска. Состояние inactive означает, что таймер выключен: включается командой `sudo systemctl enable --now systemburo-backup.timer`.

11.6. Хранение вне сервера

Копия на том же диске не защищает от отказа диска. Выгрузка во внешнее S3-совместимое хранилище включается двумя параметрами: `BACKUP_S3_REMOTE` (имя настройки rclone) и `BACKUP_S3_BUCKET` (бакет и

префикс). Пока они пусты, выгрузка пропускается, а в журнал пишется предупреждение.

Требования к хранилищу те же, что к самой системе: копии содержат персональные данные, пусть и зашифрованные. Размещение данных выбирается с учётом требований к обработке персональных данных на территории Российской Федерации.

11.7. Восстановление

ОПАСНО. Восстановление заменяет текущее содержимое базы содержимым копии. Отменить это нельзя. Перед началом убедитесь, что выбрана нужная копия: имя файла содержит дату и время снятия.

Восстановление выполняется на сервере системы, в каталоге `/opt/systemburo`. Понадобится закрытый ключ шифрования: принесите файл `buro-backup.key` из хранилища секретов на время работ и удалите его с сервера после.

Порядок действий выполняет одна команда: она включает режим технических работ, останавливает прикладной сервер, восстанавливает базу и файлы, проверяет наполнение до запуска приложения, поднимает систему и снимает режим.

Имя нужной копии смотрят в каталоге копий: в имени файла стоят дата и время снятия.

Листинг 11.17 — Перечень доступных копий

```
sudo make deploy-backup-status
```

Ожидаемый результат: после сводки по каталогам выводится перечень копий - дата снятия словами, размер, состав, метка и имя файла, которое передаётся команде восстановления. Под строкой выгрузки базы идут её спутники: архив загруженных файлов и архив бланков, снятые в тот же момент. Дата и метка у них те же, поэтому повторно не печатаются.

Копии, пригодные для восстановления				
Снята	Размер	Что входит	Метка	Файл
2 августа 2026, 06:00	9.2 МБ	база+файлы+архив	-	buro-db-2026-08-02-0600.dump.age
	41.5 МБ	файлы		buro-uploads-2026-08-02-0600.tar.gz.age
	3.4 МБ	архив бланков		buro-archive-2026-08-02-0600.tar.gz.age
1 августа 2026, 17:22	9.2 МБ	только база	pered-testom	buro-db-2026-08-01-1722-pered-testom.dump.age

Файлы архивируются раз в неделю (BACKUP_UPLOADS_MODE=weekly), поэтому состав «только база» у копий за остальные дни - ожидаемый.

Копии перечислены от новых к старым. Одна и та же копия в нескольких каталогах показывается один раз: это один файл, на который стоят жёсткие ссылки.

Колонка «Что входит» отвечает на главный вопрос перед восстановлением - полная ли копия. Значение база+файлы+архив означает, что восстановить можно всё; только база - что загруженные файлы и бланки придётся брать из копии за другой день. Это не поломка, пока BACKUP_UPLOADS_MODE равен weekly: в этом режиме файлы архивируются по воскресеньям и первого числа, о чём команда и напоминает строкой под перечнем. В режиме daily та же строка заменяется предупреждением: файлы должны были войти в каждую копию, и если их нет, причина ищется в журнале копирования.

Ниже перечня может появиться ещё один блок - «Архивы файлов без выгрузки базы за тот же срок». В него попадают архивы, пережившие свою копию базы: сроки хранения считаются по каждому виду файлов отдельно, поэтому при недельном режиме архив загруженных файлов остаётся в хранилище дольше, чем суточные выгрузки базы. Восстанавливать такой архив не с чем - его берут только вместе с базой за другую дату, понимая последствия из подраздела «Восстановление копии, снятой давно».

Листинг 11.18 — Восстановление из копии

```
cd /opt/systemburo
AGE_IDENTITY=/путь/к/buro-backup.key \
make deploy-restore ARGS="/var/backups/systemburo/daily/<имя файла из перечня выше>"
```

На проверочном стенде команда называется make staging-restore, порядок тот же.

Ход работы виден по нумерации: каждый шаг печатается в виде [3/6] Восстанавливаю базу данных, после его завершения - затраченное время.

Шагов шесть, а если вторым аргументом передан архив загруженных файлов - семь. Самый долгий шаг обычно восстановление базы: минута-две на каждые десять мегабайт выгрузки.

ПРИМЕЧАНИЕ. Если в системе установлено средство `pv`, объём восстановления базы дополнительно показывается полосой с процентами. Устанавливать его необязательно, порядок работы от этого не меняется.

Команда запросит подтверждение: нужно ввести слово **ВОССТАНОВИТЬ**. Ожидаемый результат: выводятся числа восстановленных заявок и учётных записей, затем система поднимается и режим технических работ снимается сам.

Вторым аргументом можно передать архив загруженных файлов, если восстанавливать нужно и их. Оба имени берут из перечня выше: архив стоит строкой под своей выгрузкой базы, с подписью «файлы».

Листинг 11.19 — Восстановление вместе с файлами

```
AGE_IDENTITY=/путь/к/buro-backup.key bash scripts/restore.sh production \
/var/backups/systemburo/daily/<выгрузка базы> \
/var/backups/systemburo/daily/<архив загруженных файлов>
```

ВАЖНО. База и архив файлов берутся за один и тот же момент - у них совпадает метка времени в имени. Копия базы от одного числа с файлами от другого даёт карточки заявок, ссылающиеся на отсутствующие вложения.

Если восстановление прервалось

Система останется остановленной, а режим технических работ - включённым. Это сделано намеренно: поднимать приложение до выяснения причины опасно, потому что база может быть неполной.

ОПАСНО. Если восстановление прервалось на шаге восстановления базы, база пуста. Запуск приложения в этом состоянии создаст пустую схему заново и заведёт учётную запись администратора - данные из копии восстановить будет уже нельзя. Сначала восстановите базу, только потом поднимайте службы.

Определите, на каком шаге остановилась команда: последняя строка вывода начинается с двух знаков равенства и называет шаг.

Таблица 11.10 — Что делать при прерывании восстановления

Остановилось на шаге	Состояние системы	Порядок действий
Расшифровка копии, ключ не подошёл	База не тронута, службы остановлены	Проверить, тот ли закрытый ключ передан в AGE_IDENTITY, и повторить команду; либо поднять систему вручную и вернуться к восстановлению позже
Восстановление базы данных	База пуста , службы остановлены	Повторить восстановление из этой же или из предыдущей копии; не поднимать службы, пока счётчики не покажут данные
Восстановление загруженных файлов	База восстановлена, файлы частично	Повторить команду, передав вторым аргументом архив файлов; либо поднять систему и восстановить файлы отдельно
Проверка перед запуском	База восстановлена	Посмотреть выведенные числа: нули означают неподходящую копию, тогда повторить из другой
Запуск системы	База восстановлена, службы не поднялись	Поднять службы вручную, см. ниже
Снятие режима технических работ	Система работает, пользователи видят заглушку	Снять режим вручную, см. ниже

Ручной запуск после прерывания. Обе команды выполняются в каталоге `/opt/systemburo`. Для проверочного стенда в первой команде вместо `docker-compose.prod.yml` указывается `docker-compose.staging.yml`, во второй вместо `production` - `staging`.

Листинг 11.20 — Запуск служб и снятие режима вручную

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  start backend frontend nginx
bash scripts/maintenance-off.sh production
```

Ожидаемый результат: три службы запущены, страница входа открывается без заглушки о технических работах.

ВАЖНО. Используется `start`, а не `up`. Команда `up` обращается к реестру образов, где нужна авторизация, и на рабочем сервере завершится ошибкой `unauthorized`. Контейнеры уже созданы, их достаточно запустить.

Если службы не запускаются, причина не в восстановлении: порядок диагностики - в подразделе 13.1. Состояние базы в любой момент проверяется теми же счётчиками, что выводит проверка восстановимости из подраздела 11.5.

ВАЖНО. После восстановления проверьте вход в систему и открытие любой заявки. Если числа в выводе отличаются от ожидаемых, повторите восстановление из другой копии - предыдущие лежат в том же каталоге.

Возврат файлового архива бланков

Команда восстановления работает с базой и загруженными файлами. Файловый архив бланков в копию входит отдельным файлом `buro-archive-
<дата>.tar.gz` и разворачивается вручную - каталог архива лежит на диске сервера, а не в томе, и подменять его заодно с базой команда не берётся. Имя этого файла берут из перечня копий: он стоит под своей выгрузкой базы, с подписью «архив бланков».

Обычно этого и не требуется: перечень выложенного придёт из копии базы, а ночная сверка допишет недостающие файлы, см. подраздел 9.6. Разворачивать архив из копии нужно, когда каталог утрачен вместе с диском или из него пропали замороженные бланки - их система заново не формирует.

Листинг 11.21 — Возврат каталога архива из копии

```
age -d -i /путь/к/buro-backup.key \  
-o /tmp/buro-archive.tar.gz \  
/var/backups/systemburo/daily/buro-archive-2026-08-02-0600.tar.gz.age  
sudo tar xzf /tmp/buro-archive.tar.gz -C /srv/buro-archive  
sudo chown -R 1001:1001 /srv/buro-archive  
rm /tmp/buro-archive.tar.gz
```

Ожидаемый результат: в каталоге архива снова лежит дерево заявок, владелец совпадает с пользователем прикладного сервера. Если копии не шифруются, первая команда пропускается, а имя файла оканчивается на `.tar.gz`. Каталог назначения берётся из `ARCHIVE_HOST_PATH`, в примере это `/srv/buro-archive`.

ВАЖНО. Распаковка добавляет файлы к тем, что уже лежат в каталоге, и переписывает совпадающие по имени. Если архив разворачивается на замену прежнему содержимому, каталог сначала очищают: иначе рядом останутся файлы заявок, которых в восстановленной базе нет.

Восстановление копии, снятой давно

Копия годичной давности на сегодняшнюю версию системы разворачивается той же командой: порядок действий не меняется. Отличается последствия, и их надо знать заранее.

Схема базы приводится к текущей версии сама, при первом запуске системы после восстановления: недостающие таблицы, столбцы и индексы создаются. Обратного хода нет - схема правится только вперёд, поэтому вернуть базу к виду годичной давности после запуска новой версии уже нельзя.

ОПАСНО. Перед восстановлением старой копии снимите копию текущего состояния командой `make deploy-backup ARGS=pered-vosstanovleniem`. Без неё отменить восстановление будет нечем: данные, накопленные после снятия старой копии, исчезнут безвозвратно.

Таблица 11.11 — Что изменится при восстановлении давней копии

Что	Как поведёт себя
Учётные записи	Вернутся к состоянию копии. Работники, заведённые позже, исчезнут вместе со своими заявками и правами; пароли, изменённые позже, вернутся к прежним
Журнал запросов и журнал обращений к персональным данным	Из копии не попадут в интерфейс. Прежние таблицы сохраняются под именами <code>request_logs_legacy</code> и <code>pd_audit_logs_legacy</code> , а рабочие создаются заново пустыми: с тех пор они разделены по датам, и старый вид базе не подходит. Данные не теряются, разбираются запросом к базе
Персональные данные	Читаются только тем ключом шифрования, который действовал на момент снятия копии. Если ключ с тех пор менялся, фамилии и документы не расшифруются; ключ берут из хранилища секретов и возвращают в файл параметров вместе с копией
Загруженные файлы	Должны восстанавливаться из архива той же даты, что и база. База от одного числа с файлами от другого даёт карточки, ссылающиеся на отсутствующие вложения
Файловый архив бланков	Остаётся на диске от нынешней системы, а перечень выгруженного придёт из копии. Ночная сверка дополнит недостающее; чтобы архив в точности отвечал восстановленным заявкам, каталог очищают до запуска и выгружают заново за нужный период
Заявки в работе	Вернутся к состоянию на момент копии: согласования, сделанные позже, отменятся, а завершённые заявки снова окажутся в обработке

Порядок безопаснее проверить сначала на стенде: `make staging-restore` разворачивает ту же копию на проверочном контуре, где ошибка

ничего не стоит. Стенд поднят на той же версии системы, что и рабочий сервер, поэтому поведение будет тем же.

11.8. Перенос на другой сервер

Копии подходят и для переноса: выгрузка базы и архивы файлов не зависят от сервера, на котором сняты. Развёрнутый порядок переноса с проверками описан в разделе 14.

12. Мониторинг и журналы

12.1. Проверка состояния

Адрес `/health` возвращает признак работоспособности прикладного сервера. Проверка подключается к средствам мониторинга организации.

Листинг 12.1 — Проверка состояния

```
curl -s http://localhost/health
```

Ожидаемый результат: `{"status": "ok"}`.

ВАЖНО. Проверка подтверждает, что процесс запущен и отвечает, но к базе данных она не обращается. При недоступной базе проверка продолжит отвечать успешно, а система работать не будет. Полноценным контролем является периодическая проверка входа в систему.

Контейнер прикладного сервера имеет встроенную проверку работоспособности с интервалом 30 секунд. Контейнер базы данных проверяется каждые 10 секунд, и прикладной сервер не запускается, пока база не сообщит о готовности.

12.2. Журналы приложения

Прикладной сервер пишет журнал в поток вывода и, если задан параметр `LOG_FILE_PATH`, дополнительно в файл. На рабочем сервере файловый журнал включён.

Смена файлов выполняется самим приложением, настраивать системное средство ротации не требуется: файл сменяется при достижении 100 МБ, хранится 30 суток, сохраняется до 14 файлов, старые сжимаются.

Листинг 12.2 — Просмотр журналов

```
# все службы, в реальном времени
sudo make deploy-logs

# только прикладной сервер, последние 200 строк
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  logs --tail=200 backend

# только ошибки
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  logs backend | grep -i error
```

ВАЖНО. Журналы контейнеров по умолчанию не ограничены по размеру и способны заполнить диск. Настройте ограничение при вводе в эксплуатацию.

Листинг 12.3 — Ограничение размера журналов контейнеров

```
# /etc/docker/daemon.json
{
  "log-driver": "json-file",
  "log-opts": { "max-size": "50m", "max-file": "5" }
}
```

После изменения файла выполните перезапуск службы Docker и пересоздание контейнеров.

Листинг 12.4 — Применение ограничения журналов

```
sudo systemctl restart docker
sudo make deploy-up
```

Ожидаемый результат: для каждого контейнера хранится не более пяти файлов журнала по 50 МБ.

12.3. Журналы внутри системы

Часть журналов доступна прямо в интерфейсе и не требует доступа к серверу. Их могут просматривать как специалисты ИТ, так и операторы бюро с соответствующим правом.

Таблица 12.1 — Журналы, доступные в интерфейсе

Журнал	Содержание	Где находится
Журнал запросов	Все обращения к системе: работник, действие, код ответа, длительность, время	Раздел системного управления
Журнал обращений к персональным данным	Обращения к сведениям о людях: работник, действие, раздел, адрес, время	Раздел администрирования, открывается по отдельному праву
Журнал изменений	Кто, когда и что изменил в сущностях системы	Раздел администрирования
Журнал отказов в доступе	Попытки выполнить действие без права	Раздел администрирования
Журнал входов	Входы, выходы, неудачные попытки, блокировки и их снятие администратором	Карточка работника

Журнал запросов и журнал обращений к персональным данным поддерживают фильтрацию и выгрузку в электронную таблицу.

Подробные записи журнала запросов хранятся 30 суток, затем сворачиваются в суточные итоги. Записи журнала обращений к персональным данным хранятся 36 месяцев без свёртки и вместе с журналом запросов не удаляются.

12.4. Что контролировать

Таблица 12.2 — Показатели для наблюдения

Показатель	Норма	Признак неблагополучия
Состояние служб	Все Up, база healthy	Перезапуски, состояние Restarting
Свободное место на диске	Более 20 процентов	Менее 10 процентов требует немедленных действий
Сообщения уровня error в журнале	Единичные	Повторяющиеся однотипные ошибки
Отказы в доступе	Единичные	Массовые отказы указывают на неверно настроенные права
Срок действия сертификата	Более 30 суток	Менее 30 суток требует продления
Число подключений к базе	Значительно меньше 150	Приближение к пределу
Размер базы и крупнейшие таблицы	Рост на 2-4 ГБ в год	Резкий рост одной таблицы вне этого порядка
Состояние файлового архива	Ошибок записи нет, очередь разбирается	Растущее число ошибок либо остановка очереди по нехватке места
Возраст последней резервной копии	Не старше суток	Двое суток и более означают, что копирование сломано

Размер базы в разрезе таблиц показывает команда `make deploy-storage`. Она только читает и ничего не изменяет, поэтому её можно выполнять в любое время. Кроме размеров она отвечает, сколько из занятого объёма подлежит очистке по срокам хранения, то есть сразу подсказывает, есть ли смысл браться за подраздел 9.9 «Очистка накопленных данных».

Листинг 12.5 — Обзор занятого места

```
sudo make deploy-storage
```

Ожидаемый результат: размер базы, перечень крупнейших таблиц с числом записей и размером, затем сводка по группам очистки. Число таблиц в перечне задаётся ключом `-top`, например `make deploy-storage ARGS="-top=30"`.

ПРИМЕЧАНИЕ. Разделы журнальных таблиц в перечне не показываются отдельными строками, их объём учтён в родительской таблице. Число записей берётся из внутренней статистики базы и может незначительно расходиться с точным, пока не отработала автоматическая очистка.

13. Диагностика и типовые неисправности

13.1. Порядок диагностики

Таблица 13.1 — Команды диагностики

Что выяснить	Команда
Состояние служб	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml ps</code>
Причина незапуска службы	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml logs <служба></code>
Потребление ресурсов	<code>sudo docker stats</code>
Свободное место	<code>df -h</code> и <code>sudo docker system df</code>
Доступность базы	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml exec db pg_isready -U postgres</code>
Действующие параметры прикладного сервера	<code>sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml exec backend env</code>
Проверка сертификата	<code>openssl x509 -in nginx/certs/fullchain.pem -noout -dates</code>

13.2. Система недоступна, страница не открывается

Таблица 13.2 — Диагностика недоступности

Шаг	Действие	Вывод
1	Проверить состояние служб	Службы не запущены, перейти к шагу 2, иначе к шагу 3
2	<code>sudo make deploy-up</code> , затем <code>sudo make deploy-logs</code>	Причина незапуска будет в журнале
3	<code>curl -s http://localhost/health</code>	Ответ есть, значит неисправность в сети или правилах межсетевого экрана. Ответа нет, значит в прикладном сервере
4	<code>df -h</code>	Заполнение диска приводит к отказу базы данных

13.3. Обратный прокси не запускается

Наиболее вероятная причина: отсутствует файл сертификата. Прокси с настроенным защищённым соединением не стартует, если сертификата нет.

Листинг 13.1 — Проверка наличия сертификата

```
ls -l nginx/certs/fullchain.pem nginx/certs/privkey.pem
```

Ожидаемый результат: оба файла существуют. При их отсутствии выпустите сертификат по подразделу 7.3.

13.4. Предупреждение о недоверенном сертификате

Признак: браузер сообщает о недоверенном сертификате и не предлагает продолжить.

Отсутствие предложения продолжить нормально и вызвано требованием обязательного защищённого соединения. Причина в том, что корневой сертификат не установлен на рабочем месте, устранение по подразделу 7.4.

Листинг 13.2 — Проверка, какой сертификат отдаёт сервер

```
openssl s_client -connect <адрес>:443 -servername <адрес> \
  </dev/null 2>/dev/null \
  | openssl x509 -noout -subject -ext subjectAltName
```

Ожидаемый результат: в поле альтернативных имён присутствует адрес, по которому обращаются работники. Если обращение идёт по

сетевому адресу, а сертификат выпущен только на имя, требуется перевыпуск с указанием адреса вторым аргументом.

13.5. Прикладной сервер не запускается

Таблица 13.3 — Сообщения об ошибках при запуске

Сообщение в журнале	Причина	Устранение
Ошибка обязательного параметра	Не задан или недопустим один из трёх обязательных параметров	Проверить файл параметров, подраздел 6.2
Ошибка подключения к базе	База не готова либо неверны учётные данные	Проверить доступность базы, подраздел 13.1
Ошибка приведения схемы	Несовместимое изменение схемы	Восстановить базу из копии, сделанной до обновления
Требуется ключ шифрования	Включено требование шифрования, ключ отсутствует	Задать ключ либо отключить требование

13.6. Изменение параметра не подействовало

Наиболее частая причина: параметр не входит в набор, передаваемый через файл параметров, см. подраздел 6.1.

Листинг 13.3 — Проверка действующих параметров

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec backend env | grep RESET_TIMEZONE
```

Ожидаемый результат: выведено заданное значение. Если параметр отсутствует в выводе, добавьте его в раздел `environment` файла описания рабочего сервера.

13.7. Заканчивается место на диске

Таблица 13.4 — Освобождение дискового пространства

Потребитель	Как проверить	Как освободить
Журналы контейнеров	<code>sudo docker system df</code>	Настроить ограничение, подраздел 12.2
Неиспользуемые образы	<code>sudo docker system df</code>	<code>sudo docker system prune -a --filter "until=168h"</code> (при выпуске новой версии убираются сами, см. ниже)
Журнал запросов в базе	Размер таблиц журнала	Уменьшить <code>REQUEST_LOG_DETAIL_DAYS</code>

Потребитель	Как проверить	Как освободить
История, слепки и суточные итоги	<code>sudo make deploy-storage</code>	Команда очистки, подраздел 9.9
Резервные копии	<code>sudo make deploy-backup-status</code>	Уменьшить сроки хранения, подраздел 11.3
Загруженные файлы	<code>sudo docker system df -v</code>	Перенести том на отдельный раздел
Файловый архив бланков	Раздел администрирования «Файловый архив»	Перенести каталог на отдельный раздел либо задать архиву предельный объём, подраздел 9.6

ВАЖНО. Не уменьшайте срок хранения журнала обращений к персональным данным без правовых оснований. Он определяется требованиями к обработке персональных данных.

ПРИМЕЧАНИЕ. После успешного выпуска новой версии сервер убирает за собой сам - удаляются висячие слои, кеш сборки старше недели и образы, на которые не ссылается ни один контейнер, старше суток. Тома не затрагиваются ни одной из этих команд: база и загруженные файлы остаются на месте. Ручная уборка из таблицы нужна, если выпуски давно не выполнялись или место кончилось между ними.

13.8. Система работает медленно

Таблица 13.5 — Диагностика замедления

Проверка	Толкование
<code>sudo docker stats</code>	Постоянная загрузка процессора базой близко к пределу означает нехватку ресурсов либо тяжёлые отчёты
Журнал запросов, сортировка по длительности	Выявляет конкретные медленные операции
Число подключений к базе	Приближение к 150 указывает на исчерпание предела
Свободная память	Нехватка приводит к вытеснению кэша базы и резкому замедлению

13.9. Работник не видит раздел или получает отказ

1. Открыть журнал отказов в доступе: там зафиксировано, какое именно право не было предоставлено.
2. Проверить назначенные работнику роль и группы прав.
3. Учесть задержку до 30 секунд после изменения прав.
4. Убедиться, что учётная запись не заблокирована.

Отдельный случай - работник не может войти вовсе и видит обратный отсчёт. Это временная блокировка входа после пяти неудачных попыток пароля; в карточке работника она помечена, и там же снимается кнопкой. Журнал входов показывает, сколько попыток и с каких адресов было сделано.

13.10. Не приходят обновления без перезагрузки страницы

Признак: данные на открытой странице обновляются только после ручного обновления.

Проверить, что обратный прокси не буферизует поток событий. В поставляемой конфигурации буферизация отключена и увеличен предельный срок ожидания для трёх адресов: потока событий и двух адресов выгрузки из файлового архива. Если конфигурация изменялась, восстановите эти параметры.

Принудительное переподключение каждые 10 минут является штатным поведением.

13.11. Выгрузка из файлового архива не начинается или обрывается

Признак: после нажатия кнопки скачивания загрузка долго не начинается, обрывается на середине либо сервер отвечает ошибкой.

Таблица 13.6 — Диагностика выгрузки из архива

Проверка	Толкование
Сообщение о превышении предела	Объём выгрузки больше заданного предела, по умолчанию два гигабайта. Сузить период либо поднять предел на сервере: <code>sudo make deploy-archive ARGS="set -zip-max 4G"</code>
Отказ в доступе	Скачивание закрыто отдельным правом, отличным от права на просмотр раздела
Настройки прокси для адресов выгрузки	При включённой буферизации прокси накапливает весь архив, прежде чем отдать первый байт: выгрузка за месяц упирается в память сервера. Буферизация должна быть отключена, предельный срок ожидания увеличен
Свободная память на сервере	<code>sudo docker stats</code> во время выгрузки: рост потребления памяти прокси означает, что буферизация всё же включена

ПРИМЕЧАНИЕ. Ссылка на скачивание действует минуту и гасится при первом использовании. Повторное открытие сохранённой ссылки заканчивается отказом - это штатное поведение, выгрузку запускают заново из интерфейса.

13.12. Бланки не появляются в каталоге архива

Признак: заявки подаются, а в каталоге пусто или новых файлов нет. Проверки идут сверху вниз, от общего выключателя к отдельному вложению.

Таблица 13.7 — Диагностика записи в архив

Проверка	Толкование
<code>sudo make deploy-archive ARGS="show"</code> , строка «Выгрузка бланков»	Значение «выключена» - записи не будет ни по одной заявке. Включается <code>sudo make deploy-archive ARGS="on"</code>
Тумблер автосохранения в карточке типа вложения	Выгружаются только те типы, у которых он включён. Тумблер недоступен, пока у типа нет действующего Excel-бланка
Состояние вложения в карточке заявки	«Нет шаблона» - приложить бланк типу вложения; «Нет места» - освободить место на разделе; «Ошибка» - причина видна в разделе администрирования, вкладка «Лента» с отбором по состоянию
Владелец каталога <code>ARCHIVE_HOST_PATH</code>	Процесс не меняет владельца и на чужом каталоге останавливается. Владелец должен совпадать с пользователем прикладного сервера, см. подраздел 9.6
Причина у строки в ленте раздела	Сообщение о запрете доступа при создании каталога (<code>permission denied</code>) означает именно чужого владельца каталога архива, а не нехватку места или отсутствие бланка
Дата заявки	Записываются заявки, изменённые после включения архива. Ранее поданные выкладывает только выгрузка задним числом за нужный период
Журнал прикладного сервера	<code>sudo make deploy-logs</code> : сообщения об остановке записи по месту и об ошибках файловой системы пишутся туда

ПРИМЕЧАНИЕ. Файл появляется не в момент нажатия кнопки, а через несколько секунд: запись идёт фоновой очередью. Если файл не появился и через минуту, проверки из таблицы уместны.

ВАЖНО. После устранения причины файлы появляются не мгновенно. Сорвавшуюся строку система забирает на повтор в ближайший обход очереди, а он идёт раз в пять минут (`ARCHIVE_SWEEP_INTERVAL`); строки, остановленные нехваткой места, повторяются раз в пятнадцать минут. Ждать нужно этот срок, а не нажимать повтор в разделе: он делает ту же работу, только раньше. Срок ближайшей попытки подписан у строки в ленте раздела администрирования.

13.13. Письма не приходят

Признак: работники сообщают, что не получают писем от системы. Проверки идут сверху вниз: сначала выясняется, отправляет ли система вообще, затем что отвечает почтовый сервер, и только потом что происходит с письмом на стороне получателя.

Шаг 1. Отправить проверочное письмо. Порядок описан в подразделе 6.6. Ответ на него разделяет две разные неисправности. Ответ с отказом означает, что система не дошла до почтового сервера или он её не принял: причина в таблице ниже. Ответ об успешной отправке при неполученном письме означает, что письмо ушло, а потерялось уже на стороне получателя: проверьте папку со спамом и записи SPF и DKIM домена отправителя, см. подраздел 6.6.

Шаг 2. Прочитать очередь. Проверочное письмо отправляется мимо очереди, поэтому его успешная отправка ещё не означает, что очередь разбирается. Состояние писем видно в таблице `email_messages`.

Листинг 13.4 — Состояние очереди писем

```
docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec -T db psql -U postgres -d "$DB_NAME" \
  -c "SELECT id, to_address, template_code, status, attempts,
      next_attempt_at, last_error
      FROM email_messages ORDER BY created_at DESC LIMIT 20;"
```

Ожидаемый результат: перечень последних писем. Значение `sent` в столбце состояния означает переданное почтовому серверу письмо, `pending` - ожидающее отправки, `failed` - письмо, по которому исчерпаны попытки. Столбец `attempts` показывает число сделанных попыток, `next_attempt_at` - время ближайшей следующей, `last_error` - дословный ответ почтового сервера на последнюю неудачную.

ВАЖНО. Столбец `body` в запрос включать не следует. В тексте письма могут быть сведения, предназначенные только получателю, и в выводе на экран сервера им не место. По этой же причине текст письма не отдаётся и через программный интерфейс.

Таблица 13.8 — Толкование состояния очереди

Что видно	Толкование
Таблица пуста, писем нет вовсе	Ни одно событие не поставило письмо в очередь. При выключенной почте это штатно: постановка отклоняется сразу
Письма в состоянии pending, число попыток не растёт	Фоновая задача разбора не работает. Проверить журнал прикладного сервера: при пустом SMTP_HOST при запуске записано, что почта не настроена и задача не запущена
Число попыток растёт, состояние pending	Почтовый сервер отказывает, отправка повторяется. Причина в столбце последней ошибки, разбор в следующей таблице
Письма в состоянии failed	Попытки исчерпаны, система больше не пытается, причина записана в журнал прикладного сервера. Устранение причины прежние письма не возобновляет: заново отправляются только новые

Шаг 3. Разобрать ответ почтового сервера. Причину даёт ответ сервера в столбце последней ошибки или в ответе на проверочное письмо. Отказов немного, и у каждого типовая причина.

Таблица 13.9 — Типовые отказы почтового сервера

Ответ	Причина	Что делать
535, отказ в проверке подлинности	Логин или пароль не приняты	Проверить SMTP_USERNAME и SMTP_PASSWORD. В Яндекс 360 требуется пароль приложения, а не пароль от учётной записи
550, отправитель не разрешён	Адрес в SMTP_FROM не совпадает с ящиком, под которым система входит на сервер	Привести SMTP_FROM к адресу ящика из SMTP_USERNAME
Истёк срок ожидания ответа	Соединение до почтового сервера не проходит	Проверить исходящее соединение с самого сервера, см. подраздел 6.6. Обычная причина - закрытый исходящий порт
Соединение отклонено, имя не разрешается	Неверный адрес или порт почтового сервера	Проверить SMTP_HOST и SMTP_PORT
Ошибка защищённого соединения, отказ по сертификату	Режим защиты не соответствует порту	Привести SMTP_TLS_MODE в соответствие: порту 587 обычно отвечает starttls, порту 465 - tls
Почта не настроена	SMTP_HOST пуст либо не дошёл до прикладного сервера	Проверить, что параметры переданы в контейнер, см. подраздел 6.6

ПРИМЕЧАНИЕ. Система переводит ответ почтового сервера на понятный язык сама, поэтому в ответе на проверочное письмо видно и объяснение причины, и дословный ответ сервера. В очереди хранится только дословный ответ, обрезанный до 500 символов: код ответа стоит в его начале и при обрезке не теряется.

13.14. Система не требует смены паролей по истечении срока

Признак: срок действия паролей включён, а работников с давними паролями система по-прежнему пускает без смены. Проверки идут сверху вниз, от общего выключателя к отдельной учётной записи. Порядок настройки описан в подразделе 9.3.

Таблица 13.10 — Диагностика срока действия паролей

Проверка	Толкование
Тумблер «Требовать смену пароля по истечении срока», раздел «Настройки», вкладка «Безопасность»	Выключен - проверки сроков не будет вовсе. В поставке он выключен, и включать его требуется отдельно
Значение «Срок действия пароля вышел у работников»	Ноль означает, что срок не вышел ни у кого: либо срок задан большим, либо пароли недавно менялись. Это штатное состояние, а не неисправность
Значение «Ближайшая проверка»	Проверка идёт ежесуточно в 04:00 по часовому поясу RESET_TIMEZONE. Если систему запустили после 04:00, первая проверка будет только на следующие сутки
Журнал прикладного сервера	make deploy - logs: при запуске записывается строка о запуске планировщика со временем ближайшей проверки, по завершении - сколько паролей помечено истёкшими и сколько пометить не удалось
Открытая вкладка работника	Требование вступает в силу не позже чем через 30 секунд и на уже открытой вкладке: она упирается в форму смены на первом же обращении к серверу. Ждать, пока истечёт выданный ранее маркер доступа, не нужно

ПРИМЕЧАНИЕ. Почта этой возможности не нужна, и её отсутствие проверку сроков не останавливает. Без настроенной почты не уходят только предупреждения о скором истечении, и работник узнаёт о нём уже на входе.

Отдельный случай - жалоба вида «система требует сменить пароль и никуда не пускает». Это не неисправность, а работа самого механизма: либо у работника вышел срок действия пароля, либо ему послали придуманный

системой пароль и включена настройка «Требовать сменить пароль при первом входе». Пока он не задаст свой пароль в открывшейся форме, система в остальном ему отказывает. Выключать настройку ради удобства не следует - именно она ограничивает срок жизни пароля, лежащего в почтовом ящике открытым текстом, а на смену по истечении срока она всё равно не влияет.

Признак другого рода: работникам разослали новые пароли кнопкой «Обновить пароль всем работникам» или из карточки, а писем никто не получил.

Таблица 13.11 — Диагностика рассылки придуманных паролей

Проверка	Толкование
Строка о ненастроенной почте в блоке «Срок действия паролей»	Почта не настроена: кнопка «Обновить пароль всем работникам» не показывается, смена из карточки отвечает отказом. Настройка описана в подразделе 6.6
Значение «Без почты»	Учётные записи без указанного адреса рассылка пропускает: выслать пароль некуда. Полный список открывается в разделе «Пользователи» переключателем режима в положение «Без почты», адреса проставляет бюро
Очередь писем	Пароли сменились, а писем нет - неисправность не в смене, а в отправке, см. подраздел 13.13. Письма ищутся в очереди по виду password_rotated

ВАЖНО. Пароль работника, у которого письмо не дошло, уже сменён - прежний не действует. Такому работнику пароль восстанавливают отдельно: в разделе «Пользователи», в карточке работника, кнопкой «Сменить пароль и отправить письмом» после того, как устранена причина недоставки, либо заданием пароля вручную там же.

14. Перенос системы на другой сервер

Раздел описывает перенос работающей системы вместе со всеми данными: например, с сервера во внутренней сети организации на арендованный сервер. Порядок обеспечивает сохранность данных и возможность вернуться к прежнему серверу, если что-то пойдёт не так.

14.1. Что переносится

Таблица 14.1 — Состав переносимых данных

Элемент	Где находится	Последствия, если не перенести
База данных	Том pgdata	Утрата всех заявок, реестров, учётных записей и журналов
Загруженные файлы	Том uploads	Фотографии, шаблоны бланков и приложения к заявкам пропадут, записи в базе будут ссылаться в пустоту
Файл параметров	.env в каталоге системы	См. предупреждение ниже
Сертификат	nginx/certs/	Потребуется выпустить заново, что при смене адреса и так необходимо

ОПАСНО. Файл параметров переносится со старого сервера, а не создаётся заново. В нём хранится ключ шифрования персональных данных. Если на новом сервере сгенерировать новый файл параметров, перенесённая база откроется, но сведения документов, удостоверяющих личность, прочитать будет невозможно ничем.

14.2. Что меняется при переносе

Три параметра привязаны к адресу системы и требуют изменения.

Таблица 14.2 — Параметры, зависящие от адреса

Параметр	Что задаёт
CORS_ALLOWED_ORIGINS	Адреса, с которых интерфейсу разрешено обращаться к серверу
VITE_API_BASE_URL	Адрес, по которому интерфейс обращается к серверу
COMPOSE_PROJECT_NAME	Имя установки, от которого зависят имена томов с данными

ВАЖНО. Адрес сервера встраивается в интерфейс на этапе сборки, а не читается при запуске. После изменения адреса образ интерфейса необходимо собрать заново, иначе интерфейс на новом сервере продолжит обращаться к старому.

14.3. Подготовка нового сервера

Выполните на новом сервере подразделы 5.1, 5.2 и 5.3: установите служебные пакеты и Docker, разместите исходный код в рабочем каталоге. Создание файла параметров и первый запуск пока не выполняйте.

ВАЖНО. Новому серверу нужен собственный доступ к репозиторию. Ключ развёртывания старого сервера не переносится вместе с данными: пара ключей создаётся на новом сервере, её открытая часть добавляется в репозиторий, а после вывода прежнего сервера из работы его ключ отзывается, см. подраздел 4.1.

14.4. Выгрузка данных со старого сервера

Работы выполняются при остановленном прикладном сервере, чтобы данные не менялись во время выгрузки. База данных при этом остаётся запущенной.

Шаг 1. Загрузите параметры установки в оболочку. Без этого имя базы и имя тома окажутся пустыми, и команды выгрузки отработают вхолостую.

Листинг 14.1 — Загрузка параметров в оболочку

```
cd /opt/systemburo
set -a; . ./env; set +a
UPLOADS_VOL=$(sudo docker volume ls --format '{{.Name}}' \
| grep '_uploads$' | head -1)
echo "база: $DB_NAME, том файлов: $UPLOADS_VOL"
```

Ожидаемый результат: выведены непустые имя базы и имя тома, например база: auto_registry, том файлов: systemburo_uploads. Если что-то пусто, дальше идти нельзя.

Шаг 2. Остановите приём заявок.

Листинг 14.2 — Остановка приёма заявок

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
stop backend frontend nginx
```

Ожидаемый результат: три службы остановлены, служба базы данных продолжает работать.

Шаг 3. Выгрузите базу данных.

Листинг 14.3 — Выгрузка базы данных

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
exec -T db pg_dump -U postgres -Fc "$DB_NAME" > /tmp/buro-db.dump
ls -lh /tmp/buro-db.dump
```

Ожидаемый результат: файл создан, размер отличен от нуля и составляет обычно от десятков мегабайт.

Шаг 4. Убедитесь, что выгрузка читается. Повреждённый файл лучше обнаружить сейчас, а не на новом сервере.

Листинг 14.4 — Проверка выгрузки

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec -T db pg_restore --list < /tmp/buro-db.dump | head -20
```

Ожидаемый результат: выводится перечень объектов базы. Сообщение об ошибке формата означает, что выгрузка повреждена и её нужно повторить.

Шаг 5. Выгрузите загруженные файлы.

Листинг 14.5 — Выгрузка загруженных файлов

```
sudo docker run --rm \
  -v "$UPLOADS_VOL":/data:ro \
  -v /tmp:/backup alpine \
  tar czf /backup/buro-uploads.tar.gz -C /data .
ls -lh /tmp/buro-uploads.tar.gz
```

Ожидаемый результат: архив создан, размер отличен от нуля.

Шаг 6. Передайте на новый сервер три файла: выгрузку базы, архив файлов и файл параметров.

Листинг 14.6 — Передача файлов на новый сервер

```
scp /tmp/buro-db.dump /tmp/buro-uploads.tar.gz .env \
  buro@<адрес нового сервера>:/tmp/
```

ВАЖНО. Файл параметров содержит пароли и ключ шифрования персональных данных. Передавайте его защищённым каналом и удалите промежуточные копии из каталога /tmp на обоих серверах после завершения переноса.

14.5. Восстановление на новом сервере

Шаг 1. Разместите файл параметров в каталоге системы и внесите изменения по подразделу 14.2: новый адрес в CORS_ALLOWED_ORIGINS и VITE_API_BASE_URL. Строку подключения к базе менять не требуется, она указывает на службу внутри контура.

Листинг 14.7 — Размещение файла параметров

```
cd /opt/systemburo
cp /tmp/.env ./env
chmod 600 ./env
set -a; . ./env; set +a
echo "база: $DB_NAME"
```

Ожидаемый результат: выведено непустое имя базы.

Шаг 2. Запустите базу данных и восстановите выгрузку.

Листинг 14.8 — Запуск базы данных и восстановление

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  up -d db
sleep 10
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec -T db pg_restore -U postgres -d "$DB_NAME" --clean --if-exists \
  < /tmp/buro-db.dump
```

Ожидаемый результат: восстановление завершается без сообщений об ошибках. Отдельные предупреждения о несуществующих объектах при первом восстановлении нормальны.

Шаг 3. Проверьте, что данные на месте, ещё до запуска приложения.

Листинг 14.9 — Проверка восстановленной базы

```
sudo docker compose -f docker-compose.base.yml -f docker-compose.prod.yml \
  exec -T db psql -U postgres -d "$DB_NAME" \
  -c "SELECT count(*) AS applications FROM applications;" \
  -c "SELECT count(*) AS users FROM users;"
```

Ожидаемый результат: числа совпадают с прежним сервером. Нули означают, что восстановление не выполнено.

Шаг 4. Восстановите загруженные файлы. Имя тома должно совпадать с тем, которое создаст описание контура.

Листинг 14.10 — Восстановление загруженных файлов

```
UPLOADS_VOL="$(basename $PWD)_uploads"
[ -n "$COMPOSE_PROJECT_NAME" ] \
  && UPLOADS_VOL="${COMPOSE_PROJECT_NAME}_uploads"
sudo docker volume create "$UPLOADS_VOL"
sudo docker run --rm \
  -v "$UPLOADS_VOL":/data \
  -v /tmp:/backup alpine \
  tar xzf /backup/buro-uploads.tar.gz -C /data
sudo docker run --rm -v "$UPLOADS_VOL":/data alpine \
  sh -c "ls /data | head; ls /data | wc -l"
```

Ожидаемый результат: выводится перечень каталогов и их число, совпадающее с прежним сервером.

14.6. Сертификат и запуск

Подготовьте сертификат для нового адреса по разделу 7. При переносе в сеть общего пользования это возможность перейти на сертификат общедоступного удостоверяющего центра и отказаться от установки корневого сертификата на рабочие места.

Листинг 14.11 — Сборка и запуск на новом сервере

```
sudo make deploy-build
sudo make deploy-up
sudo make deploy-logs
```

Ожидаемый результат: службы запускаются, в журнале нет сообщений уровня error. Приведение схемы базы данных выполняется быстро: схема уже соответствует восстановленным данным.

14.7. Проверка после переноса

Проверки выполняются до переключения пользователей на новый сервер.

Таблица 14.3 — Проверки после переноса

Проверка	Ожидаемый результат
Вход администратора	Выполняется с прежним паролем
Число заявок в центре заявок	Совпадает с прежним сервером
Открытие заявки со вложениями	Открывается, файлы и фотографии отображаются
Открытие карточки человека	Сведения документа, удостоверяющего личность, читаются
Открытие таблицы поста	Перечень допущенных объектов на месте
Формирование печатной формы	Формируется, шаблон найден
Журналы	Записи за прежний период доступны

ВАЖНО. Проверка чтения сведений документа, удостоверяющего личность, обязательна. Именно она подтверждает, что ключ шифрования перенесён верно. Все остальные проверки могут пройти успешно и при неверном ключе.

14.8. Переключение и вывод прежнего сервера из работы

После успешной проверки измените запись в системе доменных имён либо сообщите работникам новый адрес.

Прежний сервер не выключайте сразу. Держите его остановленным, но сохранным не менее двух недель: этого срока достаточно, чтобы проявились расхождения, незаметные при первичной проверке. Возврат в этом случае сводится к обратному переключению адреса.

Данные, внесённые на новом сервере после переключения, при возврате будут потеряны, поэтому решение о возврате принимается в первые сутки.

По истечении срока хранения удалите с прежнего сервера тома с данными и файл параметров: они содержат персональные данные и ключ шифрования. Тогда же отзовите его доступ к репозиторию исходного кода - удалите ключ развёртывания из настроек репозитория, порядок в подразделе 4.1. Пока ключ действует, выведенный из работы сервер сохраняет право получать код системы.

Приложение А. Порты и сетевые доступы

Таблица А.1 — Сетевые доступы

Порт	Протокол	Откуда доступен	Назначение
443	TCP	Сеть организации	Работа с системой
80	TCP	Сеть организации	Перенаправление, проверка при выпуске сертификата, проверка состояния
22	TCP	Адреса подразделения ИТ	Управление сервером
8080	TCP	Только внутренняя сеть контейнеров	Прикладной сервер
80	TCP	Только внутренняя сеть контейнеров	Веб-приложение
5432	TCP	Только внутренняя сеть контейнеров	База данных

Снаружи остаются доступны ровно три порта из этого перечня: 80 и 443 открывает сама система, 22 нужен для управления сервером и к системе отношения не имеет. Остальное закрывает межсетевой экран политикой по

умолчанию, порядок его настройки - в подразделе 5.10. Порты внутренней сети контейнеров экраном не управляются: они не публикуются на внешние адреса вовсе.

ВАЖНО. Экран не закрывает порты, опубликованные контейнерами. На рабочем сервере их публикует только обратный прокси, 80 и 443, поэтому перечень выше верен; но всякая новая публикация порта в описании контейнера открывает его наружу независимо от правил экрана, см. подраздел 5.10.

Исходящие соединения система открывает в трёх случаях, и все они необязательны: без них она работает автономно, теряя только соответствующую возможность.

Таблица А.2 — Исходящие соединения

Порт	Протокол	Куда	Назначение	Когда требуется
587 либо 465	TCP	Почтовый сервер из SMTP_HOST	Отправка писем системы	Настроена почтовая рассылка, подраздел 6.6
443	TCP	Удостоверяющий центр	Выпуск и продление сертификата	Сертификат выпускается общедоступным центром, подраздел 7.3
443	TCP	Внешний сервис сообщений	Сообщения о сбоях	Заданы параметры отправки сообщений о сбоях

ВАЖНО. Порт 25 системе не нужен. На арендованных виртуальных серверах он закрыт поставщиком услуг по умолчанию, поэтому отправка писем через него не настраивается: используются 587 или 465.

Сама система других портов не открывает. Если каталог файлового архива отдаётся работникам сетевой папкой, порт файлового доступа поднимается средствами операционной системы, наружу не публикуется и ограничивается сетью организации, см. подраздел 9.7.

Приложение Б. Перечень параметров конфигурации

Таблица Б.1 — Подключение и запуск

Параметр	По умолчанию	Назначение
DATABASE_URL	нет, обязателен	Строка подключения к базе данных
DB_NAME	auto_registry	Имя базы данных
DB_USER	postgres	Пользователь базы данных
DB_PASSWORD	нет	Пароль пользователя базы данных

Параметр	По умолчанию	Назначение
BIND_HOST	0.0.0.0	Адрес приёма соединений
BIND_PORT	8090	Порт прикладного сервера, в поставке задан 8080
LOG_LEVEL	info	Подробность журнала
SWAGGER_ENABLED	false	Публикация описания программного интерфейса

Таблица Б.2 — Пул соединений с базой данных и сроки ожидания сервера

Параметр	По умолчанию	Назначение
DB_MAX_OPEN_CONNS	50	Предел одновременных соединений с базой. Ограничение защищает базу от исчерпания её собственного предела при всплеске обращений
DB_MAX_IDLE_CONNS	25	Сколько соединений остаётся открытыми в простое, чтобы после всплеска они были горячими. Не может превышать предел одновременных: сервер откажется стартовать
DB_CONN_MAX_LIFETIME	1h	Через какое время соединение закрывается и открывается заново. Без этого после перезапуска базы или переключения на реплику соединение продолжало бы работать со старой стороной
DB_CONN_MAX_IDLE_TIME	10m	Через сколько закрывается простаивающее соединение, чтобы ночью пул опускался обратно к нескольким штукам
HTTP_READ_HEADER_TIMEOUT	10s	Сколько сервер ждёт заголовки запроса
HTTP_READ_TIMEOUT	120s	Сколько сервер ждёт запрос целиком
HTTP_WRITE_TIMEOUT	120s	Сколько отводится на отправку ответа
HTTP_IDLE_TIMEOUT	120s	Сколько живёт соединение между запросами

ПРИМЕЧАНИЕ. Ноль в любом из четырёх сроков ожидания означает «без ограничения». Это отдушина для случая, когда обработчик на данных заказчика законно идёт дольше: его выключают параметром, а не правкой кода. Снимать ограничения без нужды не следует - они защищают сервер от зависших соединений.

Таблица Б.3 — Маркеры доступа и вход

Параметр	По умолчанию	Назначение
JWT_SECRET	нет, обязателен	Ключ подписи маркера доступа
JWT_REFRESH_SECRET	нет, обязателен	Ключ подписи маркера продления
JWT_ACCESS_TTL	15m	Срок жизни маркера доступа
JWT_REFRESH_TTL	168h	Срок жизни маркера продления
COOKIE_SECURE	true	Передача маркера продления только по защищённому соединению
LOGIN_RATE_LIMIT_MAX	10	Попыток входа с одного адреса за интервал
LOGIN_RATE_LIMIT_WINDOW_SEC	60	Интервал подсчёта попыток, секунды

Таблица Б.4 — Защита персональных данных

Параметр	По умолчанию	Назначение
DATA_ENCRYPTION_KEY	пусто	Ключ шифрования, 64 шестнадцатеричных символа
REQUIRE_ENCRYPTION	false	Запрет запуска без ключей шифрования персональных данных и файлового архива
PD_AUDIT_RETENTION_MONTHS	36	Срок хранения журнала обращений к персональным данным

Таблица Б.5 — Ограничения обращений и загрузка файлов

Параметр	По умолчанию	Назначение
RATE_LIMIT_PER_MINUTE	200	Запросов в минуту на работника
RATE_LIMIT_WINDOW_SEC	60	Интервал подсчёта
PAGINATION_MAX_LIMIT	100	Наибольший размер страницы выдачи
UPLOAD_PATH	./uploads	Каталог хранения файлов, в поставке /app/uploads
UPLOAD_MAX_FILE_SIZE	10485760	Наибольший размер файла в байтах

Параметр	По умолчанию	Назначение
UPLOAD_ALLOWED_IMAGE_TYPES	image/jpeg, image/png, image/webp	Разрешённые типы изображений
UPLOAD_ALLOWED_DOC_TYPES	application/pdf и формат документов	Разрешённые типы документов

Таблица Б.6 — Файлы, приложенные к заявке

Параметр	По умолчанию	Назначение
APPLICATION_FILE_MAX_COUNT	30	Сколько файлов разрешено приложить к одной заявке
APPLICATION_FILE_MAX_TOTAL_SIZE	104857600	Наибольший суммарный размер файлов одной заявки в байтах, 100 МБ
APPLICATION_FILE_DRAFT_TTL	24h	Сколько хранится файл, загруженный к заявке, которую так и не отправили
APPLICATION_FILE_IMAGE_MAX_SIDE	2000	Предел длинной стороны изображения в точках; снимки крупнее уменьшаются
APPLICATION_FILE_JPEG_QUALITY	82	Качество перекодирования снимков, от 1 до 100

Таблица Б.7 — Файловый архив бланков

Параметр	По умолчанию	Назначение
ARCHIVE_PATH	./archive	Каталог файлового архива бланков внутри контейнера, в поставке /app/archive; на сервере ему соответствует ARCHIVE_HOST_PATH
ENTITY_EXPORT_PATH	пусто	Каталог, куда консольная выгрузка складывает пакет с данными организации. Пока значение не задано, команда выгрузки отказывает с подсказкой и ничего не пишет: место хранения выбирает тот, кто разворачивает систему, а в пакете лежат персональные данные целиком. Каталог обязан лежать вне каталога загрузок - по той же причине, что и каталог файлового архива

Параметр	По умолчанию	Назначение
ARCHIVE_HOST_PATH	./archive	Каталог файлового архива на диске сервера, подключаемый к контейнеру. На рабочем сервере сценарий подготовки параметров задаёт /srv/systemburo/archive; каталог создают до первого запуска и отдают пользователю прикладного сервера, см. подраздел 9.6
ARCHIVE_AGE_RECIPIENT	пусто	Открытый ключ принимающей стороны: им шифруются файлы архива. Пусто - архив пишется незашифрованным
ARCHIVE_AGE_IDENTITY	пусто	Закрытый ключ системы, вторым получателем. Без него служба не прочитает собственный архив и не соберёт выгрузку по кнопке; задаётся только вместе с предыдущим
ARCHIVE_WORKER_TICK	15s	Как часто разбирается очередь выгрузки бланков
ARCHIVE_SWEEP_INTERVAL	5m	Как часто повторяются выгрузки, сорвавшиеся по временной причине

Таблица Б.8 — Почтовая рассылка

Параметр	По умолчанию	Назначение
SMTP_HOST	пусто	Адрес почтового сервера. Пустое значение выключает отправку писем целиком
SMTP_PORT	587	Порт почтового сервера: 587 при starttls, 465 при tls
SMTP_USERNAME	пусто	Учётная запись для входа на почтовый сервер, обычно полный адрес ящика. Задаётся вместе с паролем; оба пустых означают сервер без проверки подлинности
SMTP_PASSWORD	пусто	Пароль к ней. В Яндекс 360 требуется пароль приложения, а не пароль от учётной записи
SMTP_FROM	пусто	Адрес отправителя. Обязателен при заданном адресе сервера и должен совпадать с ящиком входа, иначе письма отвергаются с ошибкой 550
SMTP_FROM_NAME	Бюро пропусков	Имя отправителя, показываемое получателю рядом с адресом
SMTP_TLS_MODE	starttls	Режим защиты соединения: starttls, tls или none. Значение none допустимо только для сервера в закрытом контуре
SMTP_TIMEOUT_SEC	15	Предельный срок ожидания ответа почтового сервера, секунды

Параметр	По умолчанию	Назначение
SMTP_RATE_PER_HOUR	400	Собственный предел отправки, писем в час. Задаётся заведомо ниже предела поставщика услуг
MAIL_RETRY_ATTEMPTS	5	Число попыток доставки, после которого письмо признаётся недоставленным
MAIL_WORKER_TICK	15s	Как часто разбирается очередь писем

Таблица Б.9 — Журналы и обслуживание

Параметр	По умолчанию	Назначение
LOG_FILE_PATH	пусто	Файл журнала, пустое значение означает вывод только в поток
LOG_MAX_SIZE_MB	100	Размер файла до смены
LOG_MAX_AGE_DAYS	30	Срок хранения файлов журнала
LOG_MAX_BACKUPS	14	Число хранимых файлов
LOG_COMPRESS	true	Сжатие при смене
REQUEST_LOG_DETAIL_DAYS	30	Глубина подробных записей журнала запросов
REQUEST_LOG_PARTITION_PRECREATE_DAYS	7	На сколько суток вперёд создаются разделы
REFRESH_TOKEN_RETENTION_DAYS	30	Через сколько суток удаляются недействительные маркеры продления
READ_NOTIFICATION_RETENTION_DAYS	30	Через сколько суток удаляются прочитанные уведомления
NOTIFICATION_RETENTION_DAYS	90	Через сколько суток удаляются непрочитанные уведомления
VAPID_PUBLIC_KEY	пусто	Открытый ключ подписи уведомлений в браузер. Пустой вместе с закрытым выключает доставку вне системы

Параметр	По умолчанию	Назначение
VAPID_PRIVATE_KEY	пусто	Закрытый ключ подписи уведомлений в браузер. Хранится как секрет
VAPID_SUBJECT	пусто	Контакт бюро для служб доставки уведомлений, вида mailto: или адрес сайта
PUSH_SUBSCRIPTION_RETENTION_DAYS	180	Через сколько суток удаляется подписка устройства, которому ни разу не удалось доставить
ANALYTICS_CACHE_REFRESH_SEC	60	Периодичность пересчёта показателей

Таблица Б.10 — Резервное копирование

Параметр	По умолчанию	Назначение
BACKUP_DIR	/var/backups/systemburo	Каталог копий на сервере
BACKUP_OPERATOR_GROUP	buro	Группа учётной записи оператора, которой открывается состояние копирования: отчёт о последнем запуске и журнал. Сами копии и их перечень остаются закрытыми. Пустое значение отключает доступ; отсутствие строки в файле означает значение по умолчанию. См. подраздел 11.4
BACKUP_AGE_RECIPIENT	пусто	Открытый ключ шифрования копий. Пока не задан, копирование останавливается с ошибкой и копию не создаёт

Параметр	По умолчанию	Назначение
BACKUP_ALLOW_UNENCRYPTED	пусто	Осознанное разрешение снимать копии без шифрования; принимается единственное значение yes. Копия создаётся открытой, о чём сообщают вывод, журнал и команда состояния
BACKUP_KEEP_DAILY	7	Сколько суточных копий хранить
BACKUP_KEEP_WEEKLY	4	Сколько недельных копий хранить
BACKUP_KEEP_MONTHLY	6	Сколько месячных копий хранить
BACKUP_UPLOADS_MODE	weekly	Как часто архивировать файлы: weekly или daily
BACKUP_S3_REMOTE	пусто	Имя настройки rclone для выгрузки вне сервера
BACKUP_S3_BUCKET	пусто	Бакет и префикс во внешнем хранилище

Таблица Б.11 — Прочие параметры

Параметр	По умолчанию	Назначение
CORS_ALLOWED_ORIGINS	http://localhost:8081	Адреса, которым разрешены обращения к интерфейсу
RESET_TIMEZONE	Europe/Moscow	Часовой пояс суточного сброса статусов
TELEGRAM_BOT_TOKEN	пусто	Отправка сообщений о сбоях во внешний сервис
TELEGRAM_CHAT_ID	пусто	Адресат сообщений о сбоях
COMPOSE_PROJECT_NAME	имя каталога; сценарий подготовки параметров задаёт systemburo	Имя установки, определяет имена томов с данными

Параметр	По умолчанию	Назначение
VITE_API_BASE_URL	нет	Адрес, по которому интерфейс обращается к серверу. Значение встраивается в образ интерфейса при сборке, поэтому после его изменения образ пересобирают

Параметры следующей таблицы прикладной сервер не читает: их берут обратный прокси проверочного стенда и панель управления базой данных. На рабочем сервере они не действуют, и сценарий подготовки параметров их туда не записывает.

Таблица Б.12 — Доступ к проверочному стенду

Параметр	По умолчанию	Назначение
BASIC_AUTH_USER	admin	Имя, которое прокси стенда спрашивает при открытии адреса
BASIC_AUTH_PASS	changeme, значение из состава поставки	Пароль к нему; сценарий подготовки параметров задаёт случайный. См. подраздел 8.5
PGADMIN_EMAIL	нет	Учётная запись входа в панель управления базой данных стенда
PGADMIN_PASSWORD	нет	Пароль к ней; сценарий подготовки параметров задаёт случайный

Приложение В. Файлы, необходимые для запуска

Перечень содержимого поставки, без которого система не соберётся и не запустится.

Таблица В.1 — Обязательные файлы и каталоги

Путь	Назначение
docker-compose.base.yml	Описание состава системы, общее для стенда и рабочего сервера
docker-compose.prod.yml	Дополнение для рабочего сервера: параметры базы, ресурсы, обратный прокси
docker-compose.staging.yml	Дополнение для проверочного стенда
Dockerfile	Сборка образа прикладного сервера
frontend/Dockerfile	Сборка образа веб-приложения
frontend/nginx.conf	Конфигурация отдачи статики внутри образа веб-приложения

Путь	Назначение
nginx/nginx.conf	Конфигурация обратного прокси рабочего сервера
nginx/staging.conf	Конфигурация обратного прокси стенда
nginx/Dockerfile.staging	Сборка образа прокси для стенда: базовый образ дополняется средством создания файла паролей
nginx/staging-entrypoint.sh	Создание файла паролей стенда при каждом запуске прокси
Makefile	Команды управления
scripts/init-env.sh	Создание файла параметров
scripts/init-tls.sh	Выпуск и продление сертификата
scripts/maintenance-off.sh	Снятие режима технических работ мимо интерфейса
scripts/backup.sh	Снятие резервной копии: выгрузка базы, архивы файлов, раскладка по срокам хранения, выгрузка вне сервера
scripts/backup-install.sh	Постановка копирования и ежемесячной проверки восстановимости на расписание
scripts/backup-status.sh	Состояние копий: свежесть, состав, режим шифрования, итог последнего запуска
scripts/backup-verify.sh	Проверка того, что копия разворачивается, во временной базе рядом с рабочей
scripts/restore.sh	Восстановление базы и загруженных файлов из копии
go.mod, go.sum	Перечень библиотек серверной части
cmd/, internal/, docs/	Исходный код серверной части и описание программного интерфейса
frontend/package.json, frontend/package-lock.json	Перечень библиотек интерфейса
frontend/src/, frontend/index.html, frontend/vite.config.js	Исходный код интерфейса

Создаются на сервере при установке и в поставку не входят:

Таблица В.2 — Создаваемое при установке

Путь	Чем создаётся
.env	make init-production
nginx/certs/	scripts/init-tls.sh
nginx/acme-webroot/	scripts/init-tls.sh при выпуске через общедоступный центр

Приложение Г. Проверочный лист ввода в эксплуатацию

Таблица Г.1 — Проверочный лист

№	Проверка	Отметка
1	Операционная система обновлена, часовой пояс задан	
2	Docker и Docker Compose установлены, версии соответствуют требованиям	

№	Проверка	Отметка
3	Дисковый массив собран в зеркало	
4	Файл параметров создан, секреты переданы в хранилище организации	
5	Ключ шифрования сохранён отдельно от сервера и от резервных копий	
6	Имя базы данных задано до первого запуска	
7	Сертификат выпущен, срок действия проверен	
8	Корневой сертификат установлен на рабочие места, если применялся собственный центр	
9	Система запущена, все службы работают	
10	Проверка состояния отвечает	
11	Обращение по незащищённому протоколу перенаправляется	
12	Учётная запись администратора создана, пароль отличается от исходного	
13	Вход выполняется, разделы открываются	
14	Межсетевой экран включён, снаружи открыты только порты 22, 80 и 443	
15	Ограничение размера журналов контейнеров настроено	
16	Резервное копирование настроено, восстановление проверено	
17	Мониторинг подключён	
18	Демонстрационные данные на рабочем сервере отсутствуют	
19	Публикация описания программного интерфейса отключена	
20	Требование шифрования персональных данных включено	
21	Доступ сервера к репозиторию исходного кода выдан и проверен, закрытая часть ключа с сервера не покидала	
22	Ключ шифрования резервных копий задан, закрытая часть унесена с сервера в хранилище секретов	
23	Каталог файлового архива создан, владелец совпадает с пользователем прикладного сервера	
24	Почтовая рассылка настроена, проверочное письмо отправлено и получено во входящих; записи SPF и DKIM домена отправителя внесены	
25	Защита от подбора пароля к серверу установлена, состояние правила проверено	
26	Вход на сервер выполняется по ключу, парольный вход отключён и проверен	
27	Работа с системой ведётся под отдельной учётной записью: в группу docker она не входит, команды выполняются через sudo с вводом пароля	

ЛИСТ РЕГИСТРАЦИИ ИЗМЕНЕНИЙ

В таблице фиксируются изменения документа. Версия повышается при выпуске новой редакции: вторая цифра при уточнениях и дополнениях, первая при переработке структуры или существенном изменении требований.

Таблица - Регистрация изменений

Версия	Дата	Содержание изменения	Внёс
1.0	28.07.2026	Первая редакция	
1.1	28.07.2026	Сверка с реализацией: уточнены требования к версии Docker Compose и порядок развёртывания стенда	
1.2	28.07.2026	Дополнен порядок работы с режимом технических работ: вход супер-администратора и аварийное снятие командой	
1.3	31.07.2026	Описана команда очистки накопленных данных и сроки хранения по группам	
1.4	31.07.2026	Уточнено, что сроки автоматической уборки задаются в описании службы, а не в файле параметров	
1.5	31.07.2026	Описаны обзор занятого места по таблицам, исключение групп из очистки и оговорка о том, что удаление строк не возвращает место операционной системе	
1.6	31.07.2026	Описано сужение очистки внутри группы: отрезок времени, тип сущности в журнале действий и отдельный пост для суточных слепков	
1.7	31.07.2026	Описано резервное копирование: состав копии, сроки хранения, настройка, проверка восстановимости и порядок восстановления	
1.8	31.07.2026	Добавлен способ создать ключи шифрования копий без установки средства на сервер	
1.9	31.07.2026	В разделе о копировании указано, где именно выполняются команды, и добавлен разбор причин сбоя по сообщениям журнала	
1.10	31.07.2026	Дополнены таблицы сообщений копирования: шаги файлов и архива бланков, сообщения проверки восстановимости	
1.11	31.07.2026	Описана подготовка каталога файлового архива бланков на сервере	
1.12	31.07.2026	Исправлены ссылки на подраздел об очистке накопленных данных	
1.13	01.08.2026	Уточнён состав пары ключей шифрования копий и порядок переноса закрытого ключа; в примерах восстановления указаны контуры и способ выбрать копию	
1.14	01.08.2026	Разобраны случаи прерванного восстановления и порядок ручного запуска после него; описана метка в имени копии	

Версия	Дата	Содержание изменения	Внёс
1.15	01.08.2026	Описан ход восстановления: нумерация шагов, время выполнения и полоса объёма	
1.16	01.08.2026	Единое правило хранения секретов и порядок действий при их утрате	
1.17	01.08.2026	Файловый архив: фоновое наполнение и ночная сверка, раздел администрирования и выгрузка за период; параметры архива внесены в приложение Б	
1.18	01.08.2026	Лист регистрации изменений разделён по документам: у каждого своя редакция и свой перечень изменений	
1.19	02.08.2026	Описано восстановление давней копии на текущую версию системы и порядок действий, когда проверка восстановимости не прошла	
1.20	02.08.2026	Перечень копий для восстановления смотрят по состоянию копирования: дата словами, размер и метка вместо машинного имени файла	
1.21	03.08.2026	Добавлен подраздел о выдаче каталога архива по сети; уточнены пороги места и остановка очереди выгрузки, пределы восстановления удалённых файлов и настоящая причина запрета вкладывать архив в каталог загруженных файлов; добавлен разбор сбоев выгрузки из архива	
1.22	04.08.2026	Настройка файлового архива выполняется целью таке наравне с прочими командами обслуживания; описан возврат каталога архива из резервной копии; уточнены сводка раздела администрирования и порядок изменения предела одной выгрузки	
1.23	04.08.2026	Добавлен разбор состояний выгрузки бланка: что означает каждое и что по нему делать дежурному	
1.24	04.08.2026	Добавлен разбор случая, когда бланки не появляются в каталоге архива	
1.25	04.08.2026	Указано, чем автоматическое обновление стенда отличается от ручного развёртывания со сборкой образов на сервере	
1.26	05.08.2026	Приведено в соответствие описание раздела файлового архива: вкладки обзора и ленты записей, состав показателей, отбор строк по состоянию	
1.27	05.08.2026	Уточнено, что панель управления базой данных на стенде поднимается по требованию отдельной командой	
1.28	05.08.2026	По итогам первого включения архива на стенде: владелец каталога, созданного без указания пути, сроки повтора после устранения причины, признак запрета доступа в ленте, предел длины пути при выборе шаблона	
1.29	05.08.2026	Состояния выгрузки названы так же, как в ленте архива; отмечено, что образы убираются при выпуске новой версии	
1.30	06.08.2026	Описано наполнение проверочного стенда вымышленными данными: отметка экземпляра, заготовки объёма, партии и их удаление	

Версия	Дата	Содержание изменения	Внёс
1.31	06.08.2026	Описано ограничение доступа к проверочному стенду: устройство запроса имени и пароля, адреса, отвечающие без него, срок действия однажды введённого пароля, смена пары, отключение и обратное включение; параметры доступа к стенду добавлены в приложение Б, сценарий создания файла паролей - в приложение В	
1.32	06.08.2026	Приложение параметров дополнено настройками файлов, прикладываемых к заявке	
1.33	06.08.2026	Описан срок хранения непрочитанных уведомлений и добавлен задающий его параметр	
1.34	07.08.2026	Приложение параметров дополнено ключами доставки уведомлений вне системы и сроком хранения подписок устройств; уточнены пределы файлов заявки	
1.35	07.08.2026	Описано включение шифрования файлового архива: создание ключей, порядок хранения, чтение файлов и шифрование раздела	
1.36	07.08.2026	Описан состав папки заявки в архиве: бланки, машиночитаемое описание и приложенные файлы	
1.37	08.08.2026	Описан перевод ранее записанных файлов архива в шифрованный вид и распространение запрета запуска без ключей на файловый архив	
1.38	08.08.2026	Уточнено, что через систему файлы архива скачиваются расшифрованными: ключ нужен только при чтении каталога напрямую	
1.39	08.08.2026	Приложение параметров: перечень ограничений и файлов разделён на обращения, файлы заявки и файловый архив	
1.40	09.08.2026	Перечень копий дополнен составом копии и её архивами; описан просмотр состояния стороннего каталога копий	
1.41	10.08.2026	Добавлены гриф конфиденциальности и лист ограничений на использование: порядок развёртывания и параметры установки не подлежат передаче третьим лицам	
1.42	11.08.2026	Наполнение стенда: отметки прохода описаны отдельно от создаваемых записей, добавлено согласие на обработку данных у заводимых работников	
1.43	11.08.2026	Копирование без ключа шифрования описано как отказ, а не предупреждение; добавлен параметр явного разрешения незашифрованных копий	
1.44	11.08.2026	Описано получение исходного кода из репозитория: адрес, выдача и отзыв доступа, порядок для площадки без доступа в сеть общего пользования; перечни поставки дополнены сценариями резервного копирования и восстановления; описаны набор параметров рабочего сервера и права на файл параметров	

Версия	Дата	Содержание изменения	Внёс
1.45	11.08.2026	Уточнено, что число отметок прохода в предварительном показе наполнения стенда приблизительное и может оказаться больше	
1.46	11.08.2026	Описана настройка почтовой рассылки: подключение к почтовому серверу поставщика услуг или организации, передача параметров прикладному серверу, проверочное письмо, записи SPF и DKIM у домена отправителя, исходящий порт и пределы отправки; добавлен разбор случая, когда письма не приходят; параметры почты внесены в приложение Б, исходящие соединения - в приложение А	
1.47	11.08.2026	Описана плановая смена паролей в разделе эксплуатации: включение и настройки, показания блока состояния, ручной прогон с обрывом сеансов работников, учётные записи без адреса почты, смена пароля отдельному работнику; добавлен разбор случая, когда пароли не меняются	
1.48	11.08.2026	В управление учётными записями добавлен вход в систему от имени работника: как войти и вернуться, срок сеанса, что в режиме закрыто и почему он не заменяет смену пароля	
1.49	11.08.2026	Переписана эксплуатация срока действия паролей: по истечении срока система требует смены при входе и ничего не рассылает, почта для этого не нужна; обновление паролей всем работникам и смена из карточки описаны как исключительные действия; разделена диагностика этих двух случаев	
1.50	12.08.2026	Описано заведение учётной записи: пароль придумывает система и высылает письмом, свой пароль работник задаёт при первом входе; описан запрет повторного использования паролей	
1.51	11.08.2026	Описано ограничение доступа к серверу при установке: межсетевой экран и особенность портов, опубликованных контейнерами, защита от подбора пароля и переход на вход по ключу; проверочный лист дополнен соответствующими пунктами	
1.52	11.08.2026	Модель доступа на сервере приведена к фактической: учётная запись оператора без членства в группе docker, разрешение на две команды через sudo, исключение для каталога архива и для системы контроля версий; команды документа приведены к этой модели, названы границы даваемой ею защиты	
1.53	11.08.2026	Описан запрос подтверждения перед командами рабочего сервера, ломающими данные, и границы даваемой им защиты; описан доступ оператора к состоянию копирования без полных прав, включая случаи отсутствующей группы и отключённого доступа; в перечень параметров добавлена группа оператора копирования	

Версия	Дата	Содержание изменения	Внёс
1.54	12.08.2026	В приложение Б внесены параметры пула соединений с базой данных и сроков ожидания прикладного сервера	